

NỀN TẢNG XÃ HỘI

Thiết kế hệ thống chi tiết - Bản hoàn thiện - Phiên bản 3.0

Tài liệu	Thiết kế hệ thống chi tiết / ERD / UML / đặc tả chức năng
Trạng thái	Bản hoàn thiện dùng làm cơ sở triển khai và nghiệm thu
Phạm vi	P0 bắt buộc, P1 hoàn thiện sản phẩm, P2 mở rộng có điều kiện và phần thiết kế cho tương lai
Kiến trúc	Vi dịch vụ, hướng sự kiện, CQRS theo nhu cầu và xử lý lập an toàn
Ngày cập nhật	05/09/2026

Tài liệu khóa ranh giới dữ liệu, hợp đồng và tiêu chí nghiệm thu. Mọi thay đổi phá vỡ phải được ghi nhận bằng quyết định kiến trúc và cập nhật đồng thời OpenAPI, AsyncAPI, kiểm thử hợp đồng và tài liệu.

Mục lục

1. Tổng quan thiết kế.....	8
1.1 Phạm vi triển khai.....	8
1.2 Yêu cầu phi chức năng (NFR).....	9
1.3 Giả định và ràng buộc.....	10
1.4 Danh mục rủi ro.....	10
1.5 Lộ trình triển khai.....	11
2. Ma trận sở hữu dịch vụ và dữ liệu.....	12
3. Tổng quan UML.....	13
4. ERD - Tài khoản và mạng xã hội.....	14
4.1 Các bảng của dịch vụ tài khoản.....	14
4.2 Các bảng của dịch vụ mạng xã hội.....	15
5. ERD - Cộng đồng và trò chuyện.....	16
6. ERD - Bảng tin, phương tiện và AI/tìm kiếm.....	18
7. ERD - Thương mại.....	19
8. Danh mục hợp đồng API.....	20
9. Danh mục sự kiện Kafka.....	23
10. Hợp đồng SignalR và LiveKit.....	25
10.1 Hợp đồng cơ sở của SignalR Hub.....	25
10.2 Hợp đồng LiveKit.....	25
11. Sơ đồ trình tự cốt lõi.....	26
12. Máy trạng thái.....	28
13. Đặc tả chức năng chi tiết.....	29
13.1 Dịch vụ tài khoản.....	29
13.2 Dịch vụ mạng xã hội.....	32
13.3 Cộng đồng và RTC.....	36
13.4 Trò chuyện và thời gian thực.....	38
13.5 Bảng tin và gợi ý.....	41
13.6 Dịch vụ phương tiện.....	43
13.7 Dịch vụ thương mại.....	45
13.8 Dịch vụ AI và tìm kiếm.....	47
14. Chỉ mục cơ sở dữ liệu và xử lý đồng thời.....	50
15. Bộ nhớ đệm và bản chiếu dữ liệu.....	51
16. Bảo mật.....	52
16.1 Bảo vệ dữ liệu định danh cá nhân.....	52
16.2 Mã hóa khi truyền và khi lưu.....	52
16.3 Giới hạn tần suất và điều tiết tải.....	52
16.4 Kiểm tra và làm sạch dữ liệu.....	53
16.5 Chống XSS và CSRF.....	53
16.6 Kiểm duyệt nội dung bằng AI - thiết kế cho tương lai.....	53
17. Xử lý lỗi, thử lại và DLQ.....	54

18. Khả năng quan sát và kịch bản kiểm thử.....	55
18.1 Giám sát và cảnh báo.....	55
18.2 Kịch bản kiểm thử.....	55
19. Thiết kế triển khai.....	57
20. Hướng phát triển.....	58
21. Thuật ngữ.....	59
22. Thiết kế sẵn sàng triển khai.....	60
22.1 Cấu trúc mã nguồn và trách nhiệm.....	60
22.2 Outbox, Inbox và xử lý lặp an toàn.....	60
22.3 Quy ước API, token và thời gian.....	61
22.4 Công chất lượng CI/CD.....	61
22.5 Kế hoạch triển khai hai tuần đầu.....	62
23. Phạm vi phát hành và cổng chuyển giai đoạn.....	63
23.1 Mức ưu tiên P0/P1/P2.....	63
23.2 Cổng chuyển giai đoạn.....	63
24. Ma trận truy vết triển khai.....	64
24.1 Tài khoản.....	64
24.2 Mạng xã hội.....	64
24.3 Cộng đồng và RTC.....	65
24.4 Trò chuyện và thời gian thực.....	66
24.5 Bảng tin và gợi ý.....	66
24.6 Phương tiện.....	67
24.7 Thương mại.....	67
24.8 AI và tìm kiếm.....	68
24.9 Báo cáo và điều hành nội dung.....	68
25. Hợp đồng API và sự kiện mẫu.....	69
25.1 Quy ước HTTP và mã trạng thái.....	69
25.2 Mẫu tạo bài viết.....	69
25.3 Mẫu lỗi chuẩn.....	70
25.4 Cập nhật lạc quan và yêu cầu lặp an toàn.....	70
25.5 Mẫu vỏ sự kiện Kafka.....	71
26. Quy ước Kafka và vận hành sự kiện.....	71
26.1 Danh mục topic cơ sở.....	71
26.2 Chính sách thử lại và DLQ.....	72
26.3 Phiên bản, thử tự và phát lại.....	72
27. Danh tính, phân quyền và mô hình đe dọa.....	72
27.1 Claim của access token.....	72
27.2 Xác thực nội bộ và xoay khóa.....	73
27.3 Mô hình đe dọa.....	73
28. Vòng đời dữ liệu và xóa tài khoản.....	74
28.1 Phân loại và lưu giữ dữ liệu.....	74
28.2 ACC-11 - Yêu cầu xóa và khôi phục tài khoản.....	74

28.3 Lan truyền và đối soát.....	75
29. Báo cáo vi phạm và điều hành nội dung.....	75
29.1 Dữ liệu và trạng thái.....	76
30. Sao lưu, khôi phục và ngân sách tài nguyên.....	79
30.1 Mục tiêu RPO/RTO.....	79
30.2 Chính sách sao lưu.....	79
30.3 Ngân sách tài nguyên.....	79
31. Phát hành, di trú lược đồ và quay lui.....	80
31.1 Quy tắc di trú và quay lui.....	80
31.2 Quản lý cấu hình, phụ thuộc và bí mật.....	80
32. Danh mục quyết định kiến trúc.....	82
33. Nghiệm thu và hồ sơ bàn giao.....	83
33.1 Định nghĩa hoàn thành.....	83
33.2 Kịch bản trình diễn.....	83
33.3 Hồ sơ bàn giao.....	84

Danh mục hình

Số hiệu	Tên hình
Hình 1	Bối cảnh hệ thống
Hình 2	Ranh giới dịch vụ và quyền sở hữu dữ liệu
Hình 3	Tổng quan ca sử dụng
Hình 4	Thành phần thời gian thực, phương tiện và sự kiện
Hình 5	ERD của tài khoản và mạng xã hội
Hình 6	ERD của cộng đồng và trò chuyện
Hình 7	ERD của bảng tin, phương tiện và AI/tìm kiếm
Hình 8	ERD của thương mại
Hình 9	Tạo bài viết qua Outbox/Kafka đến Bảng tin
Hình 10	Lưu tin nhắn và phát qua SignalR
Hình 11	Tham gia kênh thoại LiveKit
Hình 12	RAG giới hạn theo quyền truy cập
Hình 13	Quy trình thanh toán đơn giản hóa
Hình 14	Máy trạng thái đơn hàng
Hình 15	Máy trạng thái tải lên và xử lý phương tiện
Hình 16	Sơ đồ triển khai
Hình 17	Luồng xử lý Outbox/Inbox
Hình 18	Mô hình dữ liệu báo cáo và điều hành nội dung

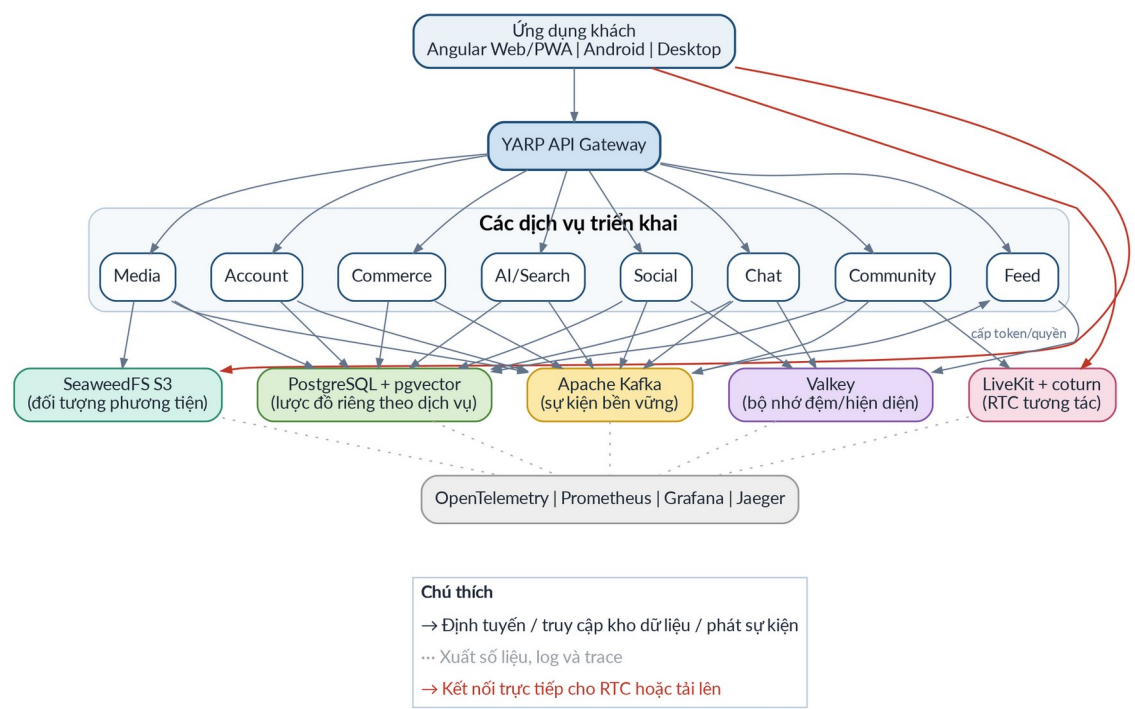
Danh mục bảng

Số hiệu	Tên bảng
Bảng 1	Phạm vi trong và ngoài kế hoạch 6 tháng
Bảng 2	Yêu cầu phi chức năng
Bảng 3	Danh mục rủi ro
Bảng 4	Lộ trình triển khai
Bảng 5	Ma trận sở hữu dịch vụ và dữ liệu
Bảng 6	Các bảng của dịch vụ tài khoản
Bảng 7	Các bảng của dịch vụ mạng xã hội
Bảng 8	Quyết định thiết kế cho cộng đồng và trò chuyện
Bảng 9	Nguồn dữ liệu chuẩn của bảng tin, phương tiện và AI/tìm kiếm
Bảng 10	Các bảng của dịch vụ thương mại
Bảng 11	Danh mục hợp đồng API
Bảng 12	Danh mục sự kiện Kafka
Bảng 13	Hợp đồng cơ sở của SignalR Hub
Bảng 14	Chỉ mục và xử lý đồng thời
Bảng 15	Bộ nhớ đệm và bản chiếu dữ liệu
Bảng 16	Ma trận bảo mật
Bảng 17	Xử lý lỗi, thử lại và DLQ
Bảng 18	Chỉ số giám sát và cảnh báo
Bảng 19	Kịch bản kiểm thử
Bảng 20	Hướng phát triển
Bảng 21	Thuật ngữ
Bảng 22	Cấu trúc mã nguồn và trách nhiệm
Bảng 23	Các bảng hạ tầng dùng chung
Bảng 24	Quy ước API, token và thời gian
Bảng 25	Cổng chất lượng CI/CD
Bảng 26	Kế hoạch triển khai hai tuần đầu
Bảng 27	Mức ưu tiên và tiêu chí hoàn thành
Bảng 28	Cổng chuyển giai đoạn
Bảng 29	Ma trận truy vết - Tài khoản
Bảng 30	Ma trận truy vết - Mạng xã hội
Bảng 31	Ma trận truy vết - Cộng đồng và RTC
Bảng 32	Ma trận truy vết - Trò chuyện và thời gian thực
Bảng 33	Ma trận truy vết - Bảng tin và gợi ý
Bảng 34	Ma trận truy vết - Phương tiện
Bảng 35	Ma trận truy vết - Thương mại

Số hiệu	Tên bảng
Bảng 36	Ma trận truy vết - AI và tìm kiếm
Bảng 37	Ma trận truy vết - Báo cáo và điều hành nội dung
Bảng 38	Quy ước HTTP và mã trạng thái
Bảng 39	Cơ chế xử lý đồng thời và yêu cầu lặp an toàn
Bảng 40	Danh mục topic Kafka cơ sở
Bảng 41	Chính sách thử lại và DLQ
Bảng 42	Quy tắc phiên bản, thử tự và phát lại sự kiện
Bảng 43	Claim của access token
Bảng 44	Xác thực nội bộ và xoay khóa
Bảng 45	Mô hình đe dọa và kiểm soát
Bảng 46	Phân loại và thời hạn lưu giữ dữ liệu
Bảng 47	Đặc tả ACC-11
Bảng 48	Lan truyền yêu cầu xóa tài khoản
Bảng 49	Các bảng của khối báo cáo và điều hành
Bảng 50	Trạng thái và hành động điều hành
Bảng 51	Hợp đồng API và sự kiện điều hành
Bảng 52	Đặc tả MOD-01
Bảng 53	Đặc tả MOD-02
Bảng 54	Đặc tả MOD-03
Bảng 55	Đặc tả MOD-04
Bảng 56	Mục tiêu RPO và RTO
Bảng 57	Chính sách sao lưu và kiểm thử khôi phục
Bảng 58	Ngân sách tài nguyên theo cấu hình
Bảng 59	Quy tắc di trú lược đồ và quay lui
Bảng 60	Quản lý cấu hình, phụ thuộc và bí mật
Bảng 61	Danh mục quyết định kiến trúc
Bảng 62	Định nghĩa hoàn thành
Bảng 63	Kịch bản trình diễn và bằng chứng
Bảng 64	Hồ sơ bàn giao bắt buộc

1. Tổng quan thiết kế

Tài liệu chuyển đặc tả cơ sở thành thiết kế có thể triển khai: xác định quyền sở hữu thực thể, lược đồ quan hệ, hợp đồng API, sự kiện, thời gian thực, luồng tuần tự, máy trạng thái và hành vi chấp nhận của từng chức năng.



Hình 1 - Bối cảnh hệ thống

Quy tắc thiết kế
Mỗi thực thể giao dịch chỉ có một dịch vụ sở hữu. Dịch vụ khác muốn dùng dữ liệu phải gọi hợp đồng hoặc duy trì bản chiếu từ sự kiện. Việc dùng chung một máy chủ PostgreSQL không cho phép truy vấn trực tiếp xuyên cơ sở dữ liệu dịch vụ.

1.1 Phạm vi triển khai

Phạm vi dưới đây tách rõ phần bắt buộc hoàn thành trong 6 tháng và phần chỉ thiết kế cho tương lai, không bắt buộc triển khai. Chi tiết các hạng mục tương lai được trình bày tại mục 20.

Bảng 1 - Phạm vi trong và ngoài kế hoạch 6 tháng

Miền chức năng	Mục tiêu trong kế hoạch 6 tháng	Thiết kế cho tương lai
Tài khoản và xác thực	Đăng ký, đăng nhập, xoay vòng refresh token, hồ sơ, thiết lập riêng tư, OTP, Google OAuth và vòng đời xóa tài khoản (ACC-01 đến ACC-11).	2FA/MFA, giao diện quản lý phiên nhiều thiết bị và nhà cung cấp OAuth khác Google.
Mạng xã hội	Bài viết, bình luận, tương tác, theo dõi, chặn, chia sẻ, báo cáo vi phạm thủ công và bằng tin dùng con trỏ/bản chiếu (SOC-01 đến SOC-10, FED-01 đến FED-05, MOD-01 đến MOD-04).	Gợi ý nâng cao bằng duyệt đồ thị hoặc Apache AGE; kiểm duyệt tự động bằng AI.
Cộng đồng và RTC	Cộng đồng, kênh, vai trò, quyền; thoại, video, chia sẻ màn hình qua LiveKit và cấp token tham gia (COM-01 đến COM-05, RTC-01 đến RTC-03).	Ghi hình, phụ đề trực tiếp, LiveKit nhiều nút và phát công khai qua SRS/HLS.
Trò chuyện và thời gian thực	Hội thoại trực tiếp/nhóm, CRUD tin nhắn, tương tác, trạng thái đang nhập, hiện diện, đã đọc, hộp thông báo	Chuyển nội dung tin nhắn sang Cassandra khi số liệu đo cho thấy PostgreSQL không còn phù hợp.

Miền chức năng	Mục tiêu trong kế hoạch 6 tháng	Thiết kế cho tương lai
	và lời mời cuộc gọi (CHT-01 đến CHT-09).	
Phương tiện	Phiên tải lên, tải trực tiếp, xác minh, xử lý phương tiện và tin nhắn thoại (MED-01 đến MED-06).	Tối ưu phân phối qua CDN và xử lý chuyên sâu bằng GPU.
Thương mại	Tin đăng, tồn kho, giữ hàng, đơn hàng, thanh toán giả lập và Saga đơn giản hóa (MKT-01 đến MKT-07).	Cổng thanh toán thật, hoàn tiền và tranh chấp.
AI và tìm kiếm	Embedding, tìm kiếm ngữ nghĩa, trợ lý RAG, tóm tắt và chuyển lời nói thành văn bản (AI-01 đến AI-05).	Đánh chỉ mục OpenSearch tùy chọn và phục vụ mô hình bằng GPU/vLLM.
Hạ tầng và triển khai	Docker Compose một nút, Kafka một broker, PostgreSQL, Caddy, cổng API YARP, quan sát, sao lưu và khôi phục có kiểm chứng.	Kubernetes, nhân bản/phân mảnh cơ sở dữ liệu, Kafka nhiều broker và mô hình nhiều vùng.

1.2 Yêu cầu phi chức năng (NFR)

Các chỉ tiêu dưới đây là mức chấp nhận cho môi trường một nút. Chúng được dùng để xây dựng ca kiểm thử và tiêu chí nghiệm thu, không phải cam kết mức dịch vụ cho môi trường sản xuất.

Bảng 2 - Yêu cầu phi chức năng

Hạng mục	Mục tiêu cơ sở	Cách đo hoặc thực thi
Độ trễ API đọc	p95 < 300 ms cho điểm cuối đọc không tìm kiếm trên bộ dữ liệu thử nghiệm.	Đo bằng k6 và OpenTelemetry; truy vấn N+1 được xem là lỗi.
Độ trễ API ghi	p95 < 500 ms cho thao tác ghi có Outbox.	Tính cả việc ghi dữ liệu nghiệp vụ và Outbox trong cùng giao dịch.
Phát thời gian thực qua SignalR	< 200 ms từ lúc phát đến máy khách trong cùng vùng mạng.	Đo bằng dấu thời gian trong DTO tin nhắn.
Tham gia RTC qua LiveKit	< 2 giây từ lúc yêu cầu token đến trạng thái đã kết nối.	Không tính độ trễ bất thường do STUN/TURN hoặc mạng yếu.
Tính sẵn sàng cơ sở	Vận hành theo khả năng tốt nhất trên một nút; không cam kết SLA nhiều số 9.	Mô hình nhiều nút thuộc hướng phát triển.
Độ bền dữ liệu	Không mất dữ liệu đã cam kết khi khởi động lại container có volume.	Dùng PostgreSQL WAL và thời gian lưu topic Kafka tối thiểu 7 ngày.
Mô hình nhất quán	Nhất quán mạnh trong từng dịch vụ; nhất quán cuối giữa các dịch vụ.	Outbox bảo đảm phát ít nhất một lần; bộ nhận sự kiện phải xử lý lặp an toàn.
Xử lý đồng thời	Chịu tải mô phỏng khoảng 50-100 người dùng đồng thời.	Dùng k6 với kịch bản đọc, ghi, chat và giữ tồn kho.
Bảo mật	Access token sống ngắn, xoay vòng refresh token và giới hạn tần suất OTP.	Thực thi theo mục 16 và kiểm thử các trường hợp từ chối.
Khả năng quan sát	Mọi yêu cầu có traceId xuyên dịch vụ.	OpenTelemetry và Jaeger/Zipkin; có thể tắt cấu hình đầy đủ khi thiếu tài nguyên.
Độ phủ kiểm thử	Kiểm thử đơn vị cho quy tắc cốt lõi và ít nhất một kiểm thử tích hợp cho mỗi dịch vụ.	Không yêu cầu 100% độ phủ; ưu tiên quy tắc nghiệp vụ và luồng lỗi.
Khôi phục dữ liệu	RPO <= 24 giờ; RTO <= 4 giờ cho nhóm P0.	Sao lưu tự động, kiểm tra checksum và diễn tập khôi phục trên môi trường tách biệt.
Xóa tài khoản	Ẩn truy cập trong 5 phút; xóa cứng dữ liệu định danh trong tối đa 45 ngày nếu không có giữ lại hợp lệ.	Theo dõi account_deletion_request, sự kiện liên dịch vụ và cảnh báo công việc quá hạn.
Chất lượng phát hành	100% tiêu chí P0 đạt; không còn lỗi Critical/High hoặc lỗ hổng nghiêm trọng chưa có ngoại lệ được phê duyệt.	Bắt buộc qua CI/CD, kiểm thử hợp đồng, quét bí mật/phụ thuộc và hồ sơ nghiệm thu.

1.3 Giả định và ràng buộc

Giả định

- Một lập trình viên thực hiện toàn bộ hệ thống trong 6 tháng.
- Các số liệu hiệu năng được đo trên dữ liệu mô phỏng và tải thử nghiệm, không đại diện cho lưu lượng sản xuất.
- Hạ tầng triển khai cơ sở là một VPS, vận hành theo mô hình một nút bằng Docker Compose.
- Không phụ thuộc vào dịch vụ trả phí bất buộc; OTP được gửi qua SMTP cấu hình được và thanh toán sử dụng nhà cung cấp giả lập.
- Người dùng thử nghiệm và dữ liệu kiểm thử không đại diện cho quy mô vận hành lớn.

Ràng buộc

- Giới hạn CPU và RAM của VPS cho phép tắt cấu hình OpenSearch hoặc bộ quan sát đầy đủ khi không cần thiết (xem mục 19).
- Kafka chạy một broker nên không có tính sẵn sàng cao; rủi ro gián đoạn sự kiện được ghi nhận và giảm thiểu bằng Outbox, thử lại và DLQ.
- LiveKit chạy một nút nên số phòng và người tham gia đồng thời bị giới hạn so với mô hình nhiều nút.
- Trong thời hạn 6 tháng, ưu tiên hoàn thành luồng nghiệp vụ cốt lõi trước khi tối ưu hiệu năng chuyên sâu.

1.4 Danh mục rủi ro

Các rủi ro kỹ thuật chính và phương án giảm thiểu phải được rà soát tại mỗi mốc triển khai.

Bảng 3 - Danh mục rủi ro

Rủi ro	Tác động	Khả năng	Phương án giảm thiểu
Kafka một broker ngừng hoạt động làm chậm đồng bộ giữa các dịch vụ.	Cao	Trung bình	Outbox, thử lại có giãn cách, DLQ, bộ nhận sự kiện xử lý lập an toàn và cảnh báo broker.
Một máy chủ PostgreSQL dừng chung ngừng hoạt động làm nhiều dịch vụ gián đoạn.	Cao	Trung bình	Sao lưu định kỳ, volume bền vững, quy trình phục hồi và kiểm thử khôi phục.
LiveKit hoặc SFU quá tải khi có nhiều phòng thoại/video đồng thời.	Trung bình	Trung bình	Giới hạn số phòng/người tham gia, theo dõi CPU/RAM và xác định ngưỡng dung lượng đã kiểm thử.
Email OTP gửi chậm hoặc thất bại do nhà cung cấp SMTP giới hạn.	Trung bình	Trung bình	Xếp hàng và thử lại bất đồng bộ; API luôn trả phản hồi chung và không phụ thuộc việc gửi thành công tức thời.
Rò rỉ bí mật hoặc khóa API trong mã nguồn và nhật ký.	Cao	Thấp	Dùng biến môi trường hoặc kho bí mật, không commit bí mật và che dữ liệu nhạy cảm trong nhật ký.
AI/RAG trả lời sai lệch hoặc truy xuất dữ liệu ngoài quyền.	Cao	Trung bình	Giới hạn truy xuất theo nguồn và quyền; kiểm tra quyền trước khi đưa dữ liệu vào ngữ cảnh; ghi nguồn tham chiếu.
Tranh chấp khi nhiều yêu cầu cùng cập nhật bài viết, tương tác hoặc tồn kho.	Trung bình	Trung bình	Phiên bản lạc quan, ràng buộc duy nhất, cập nhật nguyên tử hoặc khóa đồng trong giao dịch ngắn.
Bộ nhận sự kiện Kafka bị trễ khi lưu lượng sự kiện tăng đột biến.	Trung bình	Thấp	Tiêu thụ theo lô, backpressure, giám sát độ trễ và tăng số bộ nhận sự kiện theo số phân vùng.
Không đủ thời gian hoàn thành toàn bộ phạm vi 6 tháng.	Cao	Trung bình	Ưu tiên Tài khoản, Mạng xã hội, Bảng tin và Trò chuyện; AI nâng cao và Thương mại có thể giảm phạm vi khi chậm tiến độ.
Lỗi được phát hiện muộn do thiếu kiểm thử tích hợp.	Trung bình	Trung bình	Viết ca kiểm thử theo NFR từ sớm và bắt buộc chạy kiểm thử trong CI trước khi hợp nhất.
Lạm dụng báo cáo hàng loạt hoặc điều hành sai quyền.	Cao	Trung bình	Giới hạn tần suất, chống báo cáo trùng, quyền tối thiểu, hàng đợi có phân công và nhật ký hành động bất biến.
Yêu cầu xóa tài khoản không được áp dụng đầy đủ ở mọi dịch vụ.	Cao	Thấp	Theo dõi trạng thái từng dịch vụ, xử lý lập an toàn, cảnh báo quá hạn và tác vụ đối soát/purge định kỳ.

1.5 Lộ trình triển khai

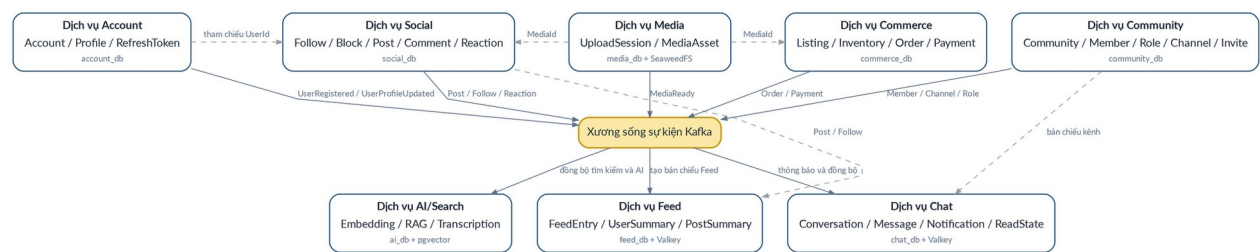
Lộ trình 6 tháng được chia theo giai đoạn và kết thúc bằng kiểm thử, giám sát, hoàn thiện tài liệu và bàn giao.

Bảng 4 - Lộ trình triển khai

Giai đoạn	Thời gian	Nội dung chính	Kết quả
Giai đoạn 0 - Nền tảng	Tuần 1-2	Khởi tạo kho mã, CI/CD, Docker Compose, các thành phần dùng chung và dịch vụ tài khoản cho đăng ký/đăng nhập/xoay vòng token.	API tài khoản chạy xuyên suốt; di trú lược đồ, nhật ký, kiểm tra sức khỏe và Outbox/Inbox hoạt động.
Giai đoạn 1 - Mạng xã hội và trò chuyện cốt lõi	Tuần 3-8	Mạng xã hội, bản chiếu bảng tin, trò chuyện qua SignalR, quyền truy cập và kiểm thử xử lý lặp.	Đạt cổng P0: luồng cốt lõi, bảo mật, quan sát và kịch bản lỗi chạy xuyên suốt.
Giai đoạn 2 - Cộng đồng, phương tiện và điều hành	Tuần 9-14	Cộng đồng/RTC, chuỗi tải lên/xử lý phương tiện, OTP, xóa tài khoản và báo cáo vi phạm thủ công; thương mại chỉ bắt đầu khi P0 đạt.	Đạt cổng P1; chức năng sản phẩm chính hoàn chỉnh và không phát sinh nợ kỹ thuật nghiêm trọng.
Giai đoạn 3 - Mở rộng và gia cố	Tuần 15-18	Thương mại, AI/tìm kiếm, RAG, tóm tắt và chuyển lời nói thành văn bản theo năng lực còn lại; hoàn thiện kiểm soát bảo mật.	P2 được hoàn thành theo thứ tự ưu tiên; phần chưa đạt được chuyển sang hướng phát triển mà không làm giảm chất lượng P0/P1.
Giai đoạn 4 - Kiểm thử và tài liệu	Tuần 19-22	Kiểm thử NFR, hợp đồng, lỗi, bảo mật, di trú, khôi phục; sửa lỗi và đồng bộ OpenAPI/AsyncAPI/tài liệu.	Đạt tiêu chí nghiệm thu; không còn lỗi nghiêm trọng hoặc thay đổi hợp đồng chưa được quản lý.
Giai đoạn 5 - Giám sát và bàn giao	Tuần 23-24	Bảng điều khiển, cảnh báo, quy trình vận hành, sao lưu/khôi phục, diễn tập triển khai và chuẩn bị bằng chứng.	Đạt cổng phát hành; hồ sơ bàn giao đầy đủ và hệ thống có thể dựng lại bằng quy trình đã kiểm chứng.

2. Ma trận sở hữu dịch vụ và dữ liệu

Ma trận này là nguồn tham chiếu khi triển khai mã nguồn. Không tạo kho dữ liệu hoặc bộ điều khiển cho một thực thể trước khi xác định rõ dịch vụ sở hữu và ranh giới dữ liệu.



Hình 2 - Ranh giới dịch vụ và quyền sở hữu dữ liệu

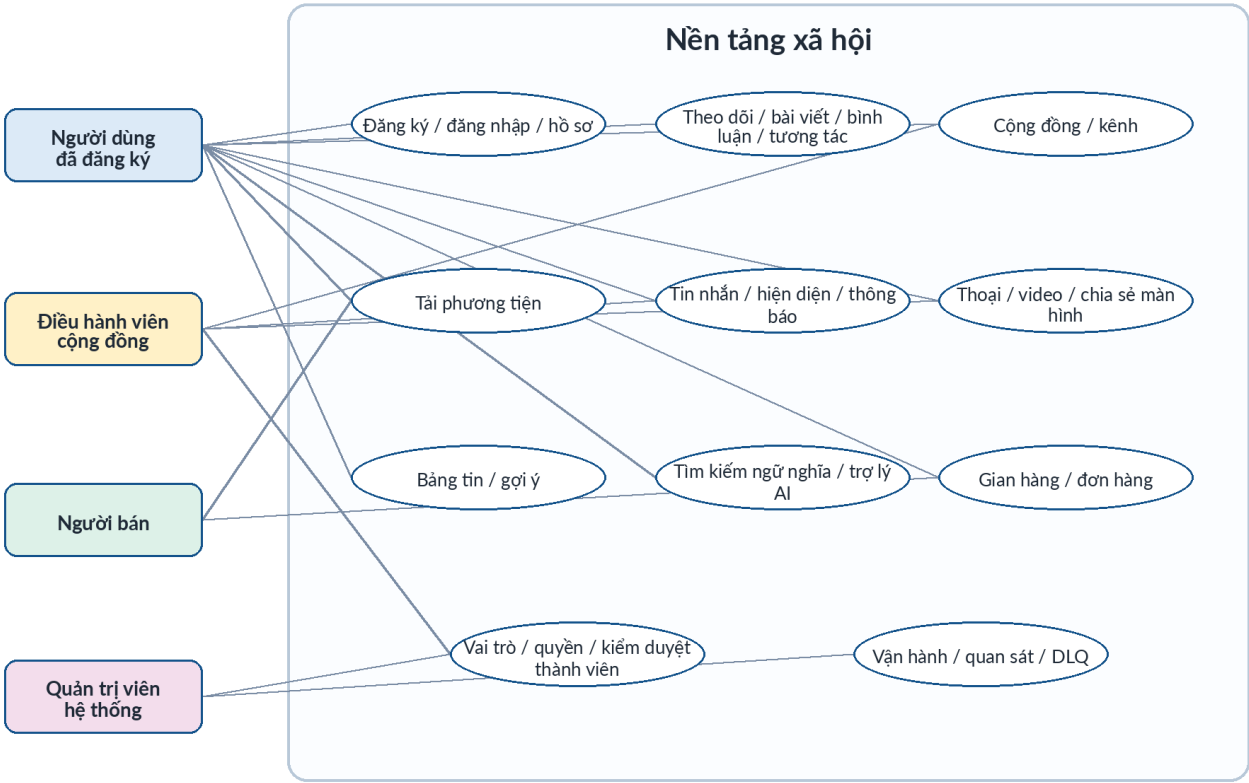
Bảng 5 - Ma trận sở hữu dịch vụ và dữ liệu

Dịch vụ	Thực thể sở hữu	Kho dữ liệu	Sự kiện chính
Tài khoản	Account, Profile, RefreshToken, AccountSetting, PasswordResetToken, AccountOAuth, AccountDeletionRequest	account_db	UserRegistered, UserProfileUpdated, UserAvatarUpdated, PasswordResetRequested, UserPasswordReset, UserDeletionRequested/Cancelled/Completed
Mạng xã hội	Follow, Block, Post, Comment, Reaction, PostMediaRef, PostShare, ContentReport, ModerationEvidence, ModerationAction	social_db	UserFollowed/Unfollowed, UserBlocked/Unblocked, PostCreated/Updated/Deleted, CommentCreated, ReactionAdded/Removed, PostShared, ContentReported, ModerationActionRequested/Completed/Rejected
Cộng đồng	Community, CommunityMember, Role, MemberRole, Channel, Invite	community_db	CommunityCreated/Updated, MemberJoined/LeftCommunity, ChannelCreated, RoleUpdated, PermissionUpdated, MemberModerated
Trò chuyện	Conversation, ConversationMember, Message, MessageReaction, Notification	chat_db	ConversationCreated, MessageSent/Edited/Deleted, NotificationRead
Bảng tin	FeedEntry, FeedUserSummary, FeedPostSummary	feed_db	Chủ yếu nhận sự kiện; có thể phát RecommendationSnapshotUpdated khi cần
Phương tiện	UploadSession, MediaAsset	media_db	MediaUploaded, MediaReady, MediaFailed, MediaDeleted
Thương mại	Listing, ListingMediaRef, Inventory, Order, OrderItem, Payment, OrderStatusHistory	commerce_db	ListingCreated/Updated, InventoryReserved/Released, OrderCreated, PaymentSucceeded/Failed, OrderStatusChanged
AI và tìm kiếm	AiEmbedding, AiChunk, AiJob,	ai_db + pgvector	EmbeddingGenerated,

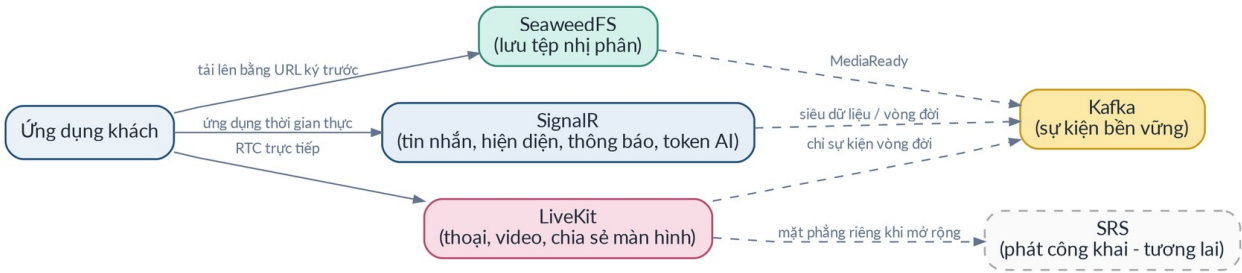
Dịch vụ	Thực thể sở hữu	Kho dữ liệu	Sự kiện chính
	transcript metadata		AISummaryReady, TranscriptReady

3. Tổng quan UML

UML tập trung vào ca sử dụng, thành phần, trình tự, trạng thái và triển khai. Chi tiết thực thể được thể hiện bằng ERD vì mô hình lưu trữ là cơ sở trực tiếp cho triển khai.



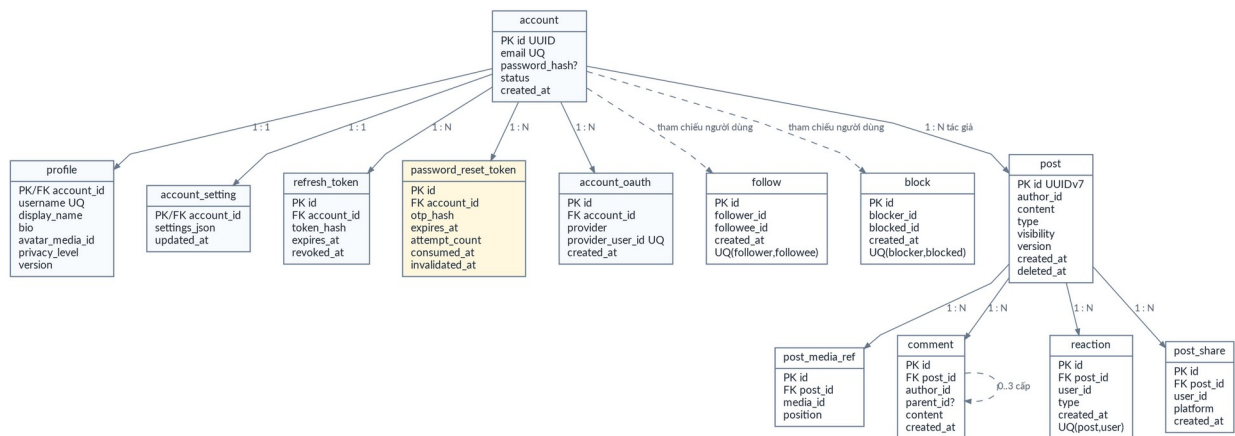
Hình 3 - Tổng quan ca sử dụng



Hình 4 - Thành phần thời gian thực, phương tiện và sự kiện

4. ERD - Tài khoản và mạng xã hội

ERD thể hiện khóa ngoại trong phạm vi từng dịch vụ. Các trường `user_id` trong Mạng xã hội là tham chiếu định danh bên ngoài; không tạo khóa ngoại vật lý sang `account_db` trong mô hình dữ liệu phân tán.



Hình 5 - ERD của tài khoản và mạng xã hội

4.1 Các bảng của dịch vụ tài khoản

Bảng 6 - Các bảng của dịch vụ tài khoản

Bảng	Trường chính	Quy tắc và chỉ mục
account	id, email, password_hash, status, created_at, updated_at	UQ(email); chỉ mục status khi có nghiệp vụ quản trị; password_hash có thể null với tài khoản chỉ dùng OAuth.
profile	account_id, username, display_name, bio, avatar_media_id, privacy_level, version	PK/FK trong account_db; UQ(username); version dùng cho xử lý đồng thời lạc quan.
refresh_token	id, account_id, token_hash, expires_at, revoked_at, replaced_by_id	Index(account_id, expires_at); chỉ lưu hash; family_id hỗ trợ phát hiện tái sử dụng và thu hồi họ phiên.
password_reset_token	id, account_id, otp_hash, expires_at, consumed_at, attempt_count, invalidated_at	Index(account_id, expires_at); OTP bấm, dùng một lần, TTL ngắn; khóa khi vượt số lần thử.
account_oauth	id, account_id, provider, provider_user_id, created_at	UQ(provider, provider_user_id); baseline chỉ dùng Google; không tự động gộp với tài khoản mật khẩu trùng email.
account_setting	account_id, notification_json, locale, timezone, updated_at	PK/FK trong account_db; chỉ chấp nhận khóa cấu hình được cho phép; không chứa bí mật.
account_deletion_request	id, account_id, requested_at, delete_after, cancelled_at, completed_at, status, version	UQ hoạt động theo account_id; thời gian ân hạn 30 ngày; theo dõi xác nhận từ các dịch vụ và cảnh báo khi quá hạn.

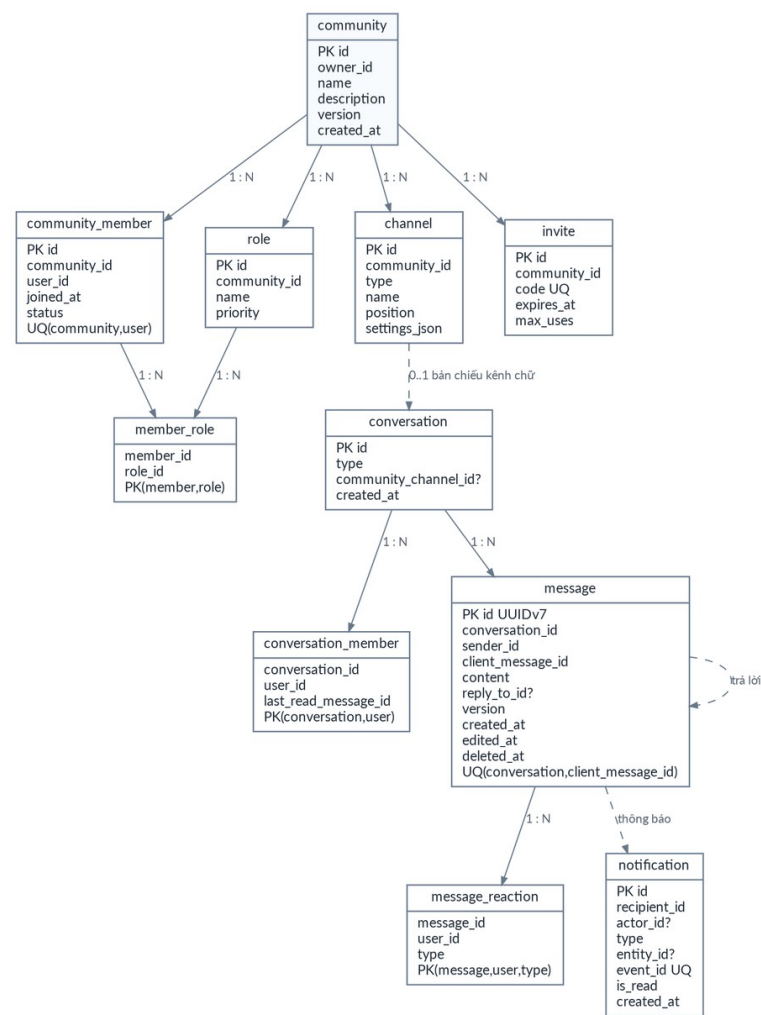
4.2 Các bảng của dịch vụ mạng xã hội

Bảng 7 - Các bảng của dịch vụ mạng xã hội

Bảng	Trường chính	Quy tắc và chỉ mục
follow	follower_id, followee_id, created_at	UQ(follower_id, followee_id); cấm tự theo dõi; thao tác thêm/xóa xử lý lặp an toàn.
block	blocker_id, blocked_id, created_at	UQ(blocker_id, blocked_id); cấm tự chặn; quan hệ chặn ưu tiên hơn theo dõi và hiển thị.
post	id, author_id, content, type, visibility, version, created_at, updated_at, deleted_at	Index(author_id, created_at DESC); version cho xử lý đồng thời; type thuộc {content, video}; video ở processing đến khi MediaReady.
post_media_ref	post_id, media_id, position	UQ(post_id, position); media_id là tham chiếu ngoài; thứ tự phải xác định.
comment	id, post_id, author_id, parent_id, content, version, created_at, deleted_at	Index(post_id, created_at, id); parent_id phải cùng bài viết; giới hạn độ sâu trả lời.
reaction	id, post_id, user_id, type, created_at, updated_at	UQ(post_id, user_id) để ngăn trùng khi có tranh chấp; cập nhật kiểu tương tác bằng upsert.
post_share	id, post_id, user_id, platform, created_at	Index(post_id, created_at); cho phép một người dùng chia sẻ nhiều lần.
content_report	id, reporter_id, target_type, target_id, reason_code, description, status, priority, version, created_at	Index(status, priority, created_at); giới hạn báo cáo trùng đang mở; target_id là tham chiếu ngoài.
moderation_evidence	id, report_id, evidence_type, content_hash, object_key, expires_at	FK nội bộ tới content_report; dữ liệu bằng chứng được hạn chế quyền và xóa theo thời hạn lưu giữ.
moderation_action	id, report_id, moderator_id, action_type, reason, expires_at, created_at	Append-only; mọi hành động có người thực hiện, lý do, correlationId và kết quả từ dịch vụ sở hữu nội dung.

5. ERD - Cộng đồng và trò chuyện

Cộng đồng sở hữu thành viên và quyền; Trò chuyện sở hữu lịch sử tin nhắn. Kênh văn bản được ánh xạ sang cuộc hội thoại Trò chuyện bằng bản chiếu hoặc tham chiếu, không dùng khóa ngoại xuyên cơ sở dữ liệu.



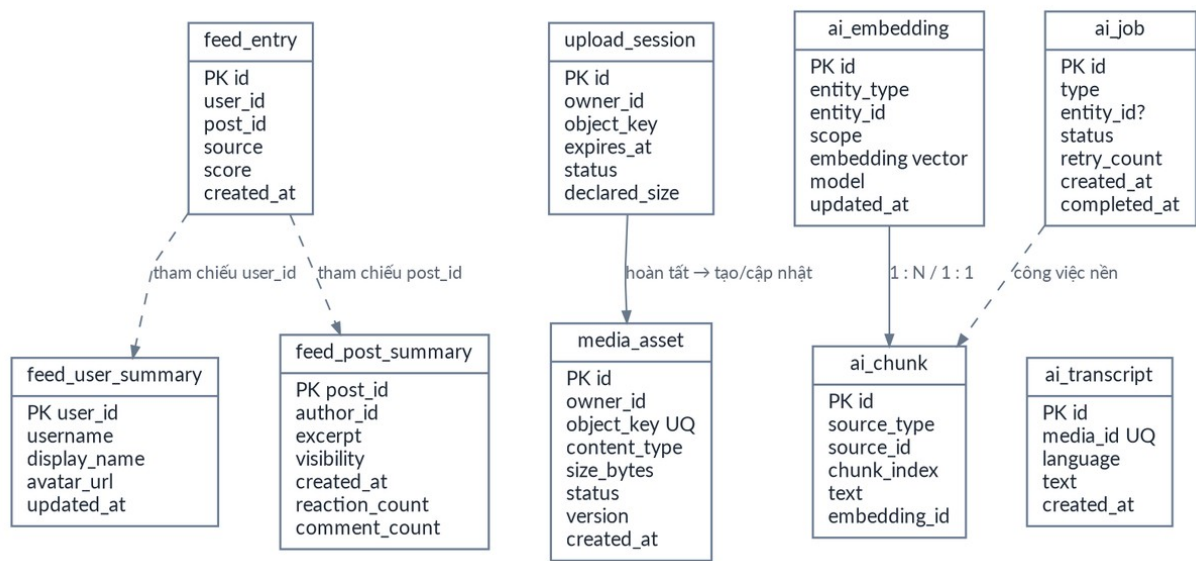
Hình 6 - ERD của cộng đồng và trò chuyện

Bảng 8 - Quyết định thiết kế cho cộng đồng và trò chuyện

Vấn đề thiết kế	Quyết định
Quyền sở hữu kênh	Cộng đồng sở hữu siêu dữ liệu, loại kênh và quyền truy cập.
Quyền sở hữu tin nhắn	Trò chuyện sở hữu cuộc hội thoại, tin nhắn và trạng thái đã đọc.
Kiểm tra thành viên	Trò chuyện dùng bản chiếu cục bộ; tại ranh giới nhạy cảm có thể gọi hợp đồng Cộng đồng. Không truy vấn trực tiếp community_db.
Trạng thái hiện diện	Lưu trạng thái tạm thời trong Valkey với TTL; PostgreSQL không phải nguồn dữ liệu chuẩn.
Thông báo	Dịch vụ trò chuyện sở hữu hộp thông báo để tránh tăng thêm dịch vụ.
Xử lý đồng thời tin nhắn	Message có version; clientMessageId duy nhất theo người gửi hoặc hội thoại để chống gửi lặp.

6. ERD - Bảng tin, phương tiện và AI/tìm kiếm

Các lược đồ này chủ yếu là mô hình đọc hoặc siêu dữ liệu xử lý; một số dữ liệu có thể được dựng lại từ dịch vụ nguồn.



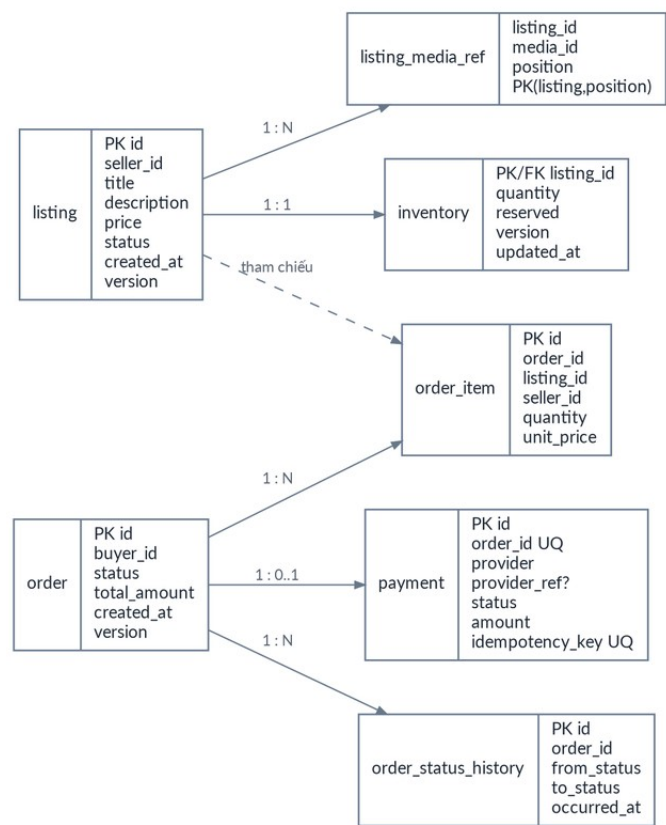
Hình 7 - ERD của bảng tin, phương tiện và AI/tìm kiếm

Bảng 9 - Nguồn dữ liệu chuẩn của bảng tin, phương tiện và AI/tìm kiếm

Phân hệ	Nguồn dữ liệu chuẩn và quy tắc dựng lại
Bản chiếu Bảng tin	Dẫn xuất từ sự kiện Account/Mạng xã hội; có thể dựng lại từ dữ liệu xuất của nguồn và phần sự kiện phát sinh sau mốc kiểm tra.
Siêu dữ liệu Phương tiện	Là dữ liệu giao dịch; đối tượng nhị phân trên SeaweedFS phải được lưu bền và sao lưu theo chính sách.
AI embedding	Là dữ liệu dẫn xuất; tạo lại khi mô hình hoặc phiên bản tiền xử lý thay đổi.
Đoạn dữ liệu RAG	Phải giữ loại nguồn, định danh nguồn, phạm vi và siêu dữ liệu phân quyền; không tạo kho ngữ liệu toàn cục không kiểm soát.

7. ERD - Thương mại

Commerce là một dịch vụ triển khai độc lập. Order, Inventory và MockPayment có thể dùng giao dịch cục bộ ở một số bước; Saga và máy trạng thái vẫn được mô hình hóa để thể hiện bù trừ và hỗ trợ tách dịch vụ khi cần.



Hình 8 - ERD của thương mại

Bảng 10 - Các bảng của dịch vụ thương mại

Bảng	Quy tắc
listing	seller_id là tham chiếu ngoài; version cho xử lý đồng thời; status quyết định khả năng hiển thị.
listing_media_ref	UQ(listing_id, position); chỉ tham chiếu MediaAsset ở trạng thái Ready và đúng mục đích sử dụng.
inventory	quantity >= 0; 0 <= reserved <= quantity; cập nhật giữ hàng bằng lệnh nguyên tử hoặc khóa dòng; có version.
order / order_item	Chụp giá tại thời điểm tạo đơn; mỗi chuyển trạng thái phải hợp lệ và được ghi lịch sử.
payment	Nhà cung cấp giả lập; idempotency_key duy nhất; một thanh toán đang hoạt động cho mỗi đơn trong phạm vi cơ sở.
order_status_history	Chỉ thêm mới để lưu vết chuyển trạng thái; không cập nhật hoặc xóa trong luồng nghiệp vụ thông thường.

8. Danh mục hợp đồng API

Các đường dẫn dưới đây là hợp đồng cơ sở của phiên bản v1. Tập OpenAPI được sinh từ mã nguồn nhưng ngữ nghĩa hợp đồng phải tuân theo tài liệu này.

Bảng 11 - Danh mục hợp đồng API

Dịch vụ	Phương thức	Đường dẫn	Quyền	Mục đích
Tài khoản	POST	/api/v1/auth/register	Công khai	Tạo tài khoản và phát UserRegistered
Tài khoản	POST	/api/v1/auth/google	Công khai	Đăng nhập/đăng ký bằng Google; phát UserRegistered nếu mới
Tài khoản	POST	/api/v1/auth/login	Công khai	Cấp access token và refresh token
Tài khoản	POST	/api/v1/auth/refresh	Refresh token	Xoay vòng refresh token và cấp cập token mới
Tài khoản	POST	/api/v1/auth/logout	Người dùng	Thu hồi refresh token hoặc họ phiên
Tài khoản	GET	/api/v1/users/{id}	Theo chính sách	Đọc hồ sơ theo quyền riêng tư
Tài khoản	PATCH	/api/v1/users/me	Người dùng	Cập nhật hồ sơ; yêu cầu If-Match
Tài khoản	PATCH	/api/v1/users/me/avatar	Người dùng	Cập nhật ảnh đại diện sau khi xác minh MediaReady
Tài khoản	PATCH	/api/v1/users/me/settings	Người dùng	Cập nhật thiết lập tài khoản
Tài khoản	POST	/api/v1/auth/forgot-password	Công khai	Yêu cầu OTP và phát PasswordResetRequested
Tài khoản	POST	/api/v1/auth/reset-password	Công khai	Xác minh OTP, đổi mật khẩu và thu hồi mọi refresh token
Tài khoản	DELETE	/api/v1/users/me	Người dùng	Yêu cầu xóa tài khoản, thu hồi phiên và bắt đầu thời gian ân hạn
Tài khoản	POST	/api/v1/users/me/deletion/cancel	Người dùng	Hủy yêu cầu xóa trong thời gian ân hạn
Mạng xã hội	POST	/api/v1/users/{id}/follow	Người dùng	Theo dõi và phát UserFollowed
Mạng xã hội	DELETE	/api/v1/users/{id}/follow	Người dùng	Bỏ theo dõi và phát UserUnfollowed
Mạng xã hội	POST	/api/v1/users/{id}/block	Người dùng	Chặn và phát UserBlocked
Mạng xã hội	DELETE	/api/v1/users/{id}/block	Người dùng	Bỏ chặn và phát UserUnblocked
Mạng xã hội	POST	/api/v1/posts	Người dùng	Tạo bài viết hoặc bài viết video; hỗ trợ Idempotency-Key
Mạng xã hội	GET	/api/v1/posts/{id}	Theo chính sách	Đọc bài viết sau khi áp dụng quyền riêng tư và chặn
Mạng xã hội	GET	/api/v1/users/{id}/posts	Theo chính sách	Đọc danh sách bài viết bằng con trỏ
Mạng xã hội	PATCH	/api/v1/posts/{id}	Chủ sở hữu	Cập nhật bài viết; yêu cầu If-Match
Mạng xã hội	DELETE	/api/v1/posts/{id}	Chủ sở hữu/Điều hành	Xóa mềm và phát

Dịch vụ	Phương thức	Đường dẫn	Quyền	Mục đích
				PostDeleted
Mạng xã hội	POST	/api/v1/posts/{id}/comments	Người dùng	Tạo bình luận hoặc trả lời
Mạng xã hội	PUT	/api/v1/posts/{id}/reaction	Người dùng	Thêm hoặc thay tương tác
Mạng xã hội	DELETE	/api/v1/posts/{id}/reaction	Người dùng	Xóa tương tác
Mạng xã hội	POST	/api/v1/posts/{id}/share	Người dùng	Sinh liên kết chia sẻ và ghi nhận PostShared
Bảng tin	GET	/api/v1/feed	Người dùng	Đọc bảng tin bằng con trỏ
Phương tiện	POST	/api/v1/media/uploads	Người dùng	Tạo phiên tải lên và URL ký trước
Phương tiện	POST	/api/v1/media/uploads/{id}/complete	Chủ sở hữu	Xác minh đối tượng và hoàn tất tải lên
Phương tiện	DELETE	/api/v1/media/{id}	Chủ sở hữu/Hệ thống	Đánh dấu xóa và lên lịch dọn đối tượng
Cộng đồng	POST	/api/v1/communities	Người dùng	Tạo cộng đồng
Cộng đồng	PATCH	/api/v1/communities/{id}	Chủ sở hữu	Cập nhật cộng đồng; yêu cầu If-Match
Cộng đồng	POST	/api/v1/communities/{id}/invites	Có quyền	Tạo lời mời có hạn dùng và số lượt
Cộng đồng	POST	/api/v1/communities/{id}/join	Người dùng/Lời mời	Tham gia cộng đồng
Cộng đồng	POST	/api/v1/communities/{id}/leave	Thành viên	Rời cộng đồng theo quy tắc chuyển chủ sở hữu
Cộng đồng	POST	/api/v1/communities/{id}/channels	Có quyền	Tạo kênh
Cộng đồng	PUT	/api/v1/communities/{id}/roles/{roleId}	Quản lý vai trò	Tạo/cập nhật vai trò và quyền
Cộng đồng	PUT	/api/v1/communities/{id}/members/{memberId}/roles	Quản lý vai trò	Gán vai trò theo thứ bậc
Cộng đồng	POST	/api/v1/communities/{id}/members/{memberId}/moderation	Điều hành	Mute/kick/ban và phát MemberModerated
Cộng đồng	POST	/api/v1/channels/{id}/rtc-token	Thành viên	Cấp token LiveKit theo quyền
Trò chuyện	POST	/api/v1/conversations	Người dùng	Tạo hội thoại trực tiếp hoặc nhóm
Trò chuyện	GET	/api/v1/conversations/{id}/messages	Thành viên	Đọc lịch sử tin nhắn bằng con trỏ
Trò chuyện	POST	/api/v1/conversations/{id}/messages	Thành viên	Gửi tin nhắn qua HTTP dự phòng; yêu cầu clientMessageId
Trò chuyện	PATCH	/api/v1/messages/{id}	Người gửi/Điều hành	Sửa tin nhắn; yêu cầu If-Match
Trò chuyện	DELETE	/api/v1/messages/{id}	Người gửi/Điều hành	Xóa mềm tin nhắn
Trò chuyện	PUT	/api/v1/messages/{id}/reaction	Thành viên	Thêm hoặc thay tương tác tin nhắn
Trò chuyện	DELETE	/api/v1/messages/{id}/reaction	Thành viên	Xóa tương tác tin nhắn
Trò chuyện	POST	/api/v1/conversations/{id}/	Thành viên	Tiến con trỏ đã đọc theo

Dịch vụ	Phương thức	Đường dẫn	Quyền	Mục đích
		read		chiều tăng
Trò chuyện	GET	/api/v1/notifications	Người dùng	Đọc hộp thông báo
Trò chuyện	PATCH	/api/v1/notifications/{id}/read	Người dùng	Đánh dấu thông báo đã đọc
Trò chuyện	POST	/api/v1/conversations/{id}/call-invites	Thành viên	Tạo lời mời cuộc gọi qua SignalR
Thương mại	POST	/api/v1/listings	Người bán	Tạo tin đăng
Thương mại	GET	/api/v1/listings	Công khai/Theo chính sách	Duyệt hoặc tìm tin đăng
Thương mại	PATCH	/api/v1/listings/{id}	Người bán	Cập nhật tin đăng; yêu cầu If-Match
Thương mại	PUT	/api/v1/listings/{id}/inventory	Người bán	Điều chỉnh tồn kho bằng cập nhật nguyên tử
Thương mại	POST	/api/v1/orders	Người mua	Tạo đơn và giữ tồn kho; bắt buộc Idempotency-Key
Thương mại	GET	/api/v1/orders/{id}	Người mua/Người bán liên quan	Đọc đơn hàng theo quyền
Thương mại	POST	/api/v1/orders/{id}/cancel	Người mua/Hệ thống	Hủy đơn hợp lệ và giải phóng tồn kho
Thương mại	POST	/api/v1/orders/{id}/pay	Người mua	Thanh toán giả lập; bắt buộc Idempotency-Key
AI và tìm kiếm	POST	/api/v1/ai/ask	Người dùng	Hỏi trợ lý RAG trong phạm vi được cấp quyền
AI và tìm kiếm	GET	/api/v1/search/semantic	Người dùng	Tìm kiếm ngữ nghĩa theo phạm vi
AI và tìm kiếm	POST	/api/v1/ai/summaries	Người có quyền	Tóm tắt nội dung do dịch vụ nguồn cấp quyền
AI và tìm kiếm	POST	/api/v1/ai/transcriptions	Người có quyền	Yêu cầu chuyển âm thanh MediaReady thành văn bản
Mạng xã hội - điều hành	POST	/api/v1/reports	Người dùng	Tạo báo cáo vi phạm và phát ContentReported
Mạng xã hội - điều hành	GET	/api/v1/moderation/reports	Điều hành	Đọc hàng đợi báo cáo theo quyền và bộ lọc
Mạng xã hội - điều hành	POST	/api/v1/moderation/reports/{id}/actions	Điều hành	Ghi hành động và phát ModerationActionRequested
Mạng xã hội - điều hành	POST	/api/v1/moderation/reports/{id}/close	Điều hành	Đóng báo cáo với kết luận và dấu vết kiểm toán

9. Danh mục sự kiện Kafka

Tên topic có thể được tinh chỉnh khi triển khai; bên phát, bên nhận, khóa phân vùng và phiên bản phải được khóa bằng kiểm thử hợp đồng.

Bảng 12 - Danh mục sự kiện Kafka

Sự kiện	Bên phát	Bên nhận	Khóa phân vùng	Phiên bản
UserRegistered	Tài khoản	Mạng xã hội, Bảng tin, Trò chuyện, AI và tìm kiếm	UserId	v1
UserProfileUpdated	Tài khoản	Bảng tin, Trò chuyện	UserId	v1
UserAvatarUpdated	Tài khoản	Bảng tin, Trò chuyện	UserId	v1
PasswordResetRequested	Tài khoản	Tiến trình gửi email và nhật ký kiểm toán	AccountId	v1
UserPasswordReset	Tài khoản	Nhật ký bảo mật; bộ nhận sự kiện tùy chọn	AccountId	v1
UserDeletionRequested	Tài khoản	Mạng xã hội, Bảng tin, Trò chuyện, Cộng đồng, Phương tiện, Thương mại, AI và tìm kiếm	AccountId	v1
UserDeletionCancelled	Tài khoản	Các dịch vụ đã nhận yêu cầu xóa	AccountId	v1
UserDeletionCompleted	Tài khoản	Nhật ký kiểm toán và dịch vụ cần xóa bản chiếu cuối	AccountId	v1
UserFollowed	Mạng xã hội	Bảng tin, Trò chuyện	FollowerId	v1
UserUnfollowed	Mạng xã hội	Bảng tin, Trò chuyện	FollowerId	v1
UserBlocked	Mạng xã hội	Bảng tin, Trò chuyện	BlockerId	v1
UserUnblocked	Mạng xã hội	Bảng tin, Trò chuyện	BlockerId	v1
PostCreated	Mạng xã hội	Bảng tin, AI và tìm kiếm	PostId	v1
PostUpdated	Mạng xã hội	Bảng tin, AI và tìm kiếm	PostId	v1
PostDeleted	Mạng xã hội	Bảng tin, AI và tìm kiếm	PostId	v1
CommentCreated	Mạng xã hội	Trò chuyện tạo thông báo	PostId	v1
ReactionAdded	Mạng xã hội	Trò chuyện tạo thông báo; Bảng tin cập nhật bộ đếm	PostId	v1
ReactionRemoved	Mạng xã hội	Bảng tin cập nhật bộ đếm; Trò chuyện tùy chọn	PostId	v1
PostShared	Mạng xã hội	Bảng tin dùng tùy chọn cho xếp hạng	PostId	v1
ContentReported	Mạng xã hội	Hàng đợi điều hành và Trò chuyện tạo thông báo nội bộ	ReportId	v1
ModerationActionRequested	Mạng xã hội	Dịch vụ sở hữu target_type	TargetId	v1
ModerationActionCompleted	Dịch vụ sở hữu nội dung	Mạng xã hội và Trò chuyện	ReportId	v1
ModerationActionRejected	Dịch vụ sở hữu nội dung	Mạng xã hội và Trò chuyện	ReportId	v1
CommunityCreated	Cộng đồng	Trò chuyện tạo bản chiếu	CommunityId	v1
CommunityUpdated	Cộng đồng	Trò chuyện cập nhật bản chiếu	CommunityId	v1
MemberJoined	Cộng đồng	Trò chuyện cập nhật bản chiếu	CommunityId	v1
MemberLeftCommunity	Cộng đồng	Trò chuyện cập nhật bản chiếu	CommunityId	v1
ChannelCreated	Cộng đồng	Trò chuyện tạo bản chiếu	ChannelId	v1
RoleUpdated	Cộng đồng	Trò chuyện cập nhật quyền cục	CommunityId	v1

Sự kiện	Bên phát	Bên nhận	Khóa phân vùng	Phiên bản
		bộ		
PermissionUpdated	Cộng đồng	Trò chuyện cập nhật quyền cục bộ	CommunityId	v1
MemberModerated	Cộng đồng	Trò chuyện tạo thông báo hoặc cập nhật quyền	CommunityId	v1
ConversationCreated	Trò chuyện	Bộ nhận sự kiện phân tích tùy chọn	ConversationId	v1
MessageSent	Trò chuyện	AI và tìm kiếm tùy chọn; thông báo/phân tích	ConversationId	v1
MessageEdited	Trò chuyện	AI và tìm kiếm cập nhật dữ liệu dẫn xuất tùy chọn	ConversationId	v1
MessageDeleted	Trò chuyện	AI và tìm kiếm xóa hoặc ẩn dữ liệu dẫn xuất	ConversationId	v1
MediaUploaded	Phương tiện	Tiến trình xử lý phương tiện	MediaId	v1
MediaReady	Phương tiện	Mạng xã hội, Thương mại hoặc Trò chuyện theo tham chiếu	MediaId	v1
MediaFailed	Phương tiện	Dịch vụ tham chiếu phương tiện và hộp thông báo	MediaId	v1
MediaDeleted	Phương tiện	Dịch vụ giữ tham chiếu và AI và tìm kiếm	MediaId	v1
ListingCreated	Thương mại	AI và tìm kiếm tùy chọn	ListingId	v1
ListingUpdated	Thương mại	AI và tìm kiếm tùy chọn	ListingId	v1
InventoryReserved	Thương mại	Quy trình nội bộ	ListingId	v1
InventoryReleased	Thương mại	Quy trình nội bộ	ListingId	v1
OrderCreated	Thương mại	Quy trình nội bộ và Trò chuyện tạo thông báo tùy chọn	OrderId	v1
PaymentSucceeded	Thương mại	Quy trình nội bộ và Trò chuyện tạo thông báo	OrderId	v1
PaymentFailed	Thương mại	Quy trình bù trừ và Trò chuyện tạo thông báo	OrderId	v1
OrderStatusChanged	Thương mại	Quy trình nội bộ và Trò chuyện tạo thông báo	OrderId	v1
EmbeddingGenerated	AI và tìm kiếm	Bộ nhận sự kiện nội bộ tùy chọn	EntityId	v1
AiSummaryReady	AI và tìm kiếm	Trò chuyện	RequestId	v1
TranscriptReady	AI và tìm kiếm	Trò chuyện	MessageId	v1

Hợp đồng sự kiện

Vỏ sự kiện gồm: eventId, eventType, eventVersion, occurredAt, producer, correlationId, aggregateId và trường payload. Bộ nhận sự kiện xử lý theo cơ chế phát ít nhất một lần; cùng một EventId không được tạo tác dụng phụ trùng.

10. Hợp đồng SignalR và LiveKit

SignalR truyền dữ liệu ứng dụng theo thời gian thực; LiveKit truyền âm thanh, video và màn hình. Siêu dữ liệu vòng đời cuộc gọi hoặc phòng có thể phát qua Kafka, nhưng gói phương tiện không đi qua Kafka.

10.1 Hợp đồng cơ sở của SignalR Hub

Bảng 13 - Hợp đồng cơ sở của SignalR Hub

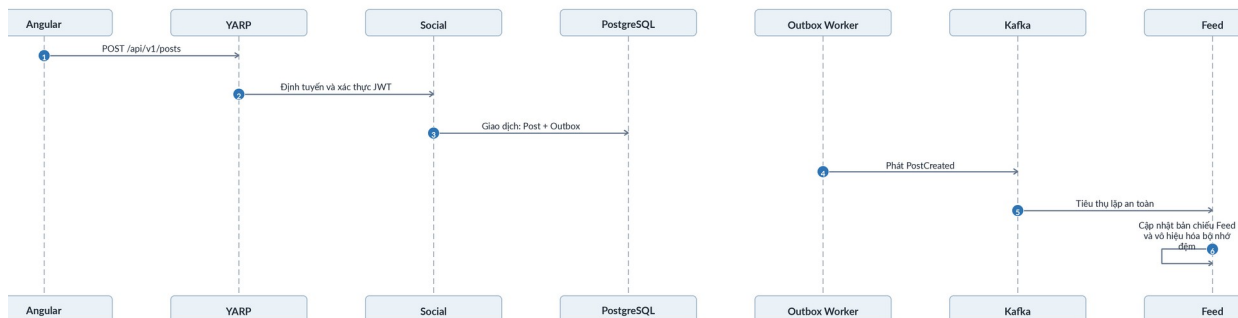
Hướng	Phương thức/Sự kiện	Dữ liệu và quy tắc
Máy khách -> Hub	SendMessage	conversationId, clientId, messageId, content, replyTo; bắt buộc kiểm tra thành viên và chống gửi lặp.
Máy khách -> Hub	Typing	conversationId, isTyping; trạng thái tạm thời, có giới hạn tần suất và tự hết hạn.
Máy khách -> Hub	MarkRead	conversationId, messageId; con trỏ đã đọc chỉ được tiến về phía trước.
Máy chủ -> Máy khách	MessageCreated	DTO tin nhắn; chỉ gửi tới nhóm hội thoại đã được cấp quyền.
Máy chủ -> Máy khách	MessageUpdated/Deleted	messageId, version và trạng thái mới.
Máy chủ -> Máy khách	MessageReactionChanged	messageId và bản tóm tắt tương tác mới.
Máy chủ -> Máy khách	TypingChanged	conversationId, userId, isTyping và thời điểm hết hạn.
Máy chủ -> Máy khách	ReadUpdated	conversationId, userId, messageId.
Máy chủ -> Máy khách	PresenceChanged	userId và trạng thái; áp dụng quyền riêng tư.
Máy chủ -> Máy khách	NotificationCreated	DTO thông báo đã được lọc theo người nhận.
Máy chủ -> Máy khách	CallInvite	channel hoặc conversation, người mời và siêu dữ liệu RTC.
Máy chủ -> Máy khách	AIToken/AICompleted	requestId, đoạn văn bản tăng dần và trạng thái hoàn tất.

10.2 Hợp đồng LiveKit

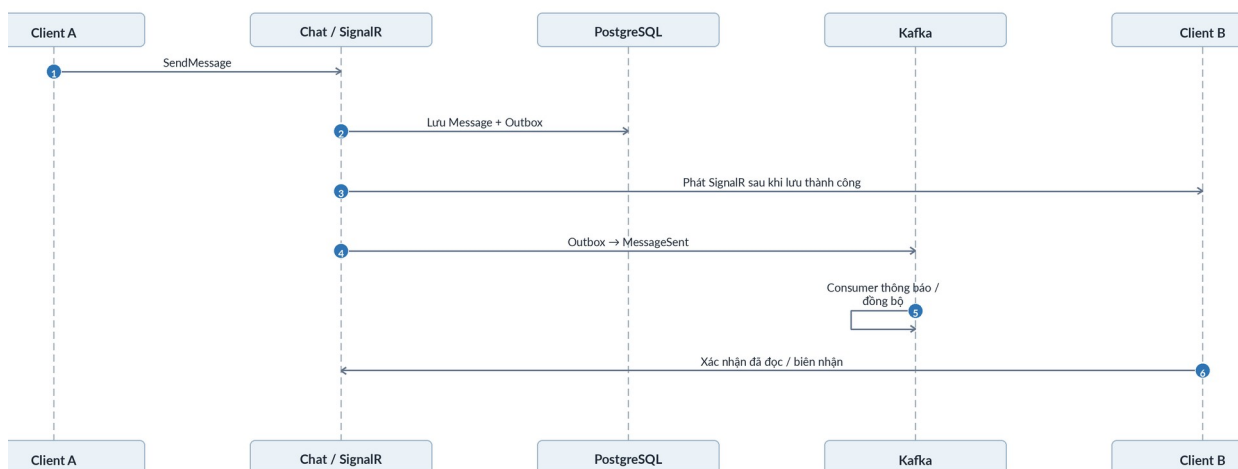
- Dịch vụ cộng đồng kiểm tra tư cách thành viên và các quyền JoinVoice, Speak, ScreenShare.
- Máy chủ cấp token sống ngắn, giới hạn theo phòng và quyền của người tham gia.
- Máy khách kết nối trực tiếp tới LiveKit; coturn là đường dự phòng khi bị NAT hoặc tường lửa chặn.
- Phiên bản cơ sở chạy một nút; mô hình nhiều nút và tính sẵn sàng cao thuộc hướng phát triển.
- Ghi hình và phụ đề trực tiếp không thuộc phạm vi bắt buộc.

11. Sơ đồ trình tự cốt lõi

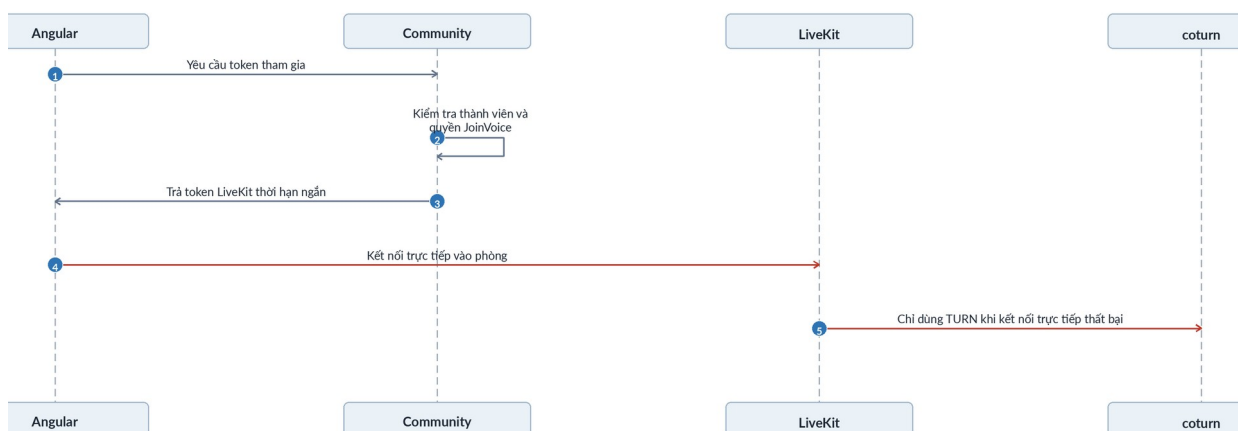
Các sơ đồ dưới đây là luồng tham chiếu cho kiểm thử tích hợp và theo dõi phân tán.



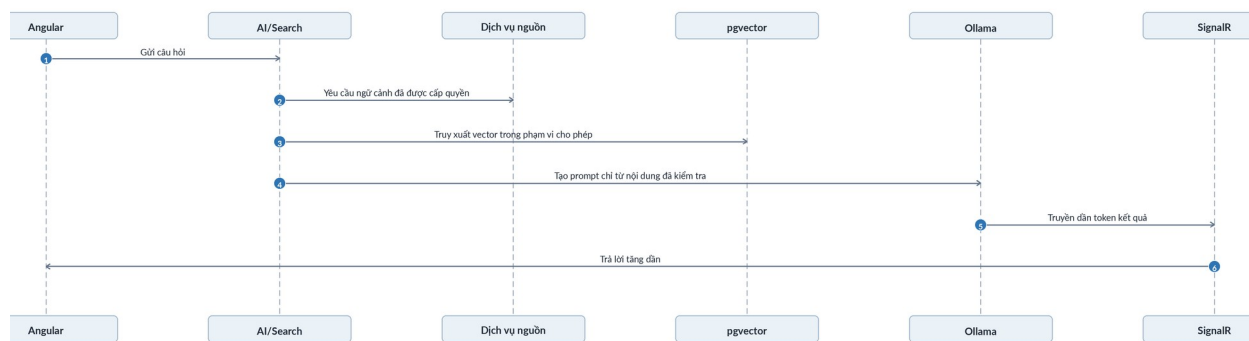
Hình 9 - Tạo bài viết qua Outbox/Kafka đến Bảng tin



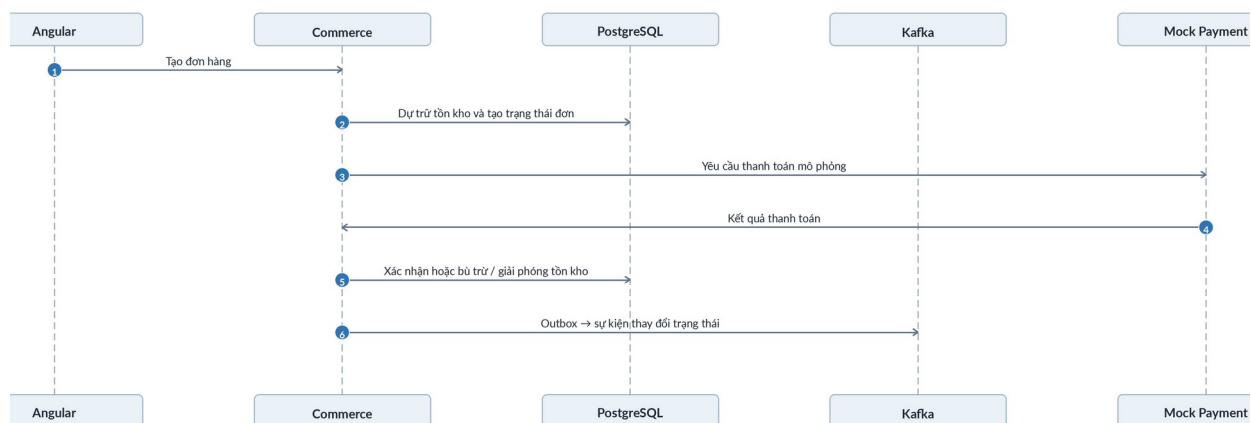
Hình 10 - Lưu tin nhắn và phát qua SignalR



Hình 11 - Tham gia kênh thoại LiveKit



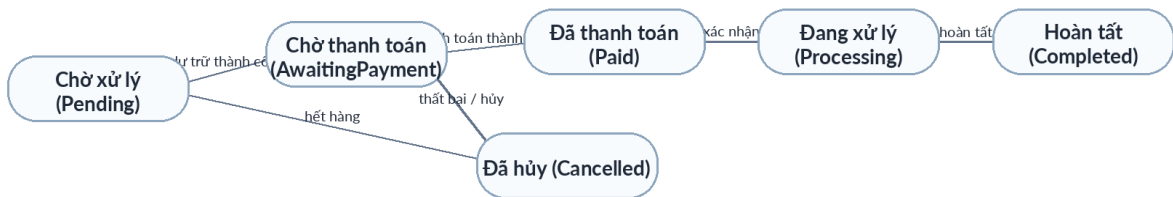
Hình 12 - RAG giới hạn theo quyền truy cập



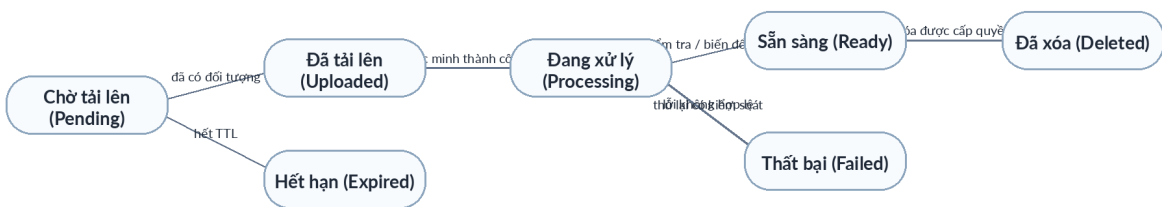
Hình 13 - Quy trình thanh toán đơn giản hóa

12. Máy trạng thái

Chuyển trạng thái được kiểm tra tại tầng miền hoặc tầng ứng dụng; mọi chuyển trạng thái không hợp lệ phải có ca kiểm thử.



Hình 14 - Máy trạng thái đơn hàng



Hình 15 - Máy trạng thái tải lên và xử lý phương tiện

13. Đặc tả chức năng chi tiết

Mỗi chức năng dưới đây xác định hành vi cơ sở. Hình dạng HTTP có thể tinh chỉnh, nhưng quy tắc nghiệp vụ, quyền sở hữu và ngữ nghĩa sự kiện không được thay đổi mà không cập nhật hợp đồng.

13.1 Dịch vụ tài khoản

ACC-01 - Đăng ký

Trường	Đặc tả
Dịch vụ sở hữu	Tài khoản
Tác nhân chính	Khách
Điều kiện trước	Email và username chưa tồn tại.
Luồng chính	Kiểm tra dữ liệu -> bấm mật khẩu -> tạo Account/Profile -> ghi Outbox UserRegistered -> trả thông tin tài khoản.
Kiểm tra và phân quyền	Định dạng email, chính sách mật khẩu, username duy nhất và giới hạn tần suất.
Thay đổi dữ liệu	Thêm bản ghi account/profile/outbox.
Sự kiện và thời gian thực	Phát UserRegistered qua Kafka.
Lỗi và trường hợp biên	409 khi email hoặc username trùng; 422 khi dữ liệu không hợp lệ; lỗi DB tạm thời trả 503 và chỉ thử lại tại tầng an toàn.
Ghi chú	Không bao giờ trả password_hash.

ACC-02 - Đăng nhập

Trường	Đặc tả
Dịch vụ sở hữu	Tài khoản
Tác nhân chính	Khách
Điều kiện trước	Tài khoản đang hoạt động.
Luồng chính	Xác minh thông tin đăng nhập -> cấp access token sống ngắn và refresh token -> lưu hash của refresh token.
Kiểm tra và phân quyền	Giới hạn tần suất; có thể khóa tạm theo chính sách; từ chối tài khoản bị vô hiệu hóa.
Thay đổi dữ liệu	Thêm bản ghi refresh_token và chỉ lưu token_hash.
Sự kiện và thời gian thực	Không yêu cầu phát sự kiện Kafka.
Lỗi và trường hợp biên	401 không hợp lệ; 403 bị vô hiệu hóa.
Ghi chú	Không tiết lộ email hoặc tài khoản có tồn tại.

ACC-03 - Xoay vòng refresh token

Trường	Đặc tả
Dịch vụ sở hữu	Tài khoản
Tác nhân chính	Đã xác thực bằng refresh token
Điều kiện trước	Refresh token hợp lệ và chưa bị thu hồi.
Luồng chính	Xác minh hash -> thu hồi token cũ -> tạo token thay thế -> cấp access token và refresh token mới.

Trường	Đặc tả
Kiểm tra và phân quyền	Refresh token chỉ được xoay vòng một lần; phát hiện tái sử dụng theo family_id và thu hồi họ phiên khi cần.
Thay đổi dữ liệu	Cập nhật revoked_at của token cũ và thêm token thay thế trong cùng giao dịch.
Sự kiện và thời gian thực	Sự kiện kiểm toán bảo mật là tùy chọn.
Lỗi và trường hợp biên	401 khi token hết hạn, đã bị thu hồi hoặc bị tái sử dụng.

ACC-04 - Đăng xuất

Trường	Đặc tả
Dịch vụ sở hữu	Tài khoản
Tác nhân chính	Người dùng
Điều kiện trước	Refresh token hoặc phiên tồn tại.
Luồng chính	Thu hồi refresh token được yêu cầu hoặc toàn bộ họ phiên.
Kiểm tra và phân quyền	Token hoặc phiên phải thuộc người gọi.
Thay đổi dữ liệu	Cập nhật refresh_token.revoked_at.
Sự kiện và thời gian thực	Không yêu cầu.
Lỗi và trường hợp biên	Đăng xuất xử lý lập an toàn và vẫn trả thành công khi token đã bị thu hồi.

ACC-05 - Xem và cập nhật hồ sơ

Trường	Đặc tả
Dịch vụ sở hữu	Tài khoản
Tác nhân chính	Người dùng
Điều kiện trước	Hồ sơ đích được phép hiển thị theo chính sách riêng tư.
Luồng chính	GET đọc hồ sơ hoặc PATCH các trường cho phép -> kiểm tra version -> cập nhật profile -> ghi Outbox UserProfileUpdated.
Kiểm tra và phân quyền	Kiểm tra ràng buộc username và tên hiển thị; chỉ chủ sở hữu được sửa.
Thay đổi dữ liệu	Cập nhật profile/version.
Sự kiện và thời gian thực	UserProfileUpdated.
Lỗi và trường hợp biên	409 khi version xung đột; 403 khi không đủ quyền hoặc vi phạm chính sách riêng tư.

ACC-06 - Cập nhật tham chiếu avatar

Trường	Đặc tả
Dịch vụ sở hữu	Tài khoản
Tác nhân chính	Người dùng
Điều kiện trước	MediaAsset ở trạng thái Ready và thuộc quyền sở hữu hoặc sử dụng của người gọi.

Trường	Đặc tả
Luồng chính	Gán avatar_media_id -> phát sự kiện cập nhật hồ sơ.
Kiểm tra và phân quyền	Kiểm tra quyền sở hữu và tham chiếu Phương tiện qua hợp đồng hoặc bản chiếu.
Thay đổi dữ liệu	Cập nhật profile.
Sự kiện và thời gian thực	UserProfileUpdated/UserAvatarUpdated.
Lỗi và trường hợp biên	422 khi MediaAsset chưa ở trạng thái Ready hoặc không được phép sử dụng.

ACC-07 - Quyền riêng tư và thiết lập tài khoản

Trường	Đặc tả
Dịch vụ sở hữu	Tài khoản
Tác nhân chính	Người dùng
Điều kiện trước	Đã xác thực.
Luồng chính	Cập nhật mức hiển thị và thiết lập bằng tập giá trị cho phép rõ ràng.
Kiểm tra và phân quyền	Chỉ chính người dùng hoặc quản trị viên được thực hiện thao tác trạng thái tương ứng.
Thay đổi dữ liệu	Cập nhật account_setting hoặc các trường thiết lập tương ứng.
Sự kiện và thời gian thực	Chỉ phát sự kiện quyền riêng tư hoặc hồ sơ khi dịch vụ hạ nguồn thực sự cần.
Lỗi và trường hợp biên	422 khi enum hoặc giá trị thiết lập không hợp lệ; 409 khi version xung đột.

ACC-08 - Yêu cầu OTP khôi phục mật khẩu

Trường	Đặc tả
Dịch vụ sở hữu	Tài khoản
Tác nhân chính	Khách
Điều kiện trước	Hệ thống xử lý khi có tài khoản khớp email nhưng phản hồi phải giống nhau trong mọi trường hợp.
Luồng chính	Kiểm tra định dạng email -> sinh OTP 6 chữ số -> lưu otp_hash, expires_at và attempt_count=0 -> gửi OTP qua SMTP -> trả phản hồi thành công chung.
Kiểm tra và phân quyền	Giới hạn theo tài khoản và IP; không tiết lộ email có tồn tại.
Thay đổi dữ liệu	Thêm password_reset_token với otp_hash, expires_at, attempt_count=0; vô hiệu OTP chưa dùng trước đó của cùng account.
Sự kiện và thời gian thực	Phát PasswordResetRequested để gửi email và kiểm toán; Kafka không nằm trên đường xử lý bắt buộc của API.
Lỗi và trường hợp biên	Khi nhà cung cấp email không sẵn sàng, xếp hàng và thử lại bất đồng bộ; API vẫn trả phản hồi chung.
Ghi chú	OTP có TTL mặc định 10 phút; OTP mới làm mất hiệu lực mọi OTP chưa dùng trước đó của cùng tài khoản.

ACC-09 - Đặt lại mật khẩu bằng OTP

Trường	Đặc tả
Dịch vụ sở hữu	Tài khoản
Tác nhân chính	Khách

Trường	Đặc tả
Điều kiện trước	OTP của tài khoản hợp lệ, chưa hết hạn và chưa được sử dụng.
Luồng chính	Xác minh otp_hash, thời hạn và số lần thử -> bấm mật khẩu mới -> cập nhật account -> đánh dấu token đã dùng -> thu hồi mọi refresh token.
Kiểm tra và phân quyền	OTP dùng một lần; tối đa 5 lần thử theo cấu hình; bắt buộc chính sách mật khẩu; khóa token khi vượt ngưỡng.
Thay đổi dữ liệu	Cập nhật account.password_hash, password_reset_token.consumed_at và thu hồi mọi hàng refresh_token đang hoạt động.
Sự kiện và thời gian thực	Có thể phát UserPasswordReset cho mục đích kiểm toán.
Lỗi và trường hợp biên	401 khi OTP sai, hết hạn hoặc đã dùng; 429 khi vượt số lần thử.

ACC-10 - Đăng nhập bằng Google OAuth

Trường	Đặc tả
Dịch vụ sở hữu	Tài khoản
Tác nhân chính	Khách
Điều kiện trước	Máy khách có Google id_token hợp lệ theo OAuth 2.0/OpenID Connect.
Luồng chính	Xác minh id_token với Google theo issuer, audience và chữ ký -> tìm account_oauth theo (provider, provider_user_id) -> nếu chưa có thì tạo account, account_oauth và profile mặc định -> cấp access token/refresh token như ACC-02.
Kiểm tra và phân quyền	Chỉ chấp nhận id_token đúng client_id đã cấu hình; email do Google xác minh được xem là đã xác thực.
Thay đổi dữ liệu	Thêm bản ghi account (nếu mới), account_oauth, profile.
Sự kiện và thời gian thực	UserRegistered (nếu tài khoản mới), tương tự ACC-01.
Lỗi và trường hợp biên	Email Google trùng với account dùng mật khẩu -> yêu cầu liên kết thủ công thay vì tự động gộp, tránh chiếm quyền tài khoản.
Ghi chú	Tài khoản tạo qua Google có thể không có password_hash; ACC-08/09 chỉ áp dụng sau khi người dùng tự đặt mật khẩu.

13.2 Dịch vụ mạng xã hội

SOC-01 - Theo dõi và bỏ theo dõi

Trường	Đặc tả
Dịch vụ sở hữu	Mạng xã hội
Tác nhân chính	Người dùng
Điều kiện trước	Người dùng đích tồn tại và không bị chặn theo chính sách.
Luồng chính	Theo dõi: thêm quan hệ duy nhất; bỏ theo dõi: xóa quan hệ theo cách xử lý lặp an toàn.
Kiểm tra và phân quyền	Cấm tự theo dõi; quan hệ chặn ở bất kỳ hướng nào đều ngăn theo dõi.
Thay đổi dữ liệu	Thêm hoặc xóa bản ghi follow.
Sự kiện và thời gian thực	UserFollowed/UserUnfollowed.
Lỗi và trường hợp biên	Theo dõi trùng trở thành công theo tính lặp an toàn; bị chặn trả 403 hoặc 409 theo hợp đồng.

SOC-02 - Chặn và bỏ chặn

Trường	Đặc tả
Dịch vụ sở hữu	Mạng xã hội
Tác nhân chính	Người dùng
Điều kiện trước	Đối tượng đích tồn tại.
Luồng chính	Tạo quan hệ block, xóa các quan hệ follow không còn hợp lệ và phát sự kiện.
Kiểm tra và phân quyền	Cấm tự chặn; chỉ người gọi được quản lý quan hệ chặn của mình.
Thay đổi dữ liệu	Thêm hoặc xóa block; dọn quan hệ follow theo quy tắc đã chọn.
Sự kiện và thời gian thực	UserBlocked/UserUnblocked.
Lỗi và trường hợp biên	Yêu cầu chặn hoặc bỏ chặn lặp được xử lý an toàn.

SOC-03 - Tạo bài viết

Trường	Đặc tả
Dịch vụ sở hữu	Mạng xã hội
Tác nhân chính	Người dùng
Điều kiện trước	Đã xác thực; phương tiện tham chiếu ở trạng thái Ready.
Luồng chính	Kiểm tra nội dung -> ghi Post, PostMediaRef và Outbox trong cùng giao dịch -> trả DTO đã tạo.
Kiểm tra và phân quyền	Kiểm tra độ dài, mức hiển thị, quyền sử dụng Phương tiện và giới hạn tần suất.
Thay đổi dữ liệu	Thêm post, post_media_ref và outbox_message.
Sự kiện và thời gian thực	PostCreated.
Lỗi và trường hợp biên	422 khi nội dung hoặc Phương tiện không hợp lệ; có thể dùng Idempotency-Key để tạo lại an toàn.

SOC-04 - Sửa bài viết

Trường	Đặc tả
Dịch vụ sở hữu	Mạng xã hội
Tác nhân chính	Người dùng/Chủ sở hữu
Điều kiện trước	Bài viết đang hoạt động; người gọi là chủ sở hữu.
Luồng chính	Kiểm tra version -> cập nhật các trường được phép -> ghi Outbox PostUpdated.
Kiểm tra và phân quyền	Kiểm tra chủ sở hữu, mức hiển thị, nội dung và version lạc quan.
Thay đổi dữ liệu	Cập nhật post/version.
Sự kiện và thời gian thực	PostUpdated.
Lỗi và trường hợp biên	409 khi version xung đột; 404 khi bài viết đã xóa hoặc không tồn tại; 403 khi không phải chủ sở hữu.

SOC-05 - Xóa bài viết

Trường	Đặc tả
Dịch vụ sở hữu	Mạng xã hội

Trường	Đặc tả
Tác nhân chính	Chủ sở hữu/Điều hành viên
Điều kiện trước	Bài viết tồn tại hoặc đã được xóa mềm.
Luồng chính	Xóa mềm bài viết và ghi Outbox PostDeleted; bộ nhận sự kiện xóa hoặc ẩn các bản chiếu liên quan.
Kiểm tra và phân quyền	Kiểm tra quyền; yêu cầu xóa lặp phải an toàn.
Thay đổi dữ liệu	Gán deleted_at/status.
Sự kiện và thời gian thực	PostDeleted.
Lỗi và trường hợp biên	404 không tồn tại; xóa lặp được xử lý an toàn.

SOC-06 - Xem bài viết và danh sách bài viết

Trường	Đặc tả
Dịch vụ sở hữu	Mạng xã hội
Tác nhân chính	Người xem
Điều kiện trước	Bài viết tồn tại và mức hiển thị cho phép người xem.
Luồng chính	Áp dụng bộ lọc mức hiển thị và trạng thái chặn -> truy vấn bằng con trỏ ổn định.
Kiểm tra và phân quyền	Bắt buộc áp dụng chính sách riêng tư và chặn.
Thay đổi dữ liệu	Không ghi dữ liệu.
Sự kiện và thời gian thực	Không có.
Lỗi và trường hợp biên	Có thể trả 404 cho nội dung bị ẩn để tránh tiết lộ sự tồn tại.

SOC-07 - Bình luận và trả lời

Trường	Đặc tả
Dịch vụ sở hữu	Mạng xã hội
Tác nhân chính	Người dùng
Điều kiện trước	Bài viết có thể xem; người gọi đã xác thực.
Luồng chính	Tạo bình luận hoặc trả lời và ghi Outbox CommentCreated.
Kiểm tra và phân quyền	Bình luận cha phải thuộc cùng post; giới hạn độ sâu trả lời và tần suất.
Thay đổi dữ liệu	Thêm bản ghi comment.
Sự kiện và thời gian thực	CommentCreated.
Lỗi và trường hợp biên	422 khi parent_id không hợp lệ; 403 khi bị chặn hoặc không có quyền xem bài viết.

SOC-08 - Tương tác

Trường	Đặc tả
Dịch vụ sở hữu	Mạng xã hội
Tác nhân chính	Người dùng
Điều kiện trước	Bài viết có thể xem; người gọi đã xác thực.
Luồng chính	Thêm hoặc thay một reaction cho mỗi cặp user/post; xóa bản ghi khi bỏ tương tác.

Trường	Đặc tả
Kiểm tra và phân quyền	Bắt buộc UNIQUE(post_id, user_id) và type hợp lệ.
Thay đổi dữ liệu	Thêm/cập nhật/xóa reaction.
Sự kiện và thời gian thực	ReactionAdded/Removed.
Lỗi và trường hợp biên	Tranh chấp được xử lý bằng ràng buộc duy nhất; yêu cầu thử lại không tạo reaction trùng.

SOC-09 - Tạo bài viết video

Trường	Đặc tả
Dịch vụ sở hữu	Mạng xã hội
Tác nhân chính	Người dùng
Điều kiện trước	Đã hoàn tất phiên tải lên qua Phương tiện (MED-01/02); video sẵn sàng được xử lý.
Luồng chính	Tạo post với type=video và visibility=processing -> Phương tiện chuyển mã và tạo ảnh thu nhỏ bất đồng bộ -> khi nhận MediaReady, Mạng xã hội chuyển visibility sang published. SOC-03 với type=content được hiển thị ngay.
Kiểm tra và phân quyền	Giới hạn dung lượng và thời lượng video theo cấu hình; chỉ chủ sở hữu xem được post khi còn ở trạng thái processing.
Thay đổi dữ liệu	Thêm bản ghi post (type=video, visibility=processing); post_media_ref trỏ media video.
Sự kiện và thời gian thực	PostCreated (visibility=processing); PostUpdated khi chuyển sang published (theo MediaReady, mục 9).
Lỗi và trường hợp biên	Xử lý video thất bại -> post chuyển hoặc giữ trạng thái failed và không xuất hiện trong Bảng tin; áp dụng chính sách lỗi tại mục 17.
Ghi chú	SOC-03 với nội dung thông thường không qua xử lý bất đồng bộ; bài viết video luôn đi qua chuỗi xử lý Phương tiện trước khi vào Bảng tin.

SOC-10 - Chia sẻ bài viết ra nền tảng ngoài

Trường	Đặc tả
Dịch vụ sở hữu	Mạng xã hội
Tác nhân chính	Người dùng
Điều kiện trước	Bài viết tồn tại và mức hiển thị cho phép người dùng hiện tại xem sau khi áp dụng quy tắc chặn và riêng tư.
Luồng chính	Người dùng chọn chia sẻ -> máy chủ sinh liên kết kèm Open Graph metadata và ghi post_share -> trả liên kết để máy khách mở thao tác chia sẻ tới nền tảng ngoài.
Kiểm tra và phân quyền	Áp dụng cùng quy tắc hiển thị như khi đọc post.
Thay đổi dữ liệu	Thêm bản ghi post_share (post_id, user_id, platform, created_at).
Sự kiện và thời gian thực	Mạng xã hội phát PostShared; Bảng tin có thể dùng sự kiện này như tín hiệu xếp hạng.
Lỗi và trường hợp biên	Khi nền tảng không xác định, vẫn trả liên kết chung để máy khách sao chép hoặc tự xử lý.
Ghi chú	Việc đăng lên nền tảng ngoài do máy khách hoặc deep link xử lý; máy chủ chỉ sinh liên kết và ghi nhận lượt chia sẻ.

13.3 Cộng đồng và RTC

COM-01 - Tạo và cập nhật cộng đồng

Trường	Đặc tả
Dịch vụ sở hữu	Cộng đồng
Tác nhân chính	Người dùng/Chủ sở hữu
Điều kiện trước	Đã xác thực.
Luồng chính	Tạo membership chủ sở hữu, vai trò và kênh mặc định trong một giao dịch; cập nhật Cộng đồng bằng version.
Kiểm tra và phân quyền	Kiểm tra tên; chỉ chủ sở hữu được đối thiết lập quan trọng.
Thay đổi dữ liệu	Thêm/cập nhật community/member/role/channel.
Sự kiện và thời gian thực	CommunityCreated/Updated.
Lỗi và trường hợp biên	409 khi slug bị trùng nếu hệ thống dùng slug duy nhất.

COM-02 - Mời, tham gia và rời cộng đồng

Trường	Đặc tả
Dịch vụ sở hữu	Cộng đồng
Tác nhân chính	Người dùng
Điều kiện trước	Lời mời hợp lệ hoặc chính sách cộng đồng cho phép tham gia.
Luồng chính	Tạo lời mời; tham gia thì tạo membership; rời đi thì chuyển membership sang không hoạt động.
Kiểm tra và phân quyền	Kiểm tra thời hạn, số lượt dùng tối đa và trạng thái cấm; chủ sở hữu không được rời đi khi chưa chuyển quyền.
Thay đổi dữ liệu	Thêm hoặc cập nhật membership, invite và số lượt sử dụng.
Sự kiện và thời gian thực	MemberJoined/LeftCommunity.
Lỗi và trường hợp biên	410 khi lời mời hết hạn; 403 khi người dùng bị cấm.

COM-03 - Vai trò và quyền

Trường	Đặc tả
Dịch vụ sở hữu	Cộng đồng
Tác nhân chính	Chủ sở hữu/Điều hành viên
Điều kiện trước	Người gọi có quyền ManageRole.
Luồng chính	Tạo hoặc cập nhật vai trò, gán cho thành viên và tính quyền hiệu lực.
Kiểm tra và phân quyền	Không được nâng quyền vượt quá thứ bậc của người thực hiện; vai trò chủ sở hữu được bảo vệ.
Thay đổi dữ liệu	Thêm hoặc cập nhật role và member_role.
Sự kiện và thời gian thực	RoleUpdated/PermissionUpdated.
Lỗi và trường hợp biên	403 khi có hành vi nâng quyền vượt quá thứ bậc cho phép.

COM-04 - Tạo kênh văn bản hoặc kênh thoại

Trường	Đặc tả
Dịch vụ sở hữu	Cộng đồng
Tác nhân chính	Điều hành viên
Điều kiện trước	Người gọi có quyền ManageChannel.
Luồng chính	Tạo siêu dữ liệu kênh và phát sự kiện; Trò chuyện tạo bản chiếu cho kênh văn bản.
Kiểm tra và phân quyền	Kiểm tra thiết lập theo loại kênh; có thể áp dụng tên duy nhất.
Thay đổi dữ liệu	Thêm bản ghi channel/outbox.
Sự kiện và thời gian thực	ChannelCreated.
Lỗi và trường hợp biên	Bản chiếu Trò chuyện được tạo theo nhất quán cuối; trạng thái chờ phải quan sát được.

COM-05 - Điều hành thành viên

Trường	Đặc tả
Dịch vụ sở hữu	Cộng đồng
Tác nhân chính	Điều hành viên
Điều kiện trước	Đối tượng là thành viên và người thực hiện có quyền phù hợp.
Luồng chính	Tắt tiếng, loại hoặc cấm theo chính sách; sau đó phát sự kiện.
Kiểm tra và phân quyền	Tuân theo thứ bậc vai trò; không được điều hành chủ sở hữu hoặc vai trò cao hơn.
Thay đổi dữ liệu	Cập nhật community_member.status và các trường điều hành liên quan.
Sự kiện và thời gian thực	MemberModerated.
Lỗi và trường hợp biên	403 khi vi phạm thứ bậc vai trò.

RTC-01 - Cấp token tham gia LiveKit

Trường	Đặc tả
Dịch vụ sở hữu	Cộng đồng
Tác nhân chính	Thành viên
Điều kiện trước	Kênh thoại hoặc video tồn tại.
Luồng chính	Kiểm tra thành viên và quyền JoinVoice/Speak -> sinh token sống ngắn, giới hạn phạm vi.
Kiểm tra và phân quyền	Không tin userId do máy khách gửi; định danh lấy từ claim đã xác thực.
Thay đổi dữ liệu	Chỉ ghi siêu dữ liệu cuộc gọi hoặc phòng khi chức năng yêu cầu.
Sự kiện và thời gian thực	Sự kiện vòng đời cuộc gọi hoặc phòng là tùy chọn.
Lỗi và trường hợp biên	403 khi thiếu quyền; 503 khi LiveKit tạm thời không sẵn sàng.

RTC-02 - Thoại, video và chia sẻ màn hình

Trường	Đặc tả
Dịch vụ sở hữu	Mặt phẳng LiveKit
Tác nhân chính	Thành viên
Điều kiện trước	Token và quyền phượng tiện hợp lệ.
Luồng chính	Máy khách phát hoặc đăng ký track trực tiếp với LiveKit; dùng coturn khi kết nối trực tiếp thất bại.
Kiểm tra và phân quyền	Kiểm tra quyền ScreenShare/Speak và trạng thái tắt tiếng của máy khách.
Thay đổi dữ liệu	Ứng dụng không lưu các gói phượng tiện; chỉ có siêu dữ liệu tùy chọn.
Sự kiện và thời gian thực	Chỉ phát siêu dữ liệu vòng đời.
Lỗi và trường hợp biên	Lỗi RTC không được làm gián đoạn Trò chuyện văn bản.

RTC-03 - Phát trực tiếp màn hình trong phòng

Trường	Đặc tả
Dịch vụ sở hữu	Mặt phẳng LiveKit
Tác nhân chính	Thành viên
Điều kiện trước	Đã tham gia phòng thoại và có quyền ScreenShare.
Luồng chính	Phát track màn hình; người tham gia đăng ký nhận có chọn lọc.
Kiểm tra và phân quyền	Không dùng SRS hoặc phát công khai trong phạm vi cơ sở.
Thay đổi dữ liệu	Không ghi dữ liệu quan hệ ngoài siêu dữ liệu phiên tùy chọn.
Sự kiện và thời gian thực	StreamStarted/StreamEnded là tùy chọn.
Lỗi và trường hợp biên	Giới hạn tài nguyên hoặc mạng phải được trả rõ ràng cho người dùng và không làm gián đoạn Trò chuyện.

13.4 Trò chuyện và thời gian thực

CHT-01 - Tạo hội thoại trực tiếp hoặc nhóm

Trường	Đặc tả
Dịch vụ sở hữu	Trò chuyện
Tác nhân chính	Người dùng
Điều kiện trước	Người tham gia hợp lệ và không bị chặn theo chính sách.
Luồng chính	Tạo hội thoại và thành viên; trả về DTO hội thoại.
Kiểm tra và phân quyền	Giới hạn số người tham gia; hội thoại trực tiếp 1:1 trùng có thể dùng lại hội thoại hiện có.
Thay đổi dữ liệu	Thêm conversation và conversation_member.
Sự kiện và thời gian thực	ConversationCreated là tùy chọn.
Lỗi và trường hợp biên	403 khi bị chặn; 409 khi vi phạm chính sách hội thoại nhóm trùng.

CHT-02 - Gửi tin nhắn

Trường	Đặc tả
Dịch vụ sở hữu	Trò chuyện
Tác nhân chính	Thành viên hội thoại
Điều kiện trước	Người gọi là thành viên hội thoại.
Luồng chính	Lưu message và Outbox trong một giao dịch -> phát SignalR tới nhóm đang trực tuyến -> phát sự kiện Kafka bất đồng bộ.
Kiểm tra và phân quyền	Kiểm tra độ dài, loại, tham chiếu Phương tiện, tư cách thành viên, giới hạn tần suất và clientId chống gửi lặp.
Thay đổi dữ liệu	Thêm message và outbox_message trong cùng giao dịch; client_message_id duy nhất trong phạm vi hội thoại/người gửi.
Sự kiện và thời gian thực	MessageSent + SignalR MessageCreated.
Lỗi và trường hợp biên	clientId trùng trả về tin nhắn hiện có; nếu DB lỗi thì không phát tin nhắn ảo qua thời gian thực.

CHT-03 - Sửa và xóa tin nhắn

Trường	Đặc tả
Dịch vụ sở hữu	Trò chuyện
Tác nhân chính	Người gửi/Điều hành viên
Điều kiện trước	Tin nhắn tồn tại; người gọi là người gửi hoặc điều hành viên được cấp quyền.
Luồng chính	Cập nhật lạc quan hoặc xóa mềm -> phát cập nhật SignalR -> phát sự kiện.
Kiểm tra và phân quyền	Có thể giới hạn thời gian sửa; bắt buộc kiểm tra chủ sở hữu.
Thay đổi dữ liệu	Cập nhật message.version, edited_at hoặc deleted_at; ghi Outbox cho MessageEdited/MessageDeleted.
Sự kiện và thời gian thực	MessageEdited/Deleted.
Lỗi và trường hợp biên	409 xung đột.

CHT-04 - Tương tác với tin nhắn

Trường	Đặc tả
Dịch vụ sở hữu	Trò chuyện
Tác nhân chính	Thành viên hội thoại
Điều kiện trước	Người gọi là thành viên hội thoại và tin nhắn đích tồn tại.
Luồng chính	Thêm, cập nhật hoặc xóa tương tác bằng ràng buộc duy nhất.
Kiểm tra và phân quyền	Chỉ cho phép emoji hoặc type hợp lệ và áp dụng giới hạn tần suất.
Thay đổi dữ liệu	Thêm, cập nhật hoặc xóa message_reaction.
Sự kiện và thời gian thực	SignalR MessageReactionChanged; Kafka tùy chọn.
Lỗi và trường hợp biên	Tương tác trùng được xử lý an toàn bằng ràng buộc duy nhất.

CHT-05 - Trạng thái đang nhập

Trường	Đặc tả
Dịch vụ sở hữu	Trò chuyện/SignalR
Tác nhân chính	Thành viên hội thoại
Điều kiện trước	Kết nối đang hoạt động.
Luồng chính	Phát trạng thái đang nhập tạm thời; trạng thái tự dừng hoặc hết hạn.
Kiểm tra và phân quyền	Giới hạn tần suất; không ghi PostgreSQL.
Thay đổi dữ liệu	Chỉ ghi khóa Valkey có TTL khi cần; không ghi PostgreSQL.
Sự kiện và thời gian thực	SignalR TypingChanged.
Lỗi và trường hợp biên	Bỏ qua sự kiện trạng thái đang nhập khi người dùng ngoại tuyến.

CHT-06 - Trạng thái hiện diện

Trường	Đặc tả
Dịch vụ sở hữu	Trò chuyện/SignalR
Tác nhân chính	Người dùng
Điều kiện trước	Đang kết nối.
Luồng chính	Theo dõi số kết nối và lần hoạt động gần nhất trong Valkey với TTL; phát theo chính sách riêng tư.
Kiểm tra và phân quyền	Hỗ trợ nhiều kết nối thiết bị và áp dụng quyền riêng tư.
Thay đổi dữ liệu	Chỉ cập nhật Valkey; last_seen bền vững là tùy chọn và phải được điều tiết tần suất ghi.
Sự kiện và thời gian thực	SignalR PresenceChanged.
Lỗi và trường hợp biên	Mất kết nối mạng được xử lý bằng TTL và kết nối lại.

CHT-07 - Xác nhận đã đọc

Trường	Đặc tả
Dịch vụ sở hữu	Trò chuyện
Tác nhân chính	Thành viên hội thoại
Điều kiện trước	Tin nhắn thuộc hội thoại.
Luồng chính	Chỉ tăng con trỏ last_read và phát xác nhận đã đọc.
Kiểm tra và phân quyền	Không cho phép con trỏ đã đọc lùi lại.
Thay đổi dữ liệu	Cập nhật conversation_member.
Sự kiện và thời gian thực	SignalR ReadUpdated.
Lỗi và trường hợp biên	422 khi messageId không thuộc conversationId; 404 khi không tìm thấy hội thoại hoặc tin nhắn.

CHT-08 - Hộp thông báo

Trường	Đặc tả
Dịch vụ sở hữu	Trò chuyện
Tác nhân chính	Người dùng

Trường	Đặc tả
Điều kiện trước	Đã nhận sự kiện Mạng xã hội, Cộng đồng hoặc Trò chuyện liên quan.
Luồng chính	Bộ nhận sự kiện xử lý lập an toàn tạo thông báo -> phát SignalR khi người dùng trực tuyến -> cho phép đánh dấu đã đọc.
Kiểm tra và phân quyền	Kiểm tra người nhận, riêng tư, bộ lọc và EventId trùng.
Thay đổi dữ liệu	Thêm/cập nhật notification/inbox.
Sự kiện và thời gian thực	Phát SignalR NotificationCreated; thao tác đánh dấu đọc cập nhật NotificationRead.
Lỗi và trường hợp biên	Lỗi của bộ nhận sự kiện được thử lại hữu hạn; lỗi kéo dài chuyển DLQ.

CHT-09 - Lời mời cuộc gọi

Trường	Đặc tả
Dịch vụ sở hữu	Trò chuyện + cộng đồng
Tác nhân chính	Người dùng/Thành viên
Điều kiện trước	Người gọi có quyền đối với phòng hoặc cuộc gọi.
Luồng chính	Tạo trạng thái lời mời nhẹ -> phát SignalR tới người nhận -> khi chấp nhận thì chuyển sang luồng cấp token LiveKit.
Kiểm tra và phân quyền	Kiểm tra thành viên, chặn và quyền riêng tư.
Thay đổi dữ liệu	Có thể lưu call_invite tạm thời hoặc bền vững tùy yêu cầu lịch sử.
Sự kiện và thời gian thực	SignalR CallInvite/CallStateChanged.
Lỗi và trường hợp biên	Hết thời gian hoặc từ chối không được để lại tài nguyên Phương tiện hoặc phòng không sử dụng.

13.5 Bảng tin và gợi ý

FED-01 - Xây dựng bản chiếu bảng tin theo dõi

Trường	Đặc tả
Dịch vụ sở hữu	Bảng tin
Tác nhân chính	Bộ nhận sự kiện Kafka
Điều kiện trước	Có sự kiện PostCreated và UserFollowed cần xử lý.
Luồng chính	Xử lý sự kiện lập an toàn -> tạo hoặc cập nhật FeedEntry, FeedPostSummary và FeedUserSummary khi cần.
Kiểm tra và phân quyền	Bỏ qua ứng viên bị chặn, đã xóa hoặc không hợp lệ theo quyền riêng tư.
Thay đổi dữ liệu	Thêm hoặc cập nhật bản chiếu và inbox_message trong cùng giao dịch xử lý sự kiện.
Sự kiện và thời gian thực	Không yêu cầu sự kiện bên ngoài.
Lỗi và trường hợp biên	Sự kiện trùng không tạo bản chiếu trùng; độ trễ xử lý sự kiện phải được đo và cảnh báo.

FED-02 - Đọc bảng tin bằng con trỏ

Trường	Đặc tả
Dịch vụ sở hữu	Bảng tin
Tác nhân chính	Người dùng
Điều kiện trước	Đã xác thực.
Luồng chính	Kiểm tra bộ nhớ đệm Valkey -> đọc FeedDb khi không có -> áp dụng con trỏ và giới hạn -> trả DTO đầy đủ.
Kiểm tra và phân quyền	Giới hạn kích thước trang; lọc cứng theo hiển thị và bảo đảm thứ tự ổn định.
Thay đổi dữ liệu	Không ghi dữ liệu ngoài bộ nhớ đệm.
Sự kiện và thời gian thực	Không có.
Lỗi và trường hợp biên	Không có dữ liệu trong bộ nhớ đệm là bình thường; khi hệ thống gợi ý lỗi thì dùng Bảng tin theo thời gian.

FED-03 - Cập nhật bản chiếu và làm mất hiệu lực bộ nhớ đệm

Trường	Đặc tả
Dịch vụ sở hữu	Bảng tin
Tác nhân chính	Bộ nhận sự kiện Kafka
Điều kiện trước	Có sự kiện Profile hoặc Post.
Luồng chính	Cập nhật bản tóm tắt cục bộ rồi làm mất hiệu lực các khóa bộ nhớ đệm liên quan.
Kiểm tra và phân quyền	Kiểm tra phiên bản sự kiện và khả năng xử lý lặp an toàn.
Thay đổi dữ liệu	Cập nhật bản chiếu và inbox_message; chỉ làm mất hiệu lực cache sau khi giao dịch thành công.
Sự kiện và thời gian thực	Không có.
Lỗi và trường hợp biên	Sự kiện cũ hoặc sai thứ tự được xử lý bằng version hoặc dấu thời gian khi cần.

FED-04 - Sinh ứng viên và chấm điểm gợi ý

Trường	Đặc tả
Dịch vụ sở hữu	Bảng tin và dữ liệu AI
Tác nhân chính	Người dùng
Điều kiện trước	Có đủ dữ liệu ứng viên hoặc có phương án dự phòng.
Luồng chính	Kết hợp ứng viên từ theo dõi, phổ biến, ngữ nghĩa và cộng tác -> chấm điểm -> điều chỉnh đa dạng -> lấy N kết quả đầu.
Kiểm tra và phân quyền	Áp dụng bộ lọc cứng về quyền riêng tư và chặn trước khi trả kết quả.
Thay đổi dữ liệu	Lưu Top-N trong Valkey; điểm gợi ý bền vững là tùy chọn.
Sự kiện và thời gian thực	Không có.
Lỗi và trường hợp biên	Khi chưa có dữ liệu dùng nội dung phổ biến hoặc đang theo dõi; khi AI/pgvector lỗi dùng thứ tự thời gian.

FED-05 - Cập nhật embedding sở thích

Trường	Đặc tả
Dịch vụ sở hữu	AI và tìm kiếm
Tác nhân chính	Tiến trình nền
Điều kiện trước	Đã thu thập tương tác của người dùng.
Luồng chính	Xử lý theo lô hoặc bất đồng bộ để suy ra vector sở thích từ embedding của nội dung đã tương tác.
Kiểm tra và phân quyền	Loại nội dung không thể truy cập hoặc đã xóa; giảm trọng số tín hiệu cũ.
Thay đổi dữ liệu	Cập nhật embedding hoặc kho đặc trưng của người dùng.
Sự kiện và thời gian thực	EmbeddingGenerated là tùy chọn.
Lỗi và trường hợp biên	Áp dụng backpressure và thử lại; không nằm trên đường xử lý đồng bộ của yêu cầu.

13.6 Dịch vụ phương tiện

MED-01 - Tạo phiên tải lên

Trường	Đặc tả
Dịch vụ sở hữu	Phương tiện
Tác nhân chính	Người dùng
Điều kiện trước	Đã xác thực.
Luồng chính	Kiểm tra siêu dữ liệu khai báo -> sinh khóa đối tượng -> tạo UploadSession -> sinh URL PUT ký trước sống ngắn.
Kiểm tra và phân quyền	Chỉ cho phép MIME, kích thước và mục đích hợp lệ; khóa đối tượng do máy chủ sinh.
Thay đổi dữ liệu	Thêm bản ghi UploadSession.
Sự kiện và thời gian thực	Không có.
Lỗi và trường hợp biên	Áp dụng giới hạn tần suất; trả 422 khi kích thước, MIME hoặc mục đích không hợp lệ.

MED-02 - Tải trực tiếp

Trường	Đặc tả
Dịch vụ sở hữu	Mặt phẳng SeaweedFS
Tác nhân chính	Người dùng
Điều kiện trước	URL ký trước còn hiệu lực.
Luồng chính	Máy khách gửi dữ liệu bằng PUT trực tiếp tới kho đối tượng.
Kiểm tra và phân quyền	Kiểm tra chữ ký, TTL và ràng buộc khóa đối tượng.
Thay đổi dữ liệu	Chỉ ghi đối tượng vào kho lưu trữ.
Sự kiện và thời gian thực	Không có.
Lỗi và trường hợp biên	Không sử dụng băng thông của backend cho nội dung tệp.

MED-03 - Hoàn tất và xác minh tải lên

Trường	Đặc tả
Dịch vụ sở hữu	Phương tiện
Tác nhân chính	Chủ sở hữu
Điều kiện trước	UploadSession đang chờ hoàn tất.
Luồng chính	Gọi HEAD/stat đối tượng -> xác minh tồn tại, kích thước và loại -> chuyển sang Uploaded -> ghi Outbox.
Kiểm tra và phân quyền	Kiểm tra chủ sở hữu và thời hạn phiên; không tin tuyên bố thành công từ máy khách.
Thay đổi dữ liệu	Cập nhật upload_session, media_asset và outbox_message.
Sự kiện và thời gian thực	MediaUploaded.
Lỗi và trường hợp biên	Yêu cầu hoàn tất lặp trả kết quả hiện có; 410 khi UploadSession hết hạn.

MED-04 - Xử lý phương tiện

Trường	Đặc tả
Dịch vụ sở hữu	Tiến trình nền Phương tiện
Tác nhân chính	Tiến trình nền
Điều kiện trước	Đã nhận sự kiện MediaUploaded.
Luồng chính	Kiểm tra chữ ký tệp -> tùy chọn đổi kích thước ảnh và loại siêu dữ liệu -> chuyển sang Ready hoặc Failed.
Kiểm tra và phân quyền	Giới hạn số tác vụ đồng thời; chỉ thử lại lỗi tạm thời.
Thay đổi dữ liệu	Cập nhật MediaAsset.
Sự kiện và thời gian thực	MediaReady/Failed.
Lỗi và trường hợp biên	Phương tiện không xử lý được -> chuyển DLQ và trạng thái Failed.

MED-05 - Xóa và dọn dẹp phương tiện

Trường	Đặc tả
Dịch vụ sở hữu	Phương tiện
Tác nhân chính	Chủ sở hữu/Hệ thống
Điều kiện trước	Chính sách tham chiếu cho phép xóa.
Luồng chính	Đánh dấu hoặc xóa siêu dữ liệu và đối tượng; nếu cần thì lên lịch dọn dẹp.
Kiểm tra và phân quyền	Không xóa Phương tiện còn tham chiếu; dọn đối tượng mồ côi bằng tác vụ TTL.
Thay đổi dữ liệu	Cập nhật hoặc xóa media_asset và đối tượng lưu trữ theo chính sách.
Sự kiện và thời gian thực	MediaDeleted.
Lỗi và trường hợp biên	Lỗi xóa đối tượng được thử lại bất đồng bộ.

MED-06 - Phương tiện cho tin nhắn thoại

Trường	Đặc tả
Dịch vụ sở hữu	Phương tiện và trò chuyện
Tác nhân chính	Người dùng
Điều kiện trước	Người gọi là thành viên Trò chuyện.
Luồng chính	Tải âm thanh qua luồng Phương tiện thông thường; message Trò chuyện chỉ tham chiếu MediaAsset Ready; tác vụ chuyển lời nói thành văn bản là tùy chọn.
Kiểm tra và phân quyền	Áp dụng chính sách MIME, kích thước và thời lượng âm thanh.
Thay đổi dữ liệu	Phương tiện lưu MediaAsset; Trò chuyện lưu tham chiếu MediaId trong message.
Sự kiện và thời gian thực	MediaReady có thể kích hoạt tác vụ chuyển lời nói thành văn bản trong AI và tìm kiếm.
Lỗi và trường hợp biên	Lỗi chuyển lời nói thành văn bản không làm mất tin nhắn âm thanh gốc.

13.7 Dịch vụ thương mại

MKT-01 - Tạo và sửa tin đăng

Trường	Đặc tả
Dịch vụ sở hữu	Thương mại
Tác nhân chính	Người bán
Điều kiện trước	Người bán đã xác thực.
Luồng chính	Tạo hoặc cập nhật listing với tham chiếu Phương tiện, giá, trạng thái và version.
Kiểm tra và phân quyền	Giá > 0; kiểm tra chủ sở hữu; Phương tiện ở Ready; kiểm tra version lạc quan.
Thay đổi dữ liệu	Thêm hoặc cập nhật listing, listing_media_ref và outbox_message.
Sự kiện và thời gian thực	ListingCreated/Updated.
Lỗi và trường hợp biên	409 khi version xung đột; 422 khi giá hoặc Phương tiện không hợp lệ.

MKT-02 - Duyệt và tìm kiếm tin đăng

Trường	Đặc tả
Dịch vụ sở hữu	Thương mại
Tác nhân chính	Người dùng/Khách theo chính sách
Điều kiện trước	Tin đăng đang hoạt động tồn tại.
Luồng chính	Truy vấn bằng cursor và bộ lọc; dùng PostgreSQL FTS làm cơ sở hoặc OpenSearch khi được bật.

Trường	Đặc tả
Kiểm tra và phân quyền	Không trả tin đăng không hoạt động hoặc không được phép xem.
Thay đổi dữ liệu	Không ghi dữ liệu.
Sự kiện và thời gian thực	Không có.
Lỗi và trường hợp biên	Khi phân hệ tìm kiếm lỗi, dùng truy vấn DB dự phòng nếu khả thi.

MKT-03 - Cập nhật và giữ tồn kho

Trường	Đặc tả
Dịch vụ sở hữu	Thương mại
Tác nhân chính	Người bán/Hệ thống
Điều kiện trước	Tin đăng đang hoạt động.
Luồng chính	Người bán điều chỉnh tồn kho; bước thanh toán giữ số lượng bằng thao tác nguyên tử.
Kiểm tra và phân quyền	quantity >= 0; ngăn bán vượt tồn bằng giao dịch, version hoặc khóa dòng theo thiết kế đã chọn.
Thay đổi dữ liệu	Cập nhật inventory/version.
Sự kiện và thời gian thực	InventoryReserved/Released tùy chọn.
Lỗi và trường hợp biên	Xung đột tồn kho trả trạng thái hết hàng; yêu cầu thử lại không được giữ hàng hai lần.

MKT-04 - Tạo đơn hàng

Trường	Đặc tả
Dịch vụ sở hữu	Thương mại
Tác nhân chính	Người mua
Điều kiện trước	Mặt hàng đang hoạt động và số lượng hợp lệ.
Luồng chính	Tạo bản chụp đơn hàng -> giữ tồn kho -> chuyển sang AwaitingPayment.
Kiểm tra và phân quyền	Áp dụng chính sách người mua/người bán nếu cần; chụp giá và dùng idempotency key.
Thay đổi dữ liệu	Thêm order, order_item, order_status_history và cập nhật inventory trong giao dịch.
Sự kiện và thời gian thực	OrderCreated.
Lỗi và trường hợp biên	Giữ tồn kho thất bại -> chuyển Cancelled và không để lại đơn hàng dở dang.

MKT-05 - Thanh toán giả lập

Trường	Đặc tả
Dịch vụ sở hữu	Thương mại
Tác nhân chính	Người mua
Điều kiện trước	Đơn hàng ở trạng thái AwaitingPayment.
Luồng chính	Gọi MockPaymentProvider -> lưu kết quả lập an toàn -> xác nhận hoặc thực hiện bù trừ.
Kiểm tra và phân quyền	Idempotency-Key phải duy nhất; số tiền phải khớp đơn hàng.

Trường	Đặc tả
Thay đổi dữ liệu	Thêm payment, cập nhật order và thực hiện bù trừ inventory khi thanh toán thất bại.
Sự kiện và thời gian thực	PaymentSucceeded/Failed.
Lỗi và trường hợp biên	Yêu cầu lập trả cùng kết quả.

MKT-06 - Trạng thái đơn hàng và Saga đơn giản hóa

Trường	Đặc tả
Dịch vụ sở hữu	Thương mại
Tác nhân chính	Hệ thống
Điều kiện trước	Trạng thái hiện tại hợp lệ.
Luồng chính	Áp dụng máy trạng thái: Pending, AwaitingPayment, Paid, Processing, Completed và Cancelled.
Kiểm tra và phân quyền	Từ chối chuyển trạng thái không hợp lệ.
Thay đổi dữ liệu	Cập nhật order và thêm order_status_history.
Sự kiện và thời gian thực	OrderStatusChanged.
Lỗi và trường hợp biên	Bù trừ giải phóng tồn kho đã giữ khi thất bại hoặc hủy.

MKT-07 - Phương tiện của tin đăng

Trường	Đặc tả
Dịch vụ sở hữu	Commerce + Phương tiện
Tác nhân chính	Người bán
Điều kiện trước	Phương tiện ở trạng thái Ready.
Luồng chính	Lưu tham chiếu MediaId trong listing; không sao chép dữ liệu nhị phân.
Kiểm tra và phân quyền	Kiểm tra chủ sở hữu và mục đích sử dụng.
Thay đổi dữ liệu	Chỉ thêm hoặc xóa listing_media_ref.
Sự kiện và thời gian thực	Không có.
Lỗi và trường hợp biên	Xóa listing không xóa ngay Phương tiện dùng chung; chỉ dọn khi không còn tham chiếu.

13.8 Dịch vụ AI và tìm kiếm

AI-01 - Tạo embedding

Trường	Đặc tả
Dịch vụ sở hữu	AI và tìm kiếm
Tác nhân chính	Tiến trình nền
Điều kiện trước	Có thực thể nguồn hoặc sự kiện nguồn.
Luồng chính	Chuẩn hóa văn bản đã cấp quyền -> gọi mô hình embedding qua bộ chuyển đổi Ollama -> lưu vector cùng tên mô hình và phiên bản.

Trường	Đặc tả
Kiểm tra và phân quyền	Giới hạn đầu vào; loại trường không hỗ trợ hoặc riêng tư; xử lý lập an toàn theo thực thể và phiên bản mô hình.
Thay đổi dữ liệu	Upsert ai_embedding và cập nhật ai_job.
Sự kiện và thời gian thực	EmbeddingGenerated là tùy chọn.
Lỗi và trường hợp biên	Thử lại lỗi tạm thời; lỗi mô hình hoặc đầu vào kéo dài được chuyển DLQ.

AI-02 - Tìm kiếm ngữ nghĩa

Trường	Đặc tả
Dịch vụ sở hữu	AI và tìm kiếm
Tác nhân chính	Người dùng
Điều kiện trước	Đã xác định phạm vi tìm kiếm.
Luồng chính	Tạo embedding cho truy vấn -> tính độ tương đồng bằng pgvector -> lọc theo phạm vi được cấp quyền -> trả tham chiếu và đoạn trích đã xếp hạng.
Kiểm tra và phân quyền	Bắt buộc lọc theo quyền trước khi hiển thị dữ liệu.
Thay đổi dữ liệu	Không ghi dữ liệu ngoài chỉ số và bộ nhớ đệm.
Sự kiện và thời gian thực	Không có.
Lỗi và trường hợp biên	Dùng PostgreSQL FTS dự phòng khi runtime embedding không sẵn sàng.

AI-03 - Trợ lý RAG

Trường	Đặc tả
Dịch vụ sở hữu	AI và tìm kiếm
Tác nhân chính	Người dùng
Điều kiện trước	Đã xác thực và có quyền truy cập phạm vi nguồn được yêu cầu.
Luồng chính	Truy xuất các chunk đã cấp quyền -> tạo prompt -> gọi Ollama -> truyền phản hồi tăng dần qua SignalR hoặc luồng HTTP.
Kiểm tra và phân quyền	Giới hạn prompt/ngữ cảnh, kiểm tra quyền và giới hạn tần suất AI.
Thay đổi dữ liệu	Có thể lưu nhật ký yêu cầu/hội thoại nhưng không lưu nội dung nhạy cảm.
Sự kiện và thời gian thực	SignalR AiToken/AiCompleted.
Lỗi và trường hợp biên	Khi AI không sẵn sàng, trả thông báo suy giảm; không làm lỗi chức năng cốt lõi.

AI-04 - Tóm tắt tin nhắn hoặc kênh

Trường	Đặc tả
Dịch vụ sở hữu	AI và tìm kiếm + trò chuyện
Tác nhân chính	Thành viên hội thoại
Điều kiện trước	Trò chuyện đã cấp quyền cho khoảng nội dung được yêu cầu.

Trường	Đặc tả
Luồng chính	Trò chuyện cung cấp nội dung đã giới hạn hoặc hợp đồng xuất dữ liệu -> AI tóm tắt -> trả kết quả.
Kiểm tra và phân quyền	AI không được truy vấn trực tiếp chat_db; Trò chuyện phải kiểm tra tư cách thành viên.
Thay đổi dữ liệu	Có thể lưu ai_summary kèm phạm vi nguồn và phiên bản mô hình.
Sự kiện và thời gian thực	AiSummaryReady là tùy chọn.
Lỗi và trường hợp biên	Chia nhỏ lịch sử dài; tuân theo quy tắc tin nhắn đã xóa và riêng tư.

AI-05 - Chuyển lời nói thành văn bản

Trường	Đặc tả
Dịch vụ sở hữu	AI và tìm kiếm
Tác nhân chính	Tiến trình nền/Người dùng
Điều kiện trước	Âm thanh đã MediaReady và có yêu cầu chuyển lời nói thành văn bản.
Luồng chính	Tiến trình nền tải đối tượng đã cấp quyền -> xử lý bằng whisper.cpp -> lưu bản chép lời -> phát sự kiện cho Trò chuyện.
Kiểm tra và phân quyền	Kiểm tra kích thước, thời lượng, ngôn ngữ và giới hạn số tiến trình xử lý đồng thời.
Thay đổi dữ liệu	Cập nhật ai_job và siêu dữ liệu transcript.
Sự kiện và thời gian thực	TranscriptReady.
Lỗi và trường hợp biên	Khi thất bại, âm thanh gốc vẫn dùng được; áp dụng thử lại hoặc DLQ.

AI-06 - Đánh chỉ mục OpenSearch - tùy chọn

Trường	Đặc tả
Dịch vụ sở hữu	AI và tìm kiếm
Tác nhân chính	Bộ nhận sự kiện Kafka
Điều kiện trước	Cấu hình OpenSearch được bật.
Luồng chính	Nhận sự kiện Post, Listing và User -> cập nhật chỉ mục lập an toàn; hỗ trợ bù dữ liệu theo lô và điểm kiểm tra.
Kiểm tra và phân quyền	Chỉ đánh chỉ mục các trường được phép tìm kiếm.
Thay đổi dữ liệu	Cập nhật bản chiếu và điểm kiểm tra của OpenSearch.
Sự kiện và thời gian thực	Không có.
Lỗi và trường hợp biên	Khi OpenSearch bị tắt, PostgreSQL FTS vẫn là phương án cơ sở.

14. Chỉ mục cơ sở dữ liệu và xử lý đồng thời

Chỉ mục và cơ chế xử lý đồng thời phải gắn với mẫu truy cập cụ thể, không tạo tùy tiện.

Bảng 14 - Chỉ mục và xử lý đồng thời

Khu vực	Chỉ mục hoặc cơ chế khuyến nghị
Danh sách bài viết	post(author_id, created_at DESC, id DESC); cân nhắc chỉ mục một phần WHERE deleted_at IS NULL.
Bình luận	comment(post_id, created_at, id) để phân trang bằng con trỏ.
Tương tác bài viết	UNIQUE(post_id, user_id).
Lịch sử trò chuyện	message(conversation_id, created_at DESC, id DESC); UNIQUE(conversation_id, sender_id, client_message_id).
Thông báo	notification(recipient_id, is_read, created_at DESC, id DESC).
Bảng tin	feed_entry(user_id, score DESC, created_at DESC, id DESC) hoặc chỉ mục theo cấu trúc con trỏ thực tế.
Tồn kho thương mại	listing_id là PK; có version; dùng UPDATE nguyên tử hoặc khóa dòng cho thao tác giữ hàng.
Đơn hàng và thanh toán	order(buyer_id, created_at DESC, id DESC); payment(idempotency_key UNIQUE).
Xử lý đồng thời lạc quan	Có cột version trên các aggregate có chỉnh sửa hoặc tranh chấp cao: profile, post, message, community, listing, inventory, order.
UUID	Ưu tiên UUIDv7 để có tính cục bộ theo thời gian và tạo phân tán.

15. Bộ nhớ đệm và bản chiếu dữ liệu

Khóa bộ nhớ đệm, TTL và quy tắc làm mất hiệu lực phải được mô tả cùng chức năng liên quan.

Bảng 15 - Bộ nhớ đệm và bản chiếu dữ liệu

Bộ nhớ đệm/Bản chiếu	Khóa và cách làm mất hiệu lực
Trang Bảng tin	feed:{userId}:{cursorBucket}; làm mất hiệu lực khi Post/Follow/Profile liên quan thay đổi hoặc dùng TTL ngắn.
Tóm tắt người dùng	user-summary:{userId}; cập nhật hoặc xóa khi nhận UserProfileUpdated/UserAvatarUpdated.
Hiện diện	presence:{userId}; TTL và bộ đếm kết nối; không phải nguồn dữ liệu bền vững.
Top-N gợi ý	recommendation:{userId}; có TTL và làm mới bất đồng bộ sau tương tác đáng kể.
Giới hạn tần suất	rate:{policy}:{subject}:{window}; dữ liệu tạm thời.
Bản chiếu Bảng tin	Tóm tắt Post/User cập nhật từ Kafka; chỉ giữ trường tối thiểu cần để trả dữ liệu hoàn chỉnh.

16. Bảo mật

Kiểm tra quyền được thực hiện tại ranh giới nghiệp vụ, không chỉ tại Gateway.

Bảng 16 - Ma trận bảo mật

Tài nguyên	Kiểm tra bắt buộc
Hồ sơ	Quyền hiển thị theo mức riêng tư; chỉ chủ sở hữu được sửa.
Bài viết	Quyền xem và trạng thái chặn; chủ sở hữu hoặc điều hành mới được sửa/xóa.
Cộng đồng	Tư cách thành viên, quyền hiệu lực và thứ bậc vai trò.
Hội thoại	Tư cách thành viên; chính sách chặn cho hội thoại trực tiếp.
RTC	Tư cách thành viên và quyền JoinVoice/Speak/ScreenShare; token sống ngắn và giới hạn phạm vi.
Phương tiện	Chủ sở hữu, mục đích, kích thước, MIME; URL ký trước có TTL; xác minh đối tượng sau tải lên.
Thương mại	Người bán sở hữu tin đăng; người mua sở hữu đơn; thanh toán và tạo đơn phải xử lý lặp an toàn.
AI/RAG	Kiểm tra quyền trên nguồn trước khi truy xuất và trước khi đưa nội dung vào ngữ cảnh.
Vận hành	Điểm cuối quản trị và phát lại DLQ phải được bảo vệ, ghi nhật ký và giới hạn người dùng.
Khôi phục mật khẩu	OTP dùng một lần, TTL ngắn, giới hạn theo tài khoản/IP, không tiết lộ tài khoản tồn tại và thu hồi mọi refresh token sau khi thành công.

16.1 Bảo vệ dữ liệu định danh cá nhân

- Che một phần email và số điện thoại khi trả API cho người không phải chủ sở hữu; chỉ chủ sở hữu hoặc quản trị viên được xem đầy đủ.
- Không ghi dữ liệu định danh cá nhân thô như email, OTP hoặc mật khẩu vào nhật ký; chỉ ghi userId hoặc giá trị băm khi cần.
- Tài phương tiện hoặc ảnh đại diện phải kiểm tra kích thước và MIME trước khi lưu; truy cập qua URL ký trước có TTL ngắn, không công khai bucket.
- Tài khoản xóa mềm phải ẩn dữ liệu định danh cá nhân sau thời gian ân hạn trước khi xóa cứng theo chính sách lưu giữ.

16.2 Mã hóa khi truyền và khi lưu

- Khi truyền: bắt buộc TLS cho toàn bộ lưu lượng công khai; kết nối nội bộ giữa các dịch vụ đi qua mạng Docker riêng.
- Khi lưu: password_hash và otp_hash dùng thuật toán băm có salt như Argon2 hoặc bcrypt; không lưu văn bản thuần; refresh token chỉ lưu token_hash.
- Bí mật như mật khẩu DB, khóa ký JWT và thông tin SMTP nằm trong biến môi trường hoặc kho bí mật; không ghi cứng trong kho mã.
- Phương tiện nhạy cảm được lưu trên SeaweedFS và truy cập bằng URL ký trước thay vì liên kết công khai.

16.3 Giới hạn tần suất và điều tiết tải

- Áp dụng theo chính sách tại YARP Gateway và ranh giới nghiệp vụ; khóa có dạng rate:{policy}:{subject}:{window}.
- Khôi phục mật khẩu và OTP: giới hạn số yêu cầu theo tài khoản và IP theo ACC-08/09.
- Đăng nhập: giới hạn số lần sai trước khi khóa tạm; CAPTCHA thuộc thiết kế cho tương lai.
- Điểm cuối AI/RAG: giới hạn số yêu cầu mỗi phút theo người dùng để tránh lạm dụng tài nguyên mô hình.

16.4 Kiểm tra và làm sạch dữ liệu

- Mọi dữ liệu đầu vào phải qua kiểm tra DTO bằng FluentValidation hoặc DataAnnotations tại tầng API trước khi vào nghiệp vụ.
- Dùng danh sách cho phép thay vì danh sách cấm cho trường có định dạng cố định như username, kiểu liệt kê và mức hiển thị.
- Làm sạch rich text hoặc Markdown của post, comment và message trước khi lưu và trước khi hiển thị ở máy khách.
- Tệp tải lên phải được kiểm tra MIME, kích thước và loại đúng với mục đích Phương tiện hoặc avatar.
- Google OAuth: xác minh id_token bằng thư viện chính thức và JWKS của Google; kiểm tra issuer, audience và exp trước khi tin claim.

16.5 Chống XSS và CSRF

- XSS: mã hóa đầu ra khi hiển thị, đặt header Content-Security-Policy và làm sạch HTML đầu vào để loại script, style và event handler.
- CSRF: API ưu tiên Bearer token trong header thay vì phiên cookie, nhờ đó giảm rủi ro CSRF cổ điển.
- Nếu refresh token nằm trong cookie, bắt buộc SameSite=Strict hoặc Lax và CSRF token cho yêu cầu thay đổi trạng thái.
- CORS chỉ cho phép origin của giao diện đã cấu hình; không dùng ký tự đại diện cho yêu cầu có credential.

16.6 Kiểm duyệt nội dung bằng AI - thiết kế cho tương lai

- Mục tiêu: tự động phát hiện spam, ngôn từ thù ghét hoặc nội dung nhạy cảm trong post, comment và chat.
- Thiết kế: dùng AI và tìm kiếm làm bộ phân loại nhẹ; kết quả chỉ gắn cờ và đưa vào hàng đợi điều hành thay vì tự động xóa, nhằm giảm cảnh báo sai.
- Không thuộc phạm vi bắt buộc 6 tháng; chỉ giữ thiết kế cho moderation_flag, sự kiện ContentFlagged và điểm cuối duyệt của quản trị viên.

17. Xử lý lỗi, thử lại và DLQ

Mỗi bộ nhận sự kiện có chính sách thử lại riêng; lỗi nghiệp vụ vĩnh viễn không được thử lại vô hạn.

Bảng 17 - Xử lý lỗi, thử lại và DLQ

Sự cố	Cách xử lý dự kiến
Kafka tạm thời không sẵn sàng sau khi DB đã commit	Bản ghi Outbox giữ trạng thái chờ; tiến trình nền thử lại có giãn cách.
Sự kiện Kafka bị giao lặp	Inbox hoặc khóa duy nhất theo EventId ngăn tác dụng phụ trùng.
Bộ nhận sự kiện gặp lỗi DB tạm thời	Thử lại và chỉ commit offset sau khi giao dịch xử lý thành công.
Sự kiện độc hại hoặc sai lược đồ	Thử lại hữu hạn, chuyển vào DLQ theo miền và phát cảnh báo.
AI runtime không sẵn sàng	Xếp hàng/thử lại tác vụ bất đồng bộ hoặc trả phản hồi suy giảm; Mạng xã hội và Trò chuyện không bị gián đoạn.
LiveKit không sẵn sàng	Trò chuyện văn bản vẫn hoạt động; yêu cầu RTC trả lỗi tạm thời rõ ràng.
Valkey không sẵn sàng	Đọc DB khi có thể; hiện diện và bộ nhớ đệm suy giảm nhưng dữ liệu chuẩn vẫn nguyên vẹn.
OpenSearch không sẵn sàng	Hạ cấp về PostgreSQL FTS hoặc tìm kiếm ngữ nghĩa cơ sở.
Tải lên SeaweedFS không hoàn tất	UploadSession hết hạn; tác vụ dọn dẹp xóa đối tượng mô côi.

18. Khả năng quan sát và kịch bản kiểm thử

Các kịch bản này đồng thời là kế hoạch kiểm thử và bằng chứng vận hành của kiến trúc phân tán.

18.1 Giám sát và cảnh báo

Giám sát vận hành được hoàn thiện trong giai đoạn 5 của lộ trình.

Bảng 18 - Chỉ số giám sát và cảnh báo

Chỉ số/Tín hiệu	Nguồn	Ngưỡng cảnh báo	Hành động
Tỷ lệ lỗi API 5xx	OpenTelemetry/Gateway	> 5% trong 5 phút	Xem log và trace; quay lui nếu liên quan bản triển khai mới.
Độ trễ API p95	OpenTelemetry	Vượt NFR trong 10 phút	Kiểm tra truy vấn chậm, N+1 và span có thời gian lớn.
Độ trễ bộ nhận sự kiện Kafka	Kafka exporter	> 1000 bản tin hoặc > 60 giây theo topic	Kiểm tra bộ nhận sự kiện bị chặn, tăng bộ nhận sự kiện khi còn phân vùng và xử lý backpressure.
Tình trạng broker Kafka	Kiểm tra sức khỏe	Không sẵn sàng > 1 phút	Cảnh báo ngay; xác nhận Outbox vẫn giữ bản ghi chờ.
Mức dùng pool kết nối DB	PostgreSQL exporter	> 80% trong 5 phút	Kiểm tra rò rỉ kết nối và truy vấn giữ kết nối quá lâu.
Dung lượng đĩa	Node exporter	> 85%	Xoay vòng nhật ký, dọn dữ liệu tạm hoặc tăng dung lượng.
Số phòng/người tham gia LiveKit	LiveKit metrics	Gần ngưỡng dung lượng đã kiểm thử	Hạn chế tạo phòng mới và kiểm tra CPU, RAM, băng thông.
Bộ nhớ Valkey	Valkey INFO/exporter	> 80% maxmemory	Kiểm tra TTL, chính sách loại bỏ và khóa tăng không kiểm soát.
Độ sâu hàng đợi AI/RAG	Chỉ số ứng dụng	Tăng liên tục và không giảm trong thời gian cấu hình	Kiểm tra môi trường chạy Ollama/LLM, số tiến trình nền và cơ chế điều tiết tải.
Tuổi bản ghi Outbox lâu nhất	Ứng dụng/DB	> 5 phút	Kiểm tra broker, tiến trình phát và lỗi tuần tự hóa; không xóa bản ghi chưa xác nhận.
Số bản tin DLQ	Kafka/Ứng dụng	> 0 mới trong 5 phút	Cảnh báo, phân loại lỗi, sửa nguyên nhân và phát lại có kiểm soát.
Công việc xóa tài khoản quá hạn	Ứng dụng	> 0 quá delete_after	Chạy đối soát, xác định dịch vụ chưa xác nhận và kích hoạt purge lại.
Tuổi báo cáo điều hành cũ nhất	Ứng dụng	> 24 giờ ở trạng thái Pending	Cảnh báo hàng đợi, phân công người xử lý và kiểm tra lạm dụng/spam.

- Chỉ số: Prometheus thu thập qua OpenTelemetry Collector từ từng dịch vụ; bảng điều khiển Grafana theo dịch vụ (RED: Rate/Error/Duration) và theo hạ tầng (Kafka/DB/Valkey/LiveKit).
- Theo dõi phân tán: OpenTelemetry kết hợp Jaeger hoặc Zipkin; traceId đi xuyên các dịch vụ.
- Nhật ký: định dạng JSON có traceId và correlationId; thời gian lưu tối thiểu 7 ngày và xoay vòng để tránh đầy đĩa.
- Cảnh báo: Alertmanager hoặc Grafana Alert gửi thông báo qua kênh đã cấu hình khi vượt ngưỡng.
- Quy trình xử lý sự cố: kiểm tra trace, nhật ký và chỉ số hạ tầng; quay lui bản triển khai khi cần.
- Bộ quan sát đầy đủ nằm trong cấu hình có thể tắt để giảm tài nguyên khi không cần thu thập chi tiết.

18.2 Kịch bản kiểm thử

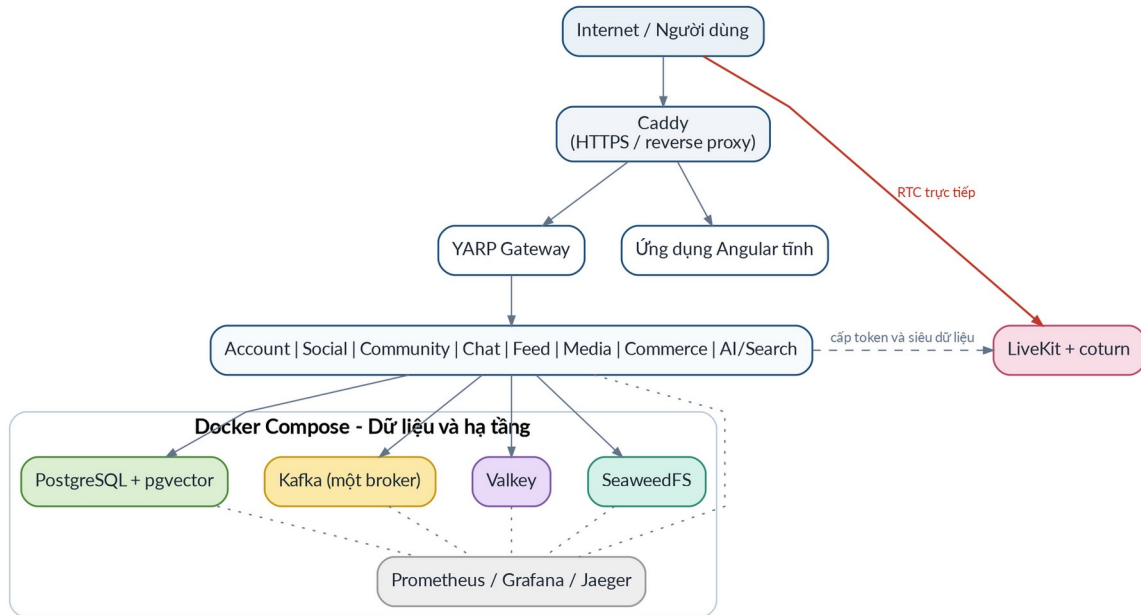
Bảng 19 - Kịch bản kiểm thử

Kịch bản	Bằng chứng chấp nhận
Tạo bài viết đến Bảng tin	Trace xuyên Gateway, Mạng xã hội, PostgreSQL, Kafka và Bảng tin; kiểm thử tích hợp xác nhận bản chiếu.

Kịch bản	Bảng chứng chấp nhận
Nhận PostCreated lập	Số dòng và bộ đếm Bảng tin không thay đổi sau lần xử lý thứ hai.
Kafka ngừng tạm thời	Tạo bài viết vẫn commit cục bộ; Outbox ở trạng thái chờ và phát sau khi broker phục hồi.
Sự kiện độc hại	Thử lại hữu hạn, vào DLQ, phát metric/cảnh báo và phát lại thành công sau khi sửa.
Tin nhắn thời gian thực	Tin nhắn tồn tại trong DB trước khi phát SignalR; kết nối lại tải được lịch sử bị bỏ lỡ.
Làm mất hiệu lực bộ nhớ đệm	Đổi avatar làm bản chiếu và cache Bảng tin cập nhật mà không phát sinh N+1 tới Account.
Tranh chấp tồn kho	Hai người mua đồng thời không thể bán vượt một đơn vị còn lại.
Phân quyền RAG	Người dùng không truy xuất được đoạn hội thoại riêng ngoài tư cách thành viên.
Phân quyền RTC	Người không phải thành viên hoặc thiếu JoinVoice không nhận được token.
Backpressure AI	Độ sâu hàng đợi tăng có kiểm soát; bộ nhớ không tăng vô hạn và tác vụ tiếp tục sau khi runtime phục hồi.
Xoay vòng refresh token	Token cũ bị thu hồi; dùng lại token cũ bị từ chối và họ phiên được đánh dấu theo chính sách.
OTP khôi phục mật khẩu	Không phân biệt email tồn tại; khóa sau số lần sai; thành công thu hồi toàn bộ refresh token.
Tái sử dụng refresh token	Token cũ bị từ chối; toàn bộ họ phiên bị thu hồi và có sự kiện/nhật ký bảo mật.
Xóa tài khoản liên dịch vụ	Tài khoản bị ẩn nhanh, bản chiếu được dọn, công việc theo dõi đủ xác nhận và purge chạy lặp an toàn.
Báo cáo và điều hành	Người dùng không đọc được hàng đợi; báo cáo trùng bị hạn chế; hành động chỉ áp dụng bởi người có quyền và có audit.
Phát lại sự kiện	Dùng consumer group riêng; không tạo email/thông báo/thanh toán lặp ngoài ý muốn; số liệu sau phát lại đúng.

19. Thiết kế triển khai

Môi trường cơ sở sử dụng hạ tầng một nút nhưng vẫn giữ nguyên ranh giới dịch vụ và cấu hình triển khai. Mô hình nhiều nút được xem là hướng phát triển. Việc công khai hệ thống ra Internet chỉ thực hiện khi có phương án mạng và bảo mật phù hợp.



Hình 16 - Sơ đồ triển khai

- Caddy kết thúc kết nối HTTPS và phục vụ hoặc định tuyến Angular/YARP theo cấu hình.
- Một máy chủ PostgreSQL có thể chứa nhiều cơ sở dữ liệu logic; mỗi dịch vụ dùng tài khoản và tên cơ sở dữ liệu riêng.
- Kafka chạy một broker trong cấu hình cơ sở; cơ chế nhân bản thuộc hướng phát triển.
- LiveKit chạy một nút; triển khai coturn khi môi trường Internet hoặc NAT yêu cầu.
- Có thể tắt OpenSearch và cấu hình quan sát đầy đủ để phù hợp tài nguyên VPS.
- Di trú lược đồ chạy bằng tác vụ hoặc lệnh có kiểm soát, không để nhiều tiến trình cùng chạy khi khởi động.

20. Hướng phát triển

Không đưa các hạng mục dưới đây vào phạm vi 6 tháng nếu làm ảnh hưởng đến việc hoàn thiện và ổn định hệ thống.

Bảng 20 - Hướng phát triển

Khu vực	Điều kiện kích hoạt và hướng phát triển
Lưu trữ trò chuyện NoSQL	Khi số liệu ghi, lưu trữ hoặc chỉ mục PostgreSQL vượt ngưỡng, đánh giá Cassandra cho nội dung tin nhắn; siêu dữ liệu hội thoại vẫn dùng quan hệ.
Gợi ý bằng đồ thị	Khi cần duyệt quan hệ nhiều bước hoặc ứng viên từ mạng lưới chung, đánh giá Apache AGE hoặc cơ sở dữ liệu đồ thị.
Phát công khai	Khi cần một nguồn phát cho số lượng lớn người xem, bổ sung SRS/HLS thành mặt phẳng riêng.
Phục vụ AI	Khi yêu cầu thông lượng đồng thời hoặc GPU tăng, đưa vLLM sau cùng lớp trừu tượng nhà cung cấp AI.
LiveKit nhiều nút	Khi số liệu sử dụng hoặc yêu cầu sẵn sàng cao đòi hỏi, triển khai kiến trúc phân tán được LiveKit hỗ trợ và kiểm thử tương thích.
Nhân bản cơ sở dữ liệu	Ưu tiên PostgreSQL replica hoặc HA trước khi cân nhắc phân mảnh.
Phân mảnh	Chỉ thực hiện khi phân vùng logic và nhân bản không còn đáp ứng yêu cầu lưu trữ hoặc ghi đã đo.
Kubernetes	Áp dụng khi nhu cầu điều phối, tự phục hồi hoặc mở rộng ngang đủ lớn để bù cho độ phức tạp.
Kiểm duyệt nội dung bằng AI	Gắn cờ nội dung đáng ngờ và chuyển vào hàng đợi điều hành; không tự động xóa trong thiết kế ban đầu.
Công khai Internet	Dùng reverse proxy và TLS cho HTTP/WebSocket; LiveKit/coturn cần địa chỉ công khai, cổng UDP và cấu hình NAT phù hợp.

21. Thuật ngữ

Các thuật ngữ và chữ viết tắt được sử dụng trong tài liệu.

Bảng 21 - Thuật ngữ

Thuật ngữ	Định nghĩa
JWT	Token chứa các claim được ký số, dùng cho xác thực và phân quyền truy cập.
OTP	Mã sử dụng một lần, có TTL ngắn, dùng trong luồng khôi phục mật khẩu.
Xoay vòng refresh token	Cấp refresh token mới ở mỗi lần sử dụng và thu hồi token cũ để giảm rủi ro bị đánh cắp.
Outbox Pattern	Lưu sự kiện trong cùng giao dịch với dữ liệu nghiệp vụ; tiến trình nền đọc Outbox và phát lên Kafka, bảo đảm phát ít nhất một lần.
Inbox Pattern	Lưu EventId đã nhận trong cùng giao dịch xử lý để ngăn tác dụng phụ lặp khi sự kiện được giao nhiều lần.
DLQ	Hàng đợi chứa bản tin không xử lý được sau số lần thử lại cho phép, chờ điều tra hoặc phát lại.
Bộ nhận sự kiện xử lý lặp an toàn	Bộ nhận sự kiện xử lý cùng một sự kiện nhiều lần mà không tạo dữ liệu hoặc tác dụng phụ trùng.
Nhất quán cuối	Dữ liệu giữa các dịch vụ có thể tạm thời khác nhau nhưng hội tụ khi sự kiện được xử lý xong.
CQRS	Tách mô hình ghi và mô hình đọc; Bảng tin sử dụng bản chiếu để tối ưu truy vấn.
SFU	Máy chủ chuyển tiếp có chọn lọc các luồng phương tiện giữa nhiều máy khách; LiveKit dùng mô hình này.
STUN/TURN/ICE	Nhóm giao thức giúp thiết lập kết nối WebRTC trực tiếp hoặc qua relay khi bị NAT/tường lửa chặn.
RAG	Cơ chế tạo câu trả lời từ dữ liệu được truy xuất và cấp quyền thay vì chỉ dựa vào kiến thức của mô hình.
Embedding	Vector số thực biểu diễn ngữ nghĩa, dùng cho tìm kiếm và xếp hạng tương đồng.
pgvector	Phần mở rộng PostgreSQL để lưu và truy vấn vector embedding.
URL ký trước	URL có chữ ký và thời hạn, cho phép truy cập tạm thời tới kho đối tượng mà không công khai bucket.
Saga đơn giản hóa	Phối hợp nhiều bước có trạng thái và hành động bù trừ khi một bước thất bại.
WAL	Nhật ký ghi trước của PostgreSQL, hỗ trợ độ bền và phục hồi dữ liệu.
TTL	Khoảng thời gian một khóa, token hoặc dữ liệu còn hiệu lực trước khi hết hạn.
p95	Giá trị mà 95% số lần đo nhỏ hơn hoặc bằng; thường dùng cho độ trễ.
HA	Khả năng tiếp tục phục vụ khi một thành phần gặp sự cố, thường đạt được bằng nhân bản hoặc nhiều nút.
RED metrics	Ba nhóm chỉ số cho dịch vụ: tần suất, lỗi và thời gian xử lý.
Correlation ID / Trace ID	Mã dùng để liên kết yêu cầu, nhật ký và trace xuyên nhiều dịch vụ.
Backpressure	Cơ chế giới hạn hoặc làm chậm đầu vào khi hệ thống xử lý không kịp, tránh tăng bộ nhớ vô hạn.
Problem Details	Định dạng lỗi HTTP chuẩn có type, title, status, detail, instance, traceId và lỗi kiểm tra dữ liệu.
RPO	Recovery Point Objective - lượng dữ liệu tối đa có thể mất, tính từ thời điểm sự cố về bản sao gần nhất.
RTO	Recovery Time Objective - thời gian tối đa để khôi phục dịch vụ đến mức chấp nhận.
SBOM	Software Bill of Materials - danh sách thành phần và phiên bản phần mềm dùng trong bản phát hành.
ADR	Architecture Decision Record - bản ghi ngắn về quyết định kiến trúc, lý do, phương án thay thế và hệ quả.
ETag/If-Match	Cấp header HTTP dùng để kiểm soát cập nhật lạc quan; yêu cầu chỉ thành công khi phiên bản máy khách còn đúng.

22. Thiết kế sẵn sàng triển khai

Phần này khóa các quy ước hạ tầng dùng chung để các dịch vụ được triển khai nhất quán ngay từ đầu. Các giá trị thời hạn có thể đưa vào cấu hình, nhưng tên hợp đồng và nguyên tắc xử lý không được thay đổi âm thầm.

22.1 Cấu trúc mã nguồn và trách nhiệm

Bảng 22 - Cấu trúc mã nguồn và trách nhiệm

Thư mục	Nội dung	Quy tắc
src/Gateway	YARP, xác thực biên, định tuyến, CORS và giới hạn tần suất chung.	Không chứa quy tắc nghiệp vụ của dịch vụ.
src/Services/{Service}.Api	Điểm cuối, DTO HTTP, middleware và điểm khởi tạo phụ thuộc.	Chỉ gọi tầng Ứng dụng; không truy cập cơ sở dữ liệu trực tiếp.
src/Services/{Service}.Application	Ca sử dụng, lệnh/truy vấn, kiểm tra dữ liệu và ranh giới giao dịch.	Phụ thuộc tầng Miền; gọi giao diện hạ tầng.
src/Services/{Service}.Domain	Tập hợp nghiệp vụ, thực thể, đối tượng giá trị, quy tắc và sự kiện miền.	Không phụ thuộc khung phát triển, cơ sở dữ liệu hoặc Kafka.
src/Services/{Service}.Infrastructure	EF Core, kho dữ liệu, Kafka, SMTP, SeaweedFS, Valkey và bộ chuyển đổi bên ngoài.	Triển khai giao diện của tầng Ứng dụng/Miền.
src/BuildingBlocks	Problem Details, liên kết truy vết, Outbox/Inbox, vô sự kiện và tiện ích kiểm thử.	Chỉ chứa thành phần dùng chung ổn định; không chứa entity nghiệp vụ.
tests	Kiểm thử đơn vị, tích hợp, hợp đồng và xuyên suốt.	Tên ca kiểm thử bám mã chức năng ACC/SOC/CHT/... trong mục 13.
deploy	Docker Compose, Caddy, di trú lược đồ, bảng điều khiển và cấu hình môi trường.	Không lưu bí mật thật trong kho mã.

22.2 Outbox, Inbox và xử lý lặp an toàn

Mỗi thao tác phát sự kiện phải ghi dữ liệu nghiệp vụ và outbox_message trong cùng giao dịch. Tiến trình nền chỉ đánh dấu published_at sau khi Kafka xác nhận. Mỗi bộ nhận sự kiện ghi inbox_message theo cặp consumer_name và event_id trong cùng giao dịch với tác dụng phụ; khóa duy nhất ngăn xử lý trùng. Tác vụ phát lại DLQ phải giữ nguyên eventId và tạo correlationId mới cho lần vận hành phát lại.



Hình 17 - Luồng xử lý Outbox/Inbox

Bảng 23 - Các bảng hạ tầng dùng chung

Bảng	Trường chính	Quy tắc
outbox_message	id, aggregate_type, aggregate_id, event_type, event_version, payload_json, correlation_id, occurred_at, published_at, retry_count, last_error	PK(id); index(published_at, occurred_at); nội dung sự kiện bất biến sau khi commit; thử lại có giãn cách.
inbox_message	consumer_name, event_id, event_type, received_at, processed_at, status, last_error	PK(consumer_name, event_id); ghi cùng giao dịch với tác dụng phụ; lỗi vĩnh viễn chuyển DLQ.
idempotency_request	scope, idempotency_key, request_hash, response_code, response_body, created_at, expires_at	PK(scope, idempotency_key); cùng khóa nhưng request_hash khác trả 409; TTL mặc định 24 giờ.

22.3 Quy ước API, token và thời gian

Bảng 24 - Quy ước API, token và thời gian

Quy ước	Giá trị cơ sở	Ghi chú
Phiên bản API	/api/v1	Thay đổi phá vỡ hợp đồng phải dùng phiên bản mới.
Định dạng lỗi	Problem Details + traceId + errors	Không trả dấu vết ngăn xếp hoặc thông tin nội bộ cho máy khách.
Phân trang	Con trỏ Base64URL, mặc định 20, tối đa 50	Con trỏ chứa khóa sắp xếp ổn định; máy khách không tự tạo.
Xử lý đồng thời	ETag và If-Match	PATCH/DELETE trên thực thể có version trả ETag; giá trị cũ trả 412.
Idempotency-Key	Bắt buộc cho tạo đơn/thanh toán; khuyến nghị cho thao tác tạo có tác dụng phụ	Lưu 24 giờ; cùng khóa nhưng request_hash khác trả 409.
Thời gian	UTC, ISO 8601	DB lưu timestamptz; chỉ giao diện chuyển múi giờ.
Access token	15 phút	JWT sống ngắn; kiểm tra issuer, audience, exp, nbf, chữ ký và token_version.
Refresh token	30 ngày	Chỉ lưu hash; xoay vòng một lần; thu hồi họ phiên khi phát hiện tái sử dụng.
OTP khôi phục	10 phút, tối đa 5 lần thử	OTP mới vô hiệu OTP cũ; giới hạn theo tài khoản và IP.
Token LiveKit	5 phút	Giới hạn room, participant identity và quyền publish/subscribe.
Correlation	Nhận hoặc sinh X-Correlation-ID	Truyền qua HTTP, vô sự kiện Kafka và nhật ký có cấu trúc.
Kích thước yêu cầu	JSON <= 1 MB; sự kiện <= 256 KB	Nhị phân đi thẳng object storage; Kafka chỉ chứa siêu dữ liệu và tham chiếu.

22.4 Cổng chất lượng CI/CD

Bảng 25 - Cổng chất lượng CI/CD

Cổng	Kiểm tra bắt buộc	Điều kiện đạt
Biên dịch	dotnet restore/build và biên dịch giao diện	Không cảnh báo được nâng thành lỗi; khóa phiên bản phụ thuộc.
Kiểm thử đơn vị	Quy tắc miền và kiểm tra dữ liệu cốt lõi	Toàn bộ kiểm thử đạt; không bỏ qua ca lỗi mà không có lý do.
Kiểm thử tích hợp	PostgreSQL/Kafka/Valkey/SeaweedFS bằng môi trường container thử nghiệm	Di trú lược đồ chạy sạch; luồng Outbox/Inbox và giao dịch đạt.
Kiểm thử kiến trúc	Ranh giới phụ thuộc, cấm truy vấn chéo DB và cấm tầng API truy cập DbContext trực tiếp	Các luật kiến trúc chạy tự động và toàn bộ đạt.
Kiểm thử hợp đồng	OpenAPI và schema sự kiện v1	Không có thay đổi phá vỡ chưa tăng phiên bản.
Kiểm tra di trú lược đồ	Nâng cấp từ phiên bản trước và tạo cơ sở dữ liệu mới	Cả hai đường chạy thành công; không để nhiều bản chạy di trú lược đồ đồng thời.
Quét bảo mật	Quét phụ thuộc, bí mật và ảnh container	Không còn bí mật thật hoặc lỗ hổng mức nghiêm trọng chưa có ngoại lệ.
SBOM và nguồn cung ứng	Sinh SBOM, khóa phiên bản gói và quét giấy phép/phụ thuộc	Không có gói không rõ nguồn gốc hoặc lỗ hổng nghiêm trọng chưa xử lý.
Đóng gói và triển khai	Tạo ảnh container theo commit, kiểm tra sức khỏe và kiểm thử nhanh	Chỉ triển khai khi các cổng trước đạt; có phương án quay lui.

22.5 Kế hoạch triển khai hai tuần đầu

Bảng 26 - Kế hoạch triển khai hai tuần đầu

Ngày	Công việc	Kết quả kiểm chứng
1-2	Tạo solution, cấu trúc dịch vụ, BuildingBlocks, quy tắc định dạng và chuỗi biên dịch/kiểm thử.	Kho mã biên dịch; CI chạy tự động trên nhánh hợp nhất.
3-4	Docker Compose cho PostgreSQL, Kafka, Valkey, SeaweedFS; kiểm tra sức khỏe và cấu hình môi trường.	Hạ tầng khởi động bằng một lệnh; volume và mạng nội bộ hoạt động.
5-7	ACC-01 đến ACC-04: đăng ký, đăng nhập, xoay vòng token, đăng xuất; di trú lược đồ Account.	API và kiểm thử tích hợp chạy xuyên suốt; không lưu token thô.
8-9	BuildingBlocks Outbox/Inbox, vô sự kiện và tiến trình phát Kafka; bộ nhận sự kiện mẫu.	UserRegistered được phát lại an toàn; EventId trùng không tạo dữ liệu trùng.
10-11	Problem Details, correlationId, giới hạn tần suất, nhật ký có cấu trúc, OpenTelemetry và OpenAPI.	Lỗi API có cùng định dạng; trace đi qua Gateway và Account.
12-14	Kiểm thử tích hợp, k6 cơ sở, bảng điều khiển tối thiểu, kiểm tra di trú lược đồ và cập nhật tài liệu.	Đạt NFR cơ sở của Account; có số liệu và bằng chứng trước khi sang Mạng xã hội.

23. Phạm vi phát hành và cổng chuyển giai đoạn

Mục tiêu của phân lớp ưu tiên là bảo vệ chất lượng của hệ thống cốt lõi. P2 vẫn thuộc hướng triển khai mong muốn, nhưng không được phép làm chậm kiểm thử, bảo mật, sao lưu hoặc hoàn thiện P0/P1.

23.1 Mức ưu tiên P0/P1/P2

Bảng 27 - Mức ưu tiên và tiêu chí hoàn thành

Mức	Mục đích	Phạm vi	Điều kiện hoàn thành
P0	Nền tảng nghiệm thu bắt buộc	Tài khoản cốt lõi; mạng xã hội; bản chiếu/đọc bảng tin; trò chuyện; Outbox/Inbox; phân quyền; quan sát; sao lưu/khôi phục; CI/CD.	Mọi luồng chính và kịch bản lỗi đạt; không còn lỗi Critical/High; dừng môi trường và phục hồi bằng quy trình tự động.
P1	Hoàn thiện sản phẩm	OTP/OAuth; xóa tài khoản; cộng đồng/RTC; phương tiện; bài viết video/chia sẻ; báo cáo và điều hành thủ công.	Chỉ bắt đầu sau P0; chức năng có kiểm thử tích hợp, quyền tài nguyên, metric và quy trình suy giảm.
P2	Mở rộng có điều kiện	Thương mại; AI/tìm kiếm; gợi ý nâng cao; OpenSearch tùy chọn.	Chỉ bắt đầu khi P0/P1 không còn lỗi nghiêm trọng; được phép giảm phạm vi trước tiên khi chậm tiến độ.
Tương lai	Không thuộc cam kết	HA nhiều nút, Kubernetes, sharding, graph DB, phát công khai quy mô lớn, cổng thanh toán thật, kiểm duyệt tự động.	Chỉ triển khai khi có số liệu hoặc yêu cầu vận hành đủ rõ để biện minh độ phức tạp.

23.2 Cổng chuyển giai đoạn

Bảng 28 - Cổng chuyển giai đoạn

Cổng	Thời điểm	Điều kiện	Bằng chứng
G0 - Kiến trúc	Trước khi phát triển miền	Ranh giới dịch vụ, ownership, schema, API/event và quy ước lỗi đã được khóa.	ADR, sơ đồ, migration rõ ràng, kiểm thử kiến trúc.
G1 - P0	Trước khi mở rộng sản phẩm	Luồng tài khoản -> bài viết -> Kafka -> bảng tin và gửi tin nhắn chạy xuyên suốt; lỗi broker/DB được xử lý đúng.	Trace, test report, dashboard, DLQ/outbox evidence.
G2 - P1	Trước khi bắt đầu P2	Cộng đồng, phương tiện, xóa tài khoản và điều hành đạt quyền, bảo mật, retry và khôi phục.	Integration tests, threat tests, restore drill.
G3 - P2	Trước khi đóng phạm vi chức năng	Mỗi chức năng mở rộng đạt NFR riêng và có đường suy giảm không làm hỏng P0/P1.	Load test, fallback test, cost/resource metrics.
G4 - Phát hành	Trước khi bàn giao	Không lỗi nghiêm trọng; OpenAPI/AsyncAPI đồng bộ; backup/restore, rollback và demo được diễn tập.	Biên bản nghiệm thu, SBOM, runbook, bản phát hành theo commit.

24. Ma trận truy vết triển khai

Mọi chức năng phải truy ngược được đến hợp đồng vào, dữ liệu, sự kiện, kiểm soát và ca kiểm thử. Tiền tố /api/v1 được rút gọn trong bảng để tiết kiệm không gian.

24.1 Tài khoản

Bảng 29 - Ma trận truy vết - Tài khoản

Mã	Hợp đồng vào	Dữ liệu chính	Sự kiện / thời gian thực	Kiểm soát bắt buộc	Kiểm thử tối thiểu	Ưu tiên
ACC-01	POST /auth/register	account, profile, outbox	UserRegistered	Email/username duy nhất; bấm mật khẩu; rate limit	Đăng ký thành công, trùng, dữ liệu sai, Outbox	P0
ACC-02	POST /auth/login	refresh_token	Không bắt buộc	Rate limit; tài khoản active; không lộ email tồn tại	Sai mật khẩu, khóa tạm, token claims	P0
ACC-03	POST /auth/refresh	refresh_token family	Audit tùy chọn	Xoay một lần; phát hiện tái sử dụng; giao dịch	Token cũ, token hết hạn, race refresh	P0
ACC-04	POST /auth/logout	refresh_token	Không bắt buộc	Đúng chủ sở hữu; lặp an toàn	Đăng xuất lặp; token đã thu hồi	P0
ACC-05	GET/PATCH /users	profile	UserProfileUpdated	Quyền riêng tư; If-Match	Ấn hồ sơ; cập nhật stale trả 412	P0
ACC-06	PATCH /users/me/avatar	profile	UserAvatarUpdated	MediaReady; quyền sử dụng; If-Match	Media chưa sẵn sàng; ảnh không thuộc quyền	P1
ACC-07	PATCH /users/me/settings	account_setting	Sự kiện khi cần	Chỉ self/admin; whitelist	Enum sai; mass assignment	P0
ACC-08	POST /auth/forgot-password	password_reset_token	PasswordResetRequested	Phản hồi chung; OTP bấm; rate limit	Email tồn tại/không tồn tại giống nhau; SMTP lỗi	P1
ACC-09	POST /auth/reset-password	account, reset token, refresh token	UserPasswordReset	OTP một lần; số lần thử; password policy	OTP sai/hết hạn; thu hồi mọi phiên	P1
ACC-10	POST /auth/google	account_oauth, account, profile	UserRegistered nếu mới	issuer/audience/signature; không tự gộp tài khoản	Token Google sai; email trùng	P1
ACC-11	DELETE /users/me; cancel	account_deletion_request	UserDeletionRequested/Cancelled/Completed	Xác thực lại; grace period; audit	Ấn nhanh; hủy; purge lặp; thiếu ack	P1

24.2 Mạng xã hội

Bảng 30 - Ma trận truy vết - Mạng xã hội

Mã	Hợp đồng vào	Dữ liệu chính	Sự kiện / thời gian thực	Kiểm soát bắt buộc	Kiểm thử tối thiểu	Ưu tiên
SOC-01	POST/DELETE /users/{id}/follow	follow	UserFollowed/Unfollowed	Cấm self; chặn hai chiều; unique	Theo dõi lặp; blocked	P0
SOC-02	POST/DELETE /users/{id}/block	block, follow	UserBlocked/Unblocked	Cấm self; dọn follow; lặp an toàn	Block race; visibility sau block	P0

Mã	Hợp đồng vào	Dữ liệu chính	Sự kiện / thời gian thực	Kiểm soát bắt buộc	Kiểm thử tối thiểu	Ưu tiên
SOC-03	POST /posts	post, media_ref, outbox	PostCreated	Nội dung; quyền media; Idempotency-Key	Create lặp; media sai; Kafka down	P0
SOC-04	PATCH /posts/{id}	post	PostUpdated	Owner; If-Match; sanitize	Stale trả 412; không phải owner	P0
SOC-05	DELETE /posts/{id}	post	PostDeleted	Owner/moderator; soft delete; lặp an toàn	Xóa lặp; projection được dọn	P0
SOC-06	GET /posts; /users/{id}/posts	post	Không	Visibility + block; cursor ổn định	Ẩn nội dung; cursor không trùng/bỏ	P0
SOC-07	POST /posts/{id}/comments	comment	CommentCreated	Parent cùng bài; độ sâu; rate limit	Parent sai; private/blocked	P0
SOC-08	PUT/DELETE reaction	reaction	ReactionAdded/Removed	Unique; visibility; upsert	Race cùng user; bộ đếm đúng	P0
SOC-09	POST /posts type=video	post, media_ref	PostCreated, PostUpdated	Media pipeline; owner-only khi processing	Ready/Failed; không vào bảng tin sớm	P1
SOC-10	POST /posts/{id}/share	post_share	PostShared	Visibility; link an toàn	Nền tảng lạ; copy-link fallback	P1

24.3 Cộng đồng và RTC

Bảng 31 - Ma trận truy vết - Cộng đồng và RTC

Mã	Hợp đồng vào	Dữ liệu chính	Sự kiện / thời gian thực	Kiểm soát bắt buộc	Kiểm thử tối thiểu	Ưu tiên
COM-01	POST/PATCH /communities	community, member, role, channel	CommunityCreated/Updated	Owner; If-Match; transaction	Tạo mặc định; slug trùng; stale	P1
COM-02	invite/join/leave	invite, community_member	MemberJoined/LeftCommunity	Hết hạn; max uses; ban; transfer owner	Invite hết; join lặp; owner leave	P1
COM-03	roles/member roles	role, member_role	RoleUpdated/PermissionUpdated	Không leo quyền; owner protected	Escalation bị chặn; cache invalidation	P1
COM-04	POST /communities/{id}/channels	channel, outbox	ChannelCreated	ManageChannel; type-specific	Projection Trò chuyện eventual	P1
COM-05	POST member moderation	community_member	MemberModerated	Role hierarchy; audit	Mute/kick/ban; target cao hơn	P1
RTC-01	POST /channels/{id}/rtc-token	room metadata tùy chọn	Lifecycle tùy chọn	Identity từ claims; quyền Join/Speak/Screen	Không member; LiveKit down	P1
RTC-02	LiveKit SDK	Không lưu media	Lifecycle	Token scoped; track permissions	RTC lỗi không hỏng text chat	P1
RTC-03	LiveKit screen track	Session metadata tùy chọn	StreamStarted/Ended tùy chọn	ScreenShare permission; giới hạn tài nguyên	Mạng yếu; giới hạn room	P1

24.4 Trò chuyện và thời gian thực

Bảng 32 - Ma trận truy vết - Trò chuyện và thời gian thực

Mã	Hợp đồng vào	Dữ liệu chính	Sự kiện / thời gian thực	Kiểm soát bắt buộc	Kiểm thử tối thiểu	Ưu tiên
CHT-01	POST /conversations	conversation, members	ConversationCreated tùy chọn	Block policy; participant limits	DM trùng; member sai	P0
CHT-02	SignalR/POST messages	message, outbox	MessageSent + MessageCreated	Membership; clientMessageId; rate limit	Gửi lặp; DB fail không ghost	P0
CHT-03	PATCH/DELETE /messages/{id}	message	MessageEdited/Deleted	Sender/moderator; If-Match	Stale 412; soft delete	P0
CHT-04	PUT/DELETE message reaction	message_reaction	SignalR ReactionChanged	Membership; unique; rate limit	Thêm/xóa lặp	P0
CHT-05	SignalR Typing	Valkey TTL tùy chọn	TypingChanged	Membership; throttle; ephemeral	Drop khi offline; auto-expire	P0
CHT-06	SignalR connect/disconnect	Valkey presence	PresenceChanged	Nhiều thiết bị; privacy	Disconnect bất thường; TTL	P0
CHT-07	POST read / MarkRead	conversation_member	ReadUpdated	Cursor chỉ tăng; membership	Không lùi; message sai	P0
CHT-08	GET/PATCH notifications	notification, inbox	NotificationCreated/Read	Recipient filter; EventId unique	Event lặp; SignalR offline	P0
CHT-09	POST call-invites	call invite metadata	CallInvite/CallStateChanged	Membership/block/privacy; timeout	Reject/timeout không rõ resource	P1

24.5 Bảng tin và gợi ý

Bảng 33 - Ma trận truy vết - Bảng tin và gợi ý

Mã	Hợp đồng vào	Dữ liệu chính	Sự kiện / thời gian thực	Kiểm soát bắt buộc	Kiểm thử tối thiểu	Ưu tiên
FED-01	Kafka consumer	feed_entry, summaries, inbox	Nhận Post/Follow/Profile	Idempotency; privacy/block	Duplicate; rebuild; lag	P0
FED-02	GET /feed	feed_db, Valkey	Không	Cursor ổn định; hard filter	Cache miss; không lộ private	P0
FED-03	Kafka consumer	summaries, cache	Nhận update/delete	Event version; invalidation	Out-of-order; avatar update	P0
FED-04	GET /feed nội bộ	recommendation cache	Không	Privacy trước trả; diversity	Cold start; AI down fallback	P2
FED-05	Background worker	interest embedding	EmbeddingGenerated tùy chọn	Loại dữ liệu không còn quyền; decay	Backpressure; retry	P2

24.6 Phương tiện

Bảng 34 - Ma trận truy vết - Phương tiện

Mã	Hợp đồng vào	Dữ liệu chính	Sự kiện / thời gian thực	Kiểm soát bắt buộc	Kiểm thử tối thiểu	Ưu tiên
MED-01	POST /media/uploads	upload_session	Không	MIME/size/purpose; key server sinh	Sai loại/kích thước; rate limit	P1
MED-02	PUT URL ký trước	Object storage	Không	Signature, TTL, key constraints	Hết hạn; backend không nhận bytes	P1
MED-03	POST complete	session, media_asset, outbox	MediaUploaded	HEAD/stat; owner; Idempotency-Key	Claim giả; complete lặp	P1
MED-04	Worker	media_asset	MediaReady/Failed	Magic bytes; bounded concurrency	Poison media; retry/DLQ	P1
MED-05	DELETE /media/{id}; cleanup	media_asset, object	MediaDeleted	Reference policy; orphan TTL	Delete object fail; retry	P1
MED-06	Media flow + Chat ref	media_asset + message ref	MediaReady; TranscriptReady tùy chọn	Chat membership; duration	Transcription fail không xóa audio	P1

24.7 Thương mại

Bảng 35 - Ma trận truy vết - Thương mại

Mã	Hợp đồng vào	Dữ liệu chính	Sự kiện / thời gian thực	Kiểm soát bắt buộc	Kiểm thử tối thiểu	Ưu tiên
MKT-01	POST/PATCH /listings	listing, media_ref	ListingCreated/Updated	Seller owner; price; If-Match	Stale 412; media sai	P2
MKT-02	GET /listings	listing	Không	Active filter; cursor	Search down -> DB fallback	P2
MKT-03	PUT inventory; checkout	inventory	Reserved/Released	Atomic update/row lock; non-negative	Hai buyer không oversell	P2
MKT-04	POST /orders	order, items, inventory	OrderCreated	Idempotency-Key; price snapshot	Stock fail không ghost order	P2
MKT-05	POST /orders/{id}/pay	payment, order	PaymentSucceeded/Failed	Idempotency-Key; amount match	Retry trả cùng kết quả	P2
MKT-06	State transition/cancel	order, status_history	OrderStatusChanged	Transition whitelist; compensation	Invalid transition; release once	P2
MKT-07	Listing media refs	listing_media_ref	Không	MediaReady; ownership/purpose	Shared media không bị xóa sớm	P2

24.8 AI và tìm kiếm

Bảng 36 - Ma trận truy vết - AI và tìm kiếm

Mã	Hợp đồng vào	Dữ liệu chính	Sự kiện / thời gian thực	Kiểm soát bắt buộc	Kiểm thử tối thiểu	Ưu tiên
AI-01	Worker/event	ai_embedding, ai_job	EmbeddingGenerated	Authorized text; model version; max input	Retry/DLQ; upsert idempotent	P2
AI-02	GET /search/semantic	pgvector	Không	Authorization trước exposure	AI down -> FTS; private filter	P2
AI-03	POST /ai/ask	chunks, request metadata	AiToken/AiCompleted	Scoped retrieval; prompt limit; rate limit	Prompt injection; AI down	P2
AI-04	POST /ai/summaries	summary tùy chọn	AiSummaryReady	Trò chuyện cấp nội dung; không query chat_db	Large chunk; deleted messages	P2
AI-05	POST transcriptions/worker	ai_job, transcript	TranscriptReady	Authorized object; duration; concurrency	Fail giữ audio; retry/DLQ	P2
AI-06	Kafka consumer	OpenSearch projection	Không	Chỉ searchable fields; checkpoint	Disabled -> PostgreSQL	P2

24.9 Báo cáo và điều hành nội dung

Bảng 37 - Ma trận truy vết - Báo cáo và điều hành nội dung

Mã	Hợp đồng vào	Dữ liệu chính	Sự kiện / thời gian thực	Kiểm soát bắt buộc	Kiểm thử tối thiểu	Ưu tiên
MOD-01	POST /reports	content_report, evidence	ContentReported	Target visible; rate limit; dedupe	Target sai; report spam; snapshot tối thiểu	P1
MOD-02	GET /moderation/reports	content_report	Không	Moderator role; field masking	Người thường bị 403; cursor/filter	P1
MOD-03	POST /reports/{id}/actions	moderation_action, outbox	ModerationActionRequested	Role/hierarchy; reason; append-only	Action lặp; target service reject	P1
MOD-04	POST /reports/{id}/close	content_report	Completed/Rejected	If-Match; audit; evidence retention	Close stale; reopen policy	P1

25. Hợp đồng API và sự kiện mẫu

Các mẫu dưới đây là hợp đồng tham chiếu. Tên trường JSON dùng camelCase; định danh dùng UUIDv7; thời gian dùng UTC ISO 8601. Mã nguồn có thể sinh OpenAPI từ implementation nhưng không được thay đổi semantics đã khóa.

25.1 Quy ước HTTP và mã trạng thái

Bảng 38 - Quy ước HTTP và mã trạng thái

Mã	Ý nghĩa	Quy tắc
200	Đọc/cập nhật thành công	Trả DTO và ETag khi tài nguyên có version.
201	Tạo thành công	Trả Location, DTO và ETag nếu có.
202	Đã nhận tác vụ bất đồng bộ	Trả requestId/jobId và điểm cuối kiểm tra trạng thái.
204	Xóa/đánh dấu thành công không cần body	Dùng cho thao tác lặp an toàn khi phù hợp.
400	Yêu cầu không đọc được	JSON sai, header thiếu định dạng hoặc con trỏ không hợp lệ.
401	Chưa xác thực hoặc token không hợp lệ	Không tiết lộ chi tiết chữ ký/token.
403	Đã xác thực nhưng không có quyền	Áp dụng tại dịch vụ sở hữu tài nguyên.
404	Không tồn tại hoặc cố ý ẩn	Có thể dùng thay 403 để tránh lộ tài nguyên riêng tư.
409	Xung đột nghiệp vụ/idempotency	Ví dụ cùng Idempotency-Key nhưng nội dung khác.
412	If-Match không còn đúng	Máy khách phải đọc lại tài nguyên trước khi cập nhật.
422	Dữ liệu hợp lệ cú pháp nhưng sai quy tắc	Trả errors theo từng trường hoặc quy tắc.
429	Vượt giới hạn tần suất	Trả Retry-After khi xác định được.
503	Phụ thuộc tạm thời không sẵn sàng	Chỉ trả khi không có đường suy giảm an toàn.

25.2 Mẫu tạo bài viết

Yêu cầu:

```
POST /api/v1/posts
Authorization: Bearer <access-token>
Idempotency-Key: 0199b7b5-7f46-7a56-8ad1-6b2e3d30f492
Content-Type: application/json

{
  "content": "Nội dung bài viết",
  "type": "content",
  "visibility": "followers",
  "mediaIds": []
}
```

Phản hồi 201 Created:

Location: /api/v1/posts/0199b7b7-5ba2-7b89-a7bd-6fa909f4d800
ETag: "1"

```
{
  "id": "0199b7b7-5ba2-7b89-a7bd-6fa909f4d800",
  "authorId": "0199b78e-b38a-76e2-a38c-dd1652e24c54",
  "content": "Nội dung bài viết",
  "type": "content",
  "visibility": "followers",
  "version": 1,
  "createdAt": "2026-09-05T10:00:00Z"
}
```

25.3 Mẫu lỗi chuẩn

HTTP/1.1 422 Unprocessable Entity
Content-Type: application/problem+json

```
{
  "type": "https://errors.social.local/validation",
  "title": "Dữ liệu không hợp lệ",
  "status": 422,
  "traceId": "00-4bf92f3577b34da6a3ce929d0e0e4736-00f067aa0ba902b7-01",
  "errors": {
    "content": ["Nội dung không được để trống."],
    "visibility": ["Giá trị không được hỗ trợ."]
  }
}
```

25.4 Cập nhật lạc quan và yêu cầu lặp an toàn

Bảng 39 - Cơ chế xử lý đồng thời và yêu cầu lặp an toàn

Trường hợp	Cách thực hiện	Kết quả bắt buộc
Cập nhật lạc quan	Máy khách gửi If-Match: "3"; DB cập nhật WHERE id = @id AND version = 3; thành công trả ETag: "4".	Không còn đúng trả 412, không ghi đè dữ liệu mới.
Tạo có Idempotency-Key	Lưu scope + key + request_hash + response; retry cùng nội dung trả đúng phản hồi cũ.	Cùng key nhưng nội dung khác trả 409.
Kafka giao lặp	Consumer ghi inbox_message và tác dụng phụ trong cùng giao dịch.	EventId đã xử lý không tạo tác dụng phụ lần hai.
Publish thành công nhưng chưa đánh dấu Outbox	Worker có thể phát lại cùng eventId sau khi khởi động lại.	Đây là hành vi dự kiến của at-least-once; consumer phải an toàn khi lặp.

25.5 Mẫu vỏ sự kiện Kafka

```
{
  "eventId": "0199b7bd-b0aa-7f2e-9d8b-61b7c294ff58",
  "eventType": "PostCreated",
  "eventVersion": 1,
  "occurredAt": "2026-09-05T10:00:00Z",
  "producer": "social-service",
  "correlationId": "0199b7b5-7f46-7a56-8ad1-6b2e3d30f492",
  "aggregateId": "0199b7b7-5ba2-7b89-a7bd-6fa909f4d800",
  "aggregateVersion": 1,
  "payload": {
    "postId": "0199b7b7-5ba2-7b89-a7bd-6fa909f4d800",
    "authorId": "0199b78e-b38a-76e2-a38c-dd1652e24c54",
    "visibility": "followers",
    "type": "content"
  }
}
```

26. Quy ước Kafka và vận hành sự kiện

Topic được nhóm theo miền hoặc aggregate để tránh tạo quá nhiều topic. Số phân vùng là cấu hình cơ sở cho môi trường một broker và phải được điều chỉnh bằng số liệu consumer lag; tăng phân vùng có thể làm thay đổi phân bố khóa nên phải được kiểm thử.

26.1 Danh mục topic cơ sở

Bảng 40 - Danh mục topic Kafka cơ sở

Topic	Khóa	Phân vùng	Lưu giữ	Nhóm sự kiện
account.user.v1	UserId/AccountId	3	7 ngày	Đăng ký, hồ sơ, mật khẩu, xóa tài khoản
social.relationship.v1	ActorId	3	7 ngày	Theo dõi, chặn
social.post.v1	PostId	6	7 ngày	Bài viết, bình luận, tương tác, chia sẻ
social.moderation.v1	ReportId/TargetId	3	30 ngày	Báo cáo và hành động điều hành
community.lifecycle.v1	CommunityId	3	7 ngày	Cộng đồng, thành viên, vai trò, kênh
chat.message.v1	ConversationId	6	7 ngày	Hội thoại và tin nhắn
media.asset.v1	MediaId	3	7 ngày	Tải lên, xử lý, xóa phương tiện
commerce.order.v1	OrderId	3	14 ngày	Đơn hàng, thanh toán và trạng thái
commerce.listing.v1	ListingId	3	7 ngày	Tin đăng và tồn kho
ai.job.v1	EntityId/RequestId	3	7 ngày	Embedding, tóm tắt, transcript

26.2 Chính sách thử lại và DLQ

Bảng 41 - Chính sách thử lại và DLQ

Loại lỗi	Xử lý	Khoảng chờ	Quy tắc
Lỗi tạm thời ngắn	Thử lại cục bộ tối đa 3 lần	200 ms, 500 ms, 1 giây có jitter	Không commit offset trước khi giao dịch thành công.
Lỗi phụ thuộc kéo dài	Chuyển sang topic retry	.retry.1m -> .retry.10m -> .retry.1h	Giữ eventId/correlationId; giới hạn tổng thời gian 24 giờ.
Lỗi dữ liệu/schema vĩnh viễn	Không thử lại vô hạn	Chuyển .dlq ngay hoặc sau số lần hữu hạn	Lưu reason, stack đã làm sạch, consumer, offset và schema version.
Lỗi nghiệp vụ dự kiến	Đánh dấu rejected	Không xem là lỗi hạ tầng	Phát sự kiện kết quả khi luồng cần biết; không gây vòng lặp retry.
Phát lại DLQ	Dùng công cụ quản trị được bảo vệ	Dry-run -> batch nhỏ -> theo dõi metric	Bắt buộc audit; không phát lại trực tiếp vào hệ thống khi chưa sửa nguyên nhân.

26.3 Phiên bản, thứ tự và phát lại

Bảng 42 - Quy tắc phiên bản, thứ tự và phát lại sự kiện

Chủ đề	Quy tắc bắt buộc
Tương thích cùng phiên bản lớn	Chỉ thêm trường tùy chọn; không đổi ý nghĩa, kiểu hoặc xóa trường bắt buộc; consumer phải bỏ qua trường chưa biết.
Thay đổi phá vỡ	Tăng major trong topic/schema; chạy song song producer/consumer trong thời gian chuyển đổi và có kế hoạch kết thúc phiên bản cũ.
Thứ tự	Chỉ cam kết trong một partition; chọn partition key theo aggregate và so sánh aggregateVersion khi có thể nhận sự kiện cũ.
Kích thước	Event <= 256 KB; không chứa tệp, transcript dài hoặc dữ liệu nhảy cảm không cần thiết; dùng object/reference.
Phát lại	Consumer group riêng; bắt đầu từ checkpoint; giới hạn tốc độ; luôn dùng Inbox; tác dụng phụ ngoài như email/thanh toán bị tắt trừ khi bật rõ ràng.
Outbox không chắc chắn	Nếu Kafka đã nhận nhưng worker chết trước khi cập nhật published_at, cùng eventId sẽ được phát lại và consumer phải bỏ qua tác dụng phụ trùng.
Schema registry	Lưu JSON Schema/Protobuf contract trong kho mã; CI kiểm tra tương thích và sinh AsyncAPI. Registry dịch vụ bên ngoài là tùy chọn.

27. Danh tính, phân quyền và mô hình đe dọa

Mỗi dịch vụ tự xác minh token và thực hiện phân quyền trên tài nguyên thuộc quyền sở hữu của mình. Không tin tưởng userId, role hoặc targetId do máy khách gửi khi thông tin tương ứng đã có trong claim hoặc dữ liệu nguồn.

27.1 Claim của access token

Bảng 43 - Claim của access token

Claim	Giá trị	Quy tắc
sub	AccountId	Định danh người dùng duy nhất; bắt buộc.
sid	Session/family id	Liên kết access token với họ refresh token để thu hồi theo phiên.
jti	Token id	Hỗ trợ audit và danh sách thu hồi khẩn cấp khi

Claim	Giá trị	Quy tắc
		cần.
iss	Issuer	Phải đúng nhà phát hành đã cấu hình.
aud	Audience	Phải chứa dịch vụ/cổng API được phép nhận token.
iat/nbf/exp	Thời gian	Kiểm tra UTC và cho phép clock skew tối đa 60 giây.
ver	Token version	Tăng khi đổi mật khẩu, vô hiệu tài khoản hoặc thu hồi toàn cục.
global_role	Vai trò toàn cục tối thiểu	Chỉ dùng cho system_admin/moderator toàn cục; không nhét vai trò cộng đồng vào JWT.

27.2 Xác thực nội bộ và xoay khóa

Bảng 44 - Xác thực nội bộ và xoay khóa

Khu vực	Quyết định	Hệ quả
HTTP nội bộ	JWT dịch vụ sống <= 5 phút, audience theo dịch vụ đích và scope tối thiểu.	Mạng Docker riêng không được xem là cơ chế xác thực.
Kafka	ACL theo principal; producer chỉ ghi topic của mình; consumer group được cấp tối thiểu.	Không dùng cùng một credential cho mọi dịch vụ.
Khóa ký	JWT có kid; duy trì khóa hiện tại và khóa trước trong giai đoạn chồng tối thiểu 24 giờ.	Khóa riêng chỉ ở dịch vụ phát hành/kho bí mật; dịch vụ khác chỉ nhận khóa công khai.
Thu hồi	Đổi password hoặc phát hiện refresh reuse tăng token_version và thu hồi session family.	Access token cũ hết hạn nhanh; điểm cuối nhảy cảm có thể kiểm tra version cache.
Quyền cộng đồng	Lưu projection cục bộ TTL <= 5 phút và cập nhật qua RoleUpdated/PermissionUpdated.	Hành động nhảy cảm xác minh đồng bộ với Cộng đồng khi projection nghi ngờ stale.

27.3 Mô hình đe dọa

Bảng 45 - Mô hình đe dọa và kiểm soát

Đe dọa	Tác động	Kiểm soát
Chiếm refresh token	Phát lại và duy trì phiên trái phép	Chỉ lưu hash, rotation, family, reuse detection, revoke all sessions, audit.
BOLA/IDOR	Đọc/sửa tài nguyên bằng id đoán được	Kiểm tra quyền tại dịch vụ sở hữu, 404 cho tài nguyên ẩn, test theo từng resource.
Giả mạo sự kiện	Ghi dữ liệu dẫn xuất sai hoặc kích hoạt tác dụng phụ	Kafka ACL, principal riêng, schema validation, producer field kiểm chứng, Inbox.
Sự kiện lặp/đảo thứ tự	Tăng bộ đếm, gửi thông báo hoặc ghi đè sai	EventId unique, aggregateVersion, partition key đúng và cập nhật có điều kiện.
XSS/nội dung độc hại	Thực thi mã ở trình duyệt	Sanitize, output encoding, CSP, không cho HTML tùy ý.
SSRF/tệp giả	Worker truy cập mạng nội bộ hoặc xử lý tệp nguy hiểm	Không nhận URL tùy ý; object key server sinh; magic-byte scan; outbound allowlist.
Prompt injection/RAG leakage	Mô hình làm theo nội dung không tin cậy hoặc lộ dữ liệu	Authorization trước retrieval, đánh dấu context là dữ liệu, không cấp công cụ nguy hiểm, giới hạn output/log.
Rò bí mật	Chiếm DB/JWT/SMTP	Secret store, quét bí mật, log masking, rotation, quyền tối thiểu.

Đe dọa	Tác động	Kiểm soát
Lạm dụng tài nguyên	DoS qua login, upload, AI hoặc báo cáo	Rate limit theo user/IP, quota, kích thước tối đa, bounded concurrency và backpressure.
Chuỗi cung ứng	Gói/ảnh container có lỗ hổng	Khóa phiên bản, SBOM, quét dependency/image, base image tối thiểu và cập nhật có kiểm thử.

28. Vòng đời dữ liệu và xóa tài khoản

Thời hạn dưới đây là mặc định của môi trường cơ sở và phải được cấu hình. Khi một báo cáo điều hành, tranh chấp hoặc yêu cầu pháp lý hợp lệ cần giữ lại dữ liệu, hệ thống đặt retention_hold có audit thay vì âm thầm bỏ qua quy trình xóa.

28.1 Phân loại và lưu giữ dữ liệu

Bảng 46 - Phân loại và thời hạn lưu giữ dữ liệu

Mức	Ví dụ	Thời hạn/quy tắc	Kiểm soát
Bí mật	Mật khẩu, OTP, refresh token, khóa ký	Không lưu plaintext; token/OTP chỉ lưu hash; secret theo vòng đời kho bí mật.	Chỉ dịch vụ sở hữu; không ghi log.
Nhạy cảm	Email, IP, nội dung riêng tư, bằng chứng điều hành	PII tài khoản xóa cứng tối đa 45 ngày; bằng chứng 180 ngày sau đóng nếu không hold.	Che trường, mã hóa khi truyền, quyền tối thiểu.
Nghịệp vụ	Bài viết, tin nhắn, đơn hàng, trạng thái	Xóa mềm 30 ngày; đơn hàng/audit giữ theo chính sách dự án; projection xóa sớm.	Dịch vụ sở hữu quyết định; downstream chỉ giữ tối thiểu.
Dẫn xuất	Feed, cache, embedding, RAG chunk	Xóa/invalidate trong 5 phút sau nguồn bị ẩn; có thể dừng lại.	Không xem là nguồn dữ liệu chuẩn.
Vận hành	Log, trace, metric	Log/trace 7 ngày; metric tổng hợp 30 ngày; audit bảo mật 90 ngày.	Không chứa OTP, token, payload nhạy cảm.
Hạ tầng sự kiện	Outbox/Inbox/DLQ	Outbox đã phát 7 ngày; Inbox 14 ngày; DLQ đến khi xử lý nhưng cảnh báo ngay.	Purge theo batch, giữ eventId và metadata audit cần thiết.
Bản sao lưu	PostgreSQL và object storage	7 bản ngày + 4 bản tuần; mã hóa và tách khỏi volume chạy.	Kiểm tra checksum và diễn tập khôi phục.

28.2 ACC-11 - Yêu cầu xóa và khôi phục tài khoản

Bảng 47 - Đặc tả ACC-11

Trường	Đặc tả
Dịch vụ sở hữu	Tài khoản
Tác nhân chính	Người dùng hoặc quản trị viên có lý do được kiểm toán
Điều kiện trước	Đã xác thực; thao tác tự xóa yêu cầu xác thực lại gần đây.
Luồng chính	Tạo account_deletion_request -> đặt account.status=pending_deletion -> thu hồi mọi refresh token -> phát UserDeletionRequested -> các dịch vụ ẩn dữ liệu và xác nhận -> sau 30 ngày tiến trình purge xóa/ẩn danh dữ liệu -> phát UserDeletionCompleted.
Hủy yêu cầu	Trong thời gian ân hạn, người dùng xác thực lại và gọi điểm cuối cancel; dịch vụ phát UserDeletionCancelled và khôi phục các projection có thể khôi phục.
Kiểm tra và phân quyền	Chỉ self/admin; id từ claim; rate limit; audit bắt buộc; không cho hủy sau

Trường	Đặc tả
	khi purge bắt đầu.
Thay đổi dữ liệu	account, refresh_token, account_deletion_request; downstream xóa projection, media không còn tham chiếu và dữ liệu AI dẫn xuất.
Lỗi và trường hợp biên	Yêu cầu lặp trả trạng thái hiện tại; thiếu xác nhận dịch vụ không chặn ẩn tài khoản nhưng chặn completed và phát cảnh báo.

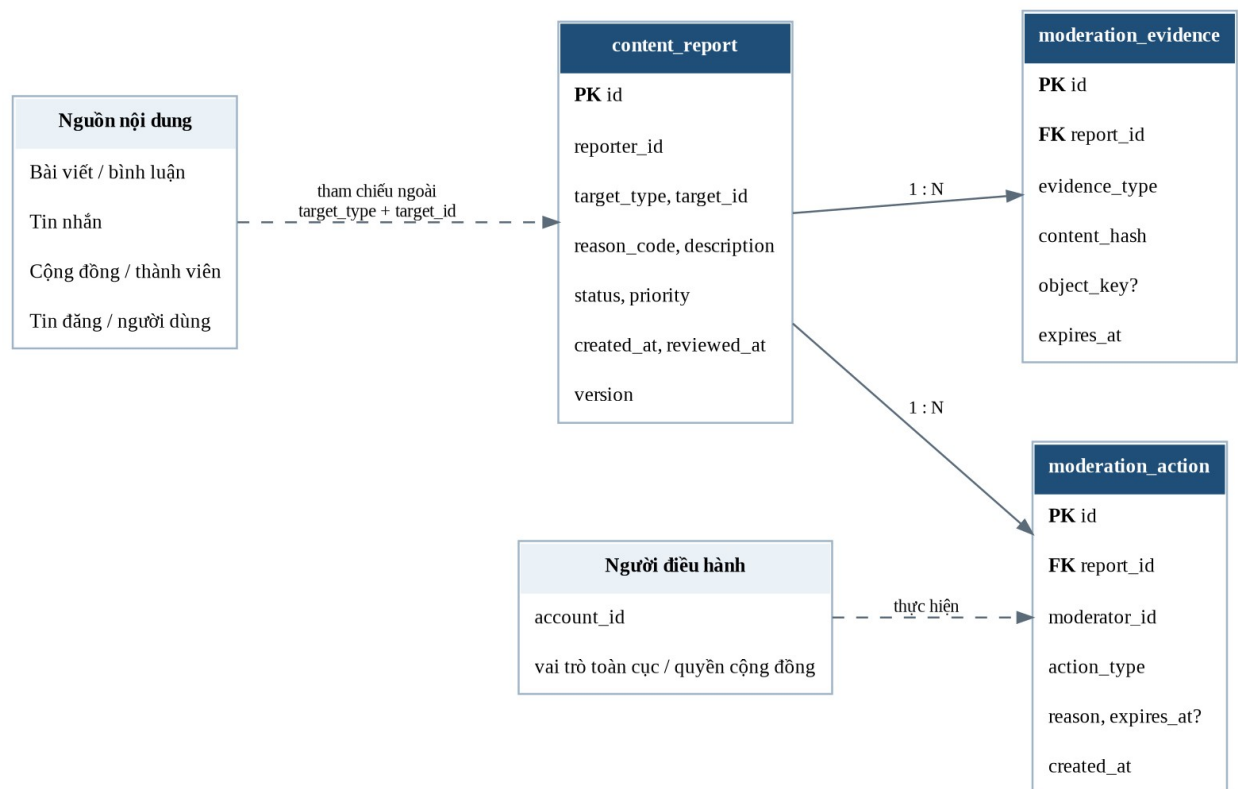
28.3 Lan truyền và đối soát

Bảng 48 - Lan truyền yêu cầu xóa tài khoản

Dịch vụ	Hành động	Quy tắc
Tài khoản	Khóa đăng nhập, thu hồi phiên, ẩn PII	AccountDeletionRequest cập nhật trạng thái và thời hạn.
Mạng xã hội	Ẩn hồ sơ liên quan, xử lý bài viết/bình luận theo chính sách, xóa follow/block	Ack theo AccountId; giữ nội dung đã ẩn danh nếu chính sách cho phép.
Bảng tin	Xóa FeedEntry/UserSummary và cache	Có thể dựng lại; phải hoàn thành trong 5 phút.
Trò chuyện	Ẩn profile projection; giữ tin nhắn theo chính sách nhưng thay tên/PII	Không làm hỏng lịch sử hội thoại của người khác.
Cộng đồng	Vô hiệu membership/role/invite	Chuyển quyền sở hữu cộng đồng trước purge nếu cần.
Phương tiện	Xóa tài sản không còn tham chiếu; giữ bằng chứng có retention_hold	Tác vụ dọn bất đồng bộ, lập an toàn.
Thương mại	Ẩn profile; giữ snapshot đơn hàng tối thiểu	Không xóa dữ liệu cần cho tính toán vẹn đơn hàng.
AI và tìm kiếm	Xóa embedding, chunk, transcript và index dẫn xuất	Không giữ prompt/payload nhạy cảm ngoài thời hạn.
Đối soát	Quét deletion_request quá hạn và trạng thái xác nhận	Retry dịch vụ thiếu, cảnh báo và chỉ completed khi đạt chính sách.

29. Báo cáo vi phạm và điều hành nội dung

Báo cáo thủ công thuộc P1 và không phụ thuộc bộ phân loại AI. Trong baseline, metadata điều hành nằm trong dịch vụ mạng xã hội để tránh thêm một deployable service; mỗi dịch vụ nguồn vẫn sở hữu nội dung thật và tự áp dụng hành động sau khi nhận yêu cầu.



Hình 18 - Mô hình dữ liệu báo cáo và điều hành nội dung

29.1 Dữ liệu và trạng thái

Bảng 49 - Các bảng của khối báo cáo và điều hành

Bảng	Trường chính	Quy tắc
content_report	id, reporter_id, target_type, target_id, reason_code, description, status, priority, assigned_to, version, created_at, reviewed_at	Index(status, priority, created_at); target là tham chiếu ngoài; một báo cáo đang mở tương đương được gộp hoặc từ chối theo policy.
moderation_evidence	id, report_id, evidence_type, content_hash, object_key, captured_at, expires_at, retention_hold	Không sao chép quá mức; object private; chỉ người có quyền điều hành truy cập; xóa theo retention.
moderation_action	id, report_id, moderator_id, action_type, target_type, target_id, reason, expires_at, correlation_id, created_at	Append-only; không sửa/xóa; hành động lặp dùng action id làm idempotency key.

Bảng 50 - Trạng thái và hành động điều hành

Trạng thái	Ý nghĩa	Chuyển hợp lệ
Pending	Mới tạo, chưa phân công	Assign -> InReview; RejectDuplicate -> Rejected
InReview	Đang xác minh bằng chứng và quyền	RequestAction -> ActionPending; Reject -> Rejected
ActionPending	Đã phát yêu cầu đến dịch vụ nguồn	Completed -> Actioned; RejectedByOwner -> InReview
Actioned	Dịch vụ nguồn đã áp dụng hành động	Close -> Closed; Reopen theo quyền đặc biệt
Rejected	Không đủ căn cứ, trùng hoặc không hợp lệ	Close -> Closed

Trạng thái	Ý nghĩa	Chuyển hợp lệ
Closed	Kết thúc xử lý	Không thay đổi; chỉ tạo báo cáo/kháng nghị mới nếu chính sách cho phép

Bảng 51 - Hợp đồng API và sự kiện điều hành

Hợp đồng	Quyền	Sự kiện	Quy tắc
POST /api/v1/reports	Người dùng	ContentReported	Tạo báo cáo; không trả dữ liệu điều hành nội bộ.
GET /api/v1/moderation/reports	Điều hành	Không	Cursor/filter; che PII theo vai trò; audit truy cập.
POST /api/v1/moderation/reports/{id}/actions	Điều hành	ModerationActionRequested	Bắt buộc reason, actionType, If-Match và idempotency action id.
POST /api/v1/moderation/reports/{id}/close	Điều hành	ModerationActionCompleted hoặc Rejected	Chỉ đóng khi không còn action pending; append audit.

MOD-01 - Gửi báo cáo vi phạm

Bảng 52 - Đặc tả MOD-01

Trường	Đặc tả
Dịch vụ sở hữu	Mạng xã hội - khối điều hành
Tác nhân chính	Người dùng
Điều kiện trước	Đã xác thực và có quyền nhìn thấy target tại thời điểm báo cáo.
Luồng chính	Xác minh target qua contract/projection -> kiểm tra giới hạn -> tạo content_report và evidence tối thiểu -> Outbox ContentReported -> trả mã báo cáo.
Kiểm tra và phân quyền	Không tin target owner từ client; reason_code whitelist; giới hạn theo user/IP/target; chống report trùng đang mở.
Lỗi và trường hợp biên	Target không tồn tại/không được thấy trả 404; vượt giới hạn trả 429; retry với Idempotency-Key không tạo bản ghi trùng.

MOD-02 - Duyệt hàng đợi báo cáo

Bảng 53 - Đặc tả MOD-02

Trường	Đặc tả
Dịch vụ sở hữu	Mạng xã hội - khối điều hành
Tác nhân chính	Người điều hành hoặc quản trị viên
Điều kiện trước	Có global_role hoặc quyền điều hành cộng đồng phù hợp.
Luồng chính	Lọc theo status/priority/type -> lấy bằng con trỏ -> kiểm tra phạm vi -> trả dữ liệu đã che trường nhạy cảm -> ghi audit truy cập.
Kiểm tra và phân quyền	Người điều hành cộng đồng chỉ thấy target thuộc cộng đồng mình; không trả object_key bằng chứng nếu chưa có quyền xem.
Lỗi và trường hợp biên	Người dùng thường trả 403; target đã xóa vẫn hiển thị metadata/bằng chứng tối thiểu theo retention.

MOD-03 - Áp dụng hành động điều hành

Bảng 54 - Đặc tả MOD-03

Trường	Đặc tả
Dịch vụ sở hữu	Mạng xã hội điều phối; dịch vụ nguồn áp dụng
Tác nhân chính	Người điều hành
Điều kiện trước	Báo cáo InReview, người thực hiện có quyền và If-Match còn đúng.
Luồng chính	Ghi moderation_action bất biến + Outbox ModerationActionRequested -> dịch vụ nguồn kiểm tra/áp dụng lập an toàn -> phát Completed hoặc Rejected -> cập nhật report.
Kiểm tra và phân quyền	Không được điều hành đối tượng có thứ bậc cao hơn; action_type theo target_type; reason bắt buộc; hành động tạm thời có expires_at.
Lỗi và trường hợp biên	Event giao lập không áp dụng hai lần; dịch vụ nguồn từ chối giữ báo cáo InReview và ghi lý do; timeout được cảnh báo.

MOD-04 - Đóng báo cáo và kiểm toán

Bảng 55 - Đặc tả MOD-04

Trường	Đặc tả
Dịch vụ sở hữu	Mạng xã hội - khối điều hành
Tác nhân chính	Người điều hành
Điều kiện trước	Không còn hành động ở trạng thái chờ.
Luồng chính	Ghi kết luận -> chuyển Closed/Rejected -> đặt thời hạn evidence -> tạo thông báo phù hợp cho người báo cáo mà không lộ thông tin nội bộ.
Kiểm tra và phân quyền	If-Match; audit append-only; chỉ admin đặc biệt được reopen và phải nêu lý do.
Lỗi và trường hợp biên	Đóng lập trả trạng thái hiện tại; không xóa audit khi target hoặc account bị xóa.

30. Sao lưu, khôi phục và ngân sách tài nguyên

Mục tiêu được thiết kế cho môi trường một nút. Bản sao lưu phải nằm ngoài volume đang chạy; nếu cùng ổ đĩa hoặc cùng máy chủ thì không được tính là bản sao chống mất máy.

30.1 Mục tiêu RPO/RTO

Bảng 56 - Mục tiêu RPO và RTO

Phạm vi	RPO	RTO	Bảng chứng khôi phục
P0 - Account/Social/Chat/Feed	<= 24 giờ	<= 4 giờ	Khôi phục PostgreSQL, projection và secret; kiểm tra đăng nhập, bài viết, tin nhắn.
Media object	<= 24 giờ	<= 8 giờ	Khôi phục metadata trước; object theo backup; asset thiếu được đánh dấu và đối soát.
Commerce	<= 24 giờ	<= 8 giờ	Đối soát order/payment mock và inventory; không phát lại thanh toán ngoài ý muốn.
AI/Search/OpenSearch	Có thể tạo lại	<= 24 giờ	Khôi phục source metadata/job; rebuild embedding/index theo batch.
Kafka	Tối thiểu 7 ngày retention	<= 4 giờ	Outbox là nguồn phát lại; projection consumer chạy từ checkpoint hoặc replay có kiểm soát.

30.2 Chính sách sao lưu

Bảng 57 - Chính sách sao lưu và kiểm thử khôi phục

Thành phần	Cách sao lưu	Lưu giữ	Kiểm chứng
PostgreSQL	pg_dump theo từng database mỗi ngày; backup toàn cụm mỗi tuần	7 ngày + 4 tuần	Restore vào instance tách biệt; chạy migration/checksum và smoke test.
SeaweedFS	Sao chép object + metadata mỗi ngày	7 ngày + 4 tuần	Đối chiếu object_key, size, hash mẫu và MediaAsset.
Cấu hình/secret	Cấu hình không bí mật trong Git; secret export mã hóa theo quy trình	Mỗi thay đổi	Dựng môi trường mới không dùng secret từ log hoặc máy cá nhân.
Kafka	Không xem Kafka là bản sao DB	Retention theo topic	Dùng Outbox và source export để rebuild; backup config/schema.
Diễn tập	Cuối mỗi milestone lớn và tối thiểu mỗi tháng	Lưu biên bản	Đo RPO/RTO thực tế, lỗi phát hiện và hành động khắc phục.

30.3 Ngân sách tài nguyên

Bảng 58 - Ngân sách tài nguyên theo cấu hình

Cấu hình/Thành phần	Ngân sách ban đầu	Phạm vi	Giới hạn
core	4 vCPU / 8 GB RAM / 80 GB SSD	P0 + phần lớn P1; AI/OpenSearch và quan sát đầy đủ tất	50 người dùng mô phỏng; RTC giới hạn nhỏ
demo-full	8 vCPU / 16 GB RAM / 160 GB SSD	Tất cả dịch vụ; Prometheus/Grafana; mô hình AI nhỏ dùng CPU	Bật theo lịch demo, không cam kết production
PostgreSQL	1.5-3 GB RAM	Nhiều database logic, pool giới hạn theo dịch vụ	Cảnh báo pool > 80%, disk > 85%
Kafka	1-2 GB RAM	Một broker, retention 7-30 ngày, payload <= 256 KB	Theo dõi heap, disk và consumer lag

Cấu hình/Thành phần	Ngân sách ban đầu	Phạm vi	Giới hạn
Valkey	256-512 MB	TTL bắt buộc, maxmemory và eviction rõ	Không lưu source-of-truth
LiveKit/coturn	0.5-1.5 GB RAM	Giới hạn room/participant theo load test	CPU/network là ngưỡng chính
Quan sát	1.5-3 GB RAM	Bật theo profile; retention ngắn	Giới hạn cardinality label
AI/Ollama	4-8 GB RAM tùy mô hình	Bounded concurrency; queue; có thể chạy máy riêng	Không nằm trên đường sống của PO

31. Phát hành, di trú lược đồ và quay lui

Bản phát hành được định danh bằng commit bất biến. Không dùng tag latest làm nguồn duy nhất. Di trú lược đồ chạy bằng tác vụ có kiểm soát trước khi mở traffic và phải tương thích với phiên bản ứng dụng đang chuyển đổi.

31.1 Quy tắc di trú và quay lui

Bảng 59 - Quy tắc di trú lược đồ và quay lui

Bước	Quy tắc	Điều kiện an toàn
Mở rộng	Thêm bảng/cột nullable hoặc có default an toàn; thêm index CONCURRENTLY khi phù hợp.	Ứng dụng cũ và mới cùng chạy được.
Chuyển dữ liệu	Backfill theo batch có checkpoint, metric và khả năng tiếp tục.	Không khóa bảng dài; có đối soát số lượng/hash.
Chuyển đọc/ghi	Bật bằng feature flag sau khi dữ liệu đủ; theo dõi lỗi và latency.	Có thể tắt flag mà không mất dữ liệu.
Thu hẹp	Chỉ xóa cột/topic/contract sau ít nhất một chu kỳ phát hành và xác nhận không còn consumer.	ADR và kiểm thử compatibility bắt buộc.
Quay lui code	Chỉ thực hiện nếu schema còn tương thích ngược.	Nếu migration phá vỡ thì ưu tiên roll-forward bằng bản sửa.
Sự kiện	Producer mới chỉ thêm trường optional trong v1; consumer được triển khai trước thay đổi producer.	Thay đổi phá vỡ dùng v2/topic mới và chạy song song.
Sao lưu trước phát hành	Backup hoặc snapshot có kiểm chứng cho migration rủi ro.	Ghi thời điểm, checksum và lệnh restore trong runbook.

31.2 Quản lý cấu hình, phụ thuộc và bí mật

Bảng 60 - Quản lý cấu hình, phụ thuộc và bí mật

Khu vực	Quy tắc	Điều kiện
Phiên bản gói .NET	Quản lý tập trung bằng Directory.Packages.props; khóa major/minor; Dependabot/Renovate chỉ tạo PR.	Mỗi thay đổi phải qua build/test/scan.
Ảnh container	Pin theo digest cho bản phát hành; base image tối thiểu; chạy non-root khi hỗ trợ.	SBOM và scan lưu cùng release.
Cấu hình	appsettings mặc định không chứa bí mật; override bằng biến môi trường; validate khi khởi động.	Thiếu cấu hình bắt buộc phải fail fast.
Bí mật	Kho bí mật hoặc file môi trường bảo vệ; tên secret chuẩn; rotation có runbook.	Không commit, không ghi log, không gửi qua chat/tài liệu.

Khu vực	Quy tắc	Điều kiện
Feature flag	Dùng cho chức năng P2, thay đổi đọc/ghi và tích hợp rủi ro.	Flag có owner, ngày hết hạn và trạng thái mặc định an toàn.
Môi trường	dev/test/staging/prod-demo tách database, topic prefix, credential và bucket.	Không dùng dữ liệu thật trong test; không chia sẻ secret giữa môi trường.

32. Danh mục quyết định kiến trúc

Mỗi quyết định thay đổi ranh giới dữ liệu, hợp đồng công khai, tính nhất quán hoặc hạ tầng phải có ADR riêng trong thư mục docs/adr. Bảng dưới đây là danh mục quyết định đã được khóa cho baseline.

Bảng 61 - Danh mục quyết định kiến trúc

Mã	Quyết định	Lý do	Hệ quả
ADR-001	Một thực thể giao dịch có một dịch vụ sở hữu	Tránh ghi chéo và mơ hồ trách nhiệm	Dịch vụ khác dùng API hoặc projection; không FK/câu query chéo DB.
ADR-002	PostgreSQL theo database logic cho từng dịch vụ	Đơn giản vận hành một nút nhưng giữ boundary	Credential/migration riêng; sự cố instance vẫn là rủi ro chung.
ADR-003	Kafka + Transactional Outbox, at-least-once	Không có distributed transaction	Consumer bắt buộc Inbox/idempotency; duplicate là bình thường.
ADR-004	SignalR cho realtime ứng dụng, LiveKit cho media	Tách thông điệp bền vững khỏi gói audio/video	Kafka không mang media packets; text chat vẫn chạy khi RTC lỗi.
ADR-005	Bảng tin là projection/CQRS	Tối ưu đọc và tránh N+1 gọi dịch vụ	Eventual consistency; phải có rebuild/checkpoint.
ADR-006	Tải tệp trực tiếp bằng URL ký trước	Giảm băng thông backend	Server sinh key, complete phải HEAD/stat và worker kiểm tra magic bytes.
ADR-007	RAG giới hạn theo quyền và nguồn	Ngăn lộ dữ liệu qua AI	AI không query DB dịch vụ khác; context chỉ từ contract đã cấp quyền.
ADR-008	Docker Compose một nút là baseline	Phù hợp thời gian và ngân sách	Không tuyên bố HA; có profile và hướng phát triển rõ.
ADR-009	Điều hành nội dung là mô-đun trong Mạng xã hội	Tránh thêm deployable service trong P1	Chỉ sở hữu metadata báo cáo; dịch vụ nguồn vẫn áp dụng action.
ADR-010	P0/P1/P2 và cổng chất lượng	Bảo vệ khả năng hoàn thành	P2 được cắt trước; không đánh đổi test, bảo mật, backup và tài liệu.

33. Nghiệm thu và hồ sơ bàn giao

Không đánh giá hoàn thành chỉ dựa trên giao diện hoặc đường đi thành công. Mỗi tiêu chí phải có bằng chứng có thể lặp lại: lệnh chạy, báo cáo kiểm thử, trace, metric, ảnh chụp dashboard hoặc dữ liệu đối soát.

33.1 Định nghĩa hoàn thành

Bảng 62 - Định nghĩa hoàn thành

Nhóm	Điều kiện đạt
Chức năng	Mã chức năng có API/event/data/test tương ứng; acceptance đạt; không còn TODO ẩn trên đường chính.
Mã nguồn	Build sạch, format/analyzer đạt, ranh giới tăng và dịch vụ đúng, không secret/debug code.
Dữ liệu	Migration up từ rỗng và từ bản trước; index/constraint/concurrency đúng; seed chỉ cho dev/test.
Hợp đồng	OpenAPI, schema sự kiện và AsyncAPI đồng bộ; không thay đổi phá vỡ không tăng phiên bản.
Kiểm thử	Unit + integration + contract + kịch bản lỗi; P0 bắt buộc 100% acceptance.
Bảo mật	Threat cases chính đạt; quét secret/dependency/container; không Critical/High chưa xử lý.
Quan sát	TraceId/correlationId, log có cấu trúc, metric RED và cảnh báo cho failure mode liên quan.
Khả năng chịu lỗi	Outbox/Inbox, retry/DLQ, fallback và idempotency được chứng minh bằng test.
Vận hành	Docker Compose/profile, healthcheck, backup/restore, migration, rollback và runbook đã diễn tập.
Tài liệu	ERD/UML/API/event/ADR/roadmap phản ánh đúng mã nguồn; không có nội dung lỗi thời hoặc trộn thuật ngữ không cần thiết.

33.2 Kịch bản trình diễn

Bảng 63 - Kịch bản trình diễn và bằng chứng

Bước	Kịch bản	Thao tác	Bằng chứng
1	Dựng hệ thống	Clone -> cấu hình secret -> docker compose up -> migration	Healthcheck toàn bộ; không thao tác tay trong DB.
2	Đăng ký/đăng nhập	Đăng ký, login, refresh rotation, thử reuse token	Token claims đúng; reuse thu hồi họ phiên.
3	Bài viết đến bảng tin	Tạo bài viết, xem Outbox/Kafka/Feed trace	Projection xuất hiện; duplicate event không tạo trùng.
4	Kafka gián đoạn	Tắt broker, tạo bài, bật lại	Ghi cục bộ thành công; Outbox phát sau; alert/metric đúng.
5	Trò chuyện	Gửi message, mất kết nối, reconnect	DB có trước realtime; lịch sử bỏ tin nhận bị lỗi.
6	Phương tiện	Tạo URL, upload, complete, worker xử lý	Backend không nhận bytes; MediaReady; tệp giả bị từ chối.
7	Quyền và RTC	Người không phải thành viên xin token	Bị 403; thành viên đúng quyền kết nối; text chat không phụ thuộc RTC.
8	Điều hành	Báo cáo nội dung, moderator xử lý, người thường thử đọc queue	Audit/action/event đúng; truy cập trái quyền bị chặn.

Bước	Kịch bản	Thao tác	Bảng chứng
9	Xóa tài khoản	Yêu cầu xóa, kiểm tra projection, chạy purge thử	Ấn nhanh, ack đầy đủ, thao tác lặp không lỗi.
10	Khôi phục	Restore backup vào môi trường mới	Đạt RTO mục tiêu và chạy smoke test P0.

33.3 Hồ sơ bàn giao

Bảng 64 - Hồ sơ bàn giao bắt buộc

Nhóm	Thành phần
Mã nguồn	Repository, tag/commit phát hành, README dựng môi trường, quy ước nhánh và commit.
Hợp đồng	OpenAPI từng dịch vụ, AsyncAPI/schema sự kiện, collection Bruno/Postman và ví dụ lỗi.
Dữ liệu	Migration, ERD, seed dev/test, script backup/restore và biên bản restore drill.
Triển khai	Docker Compose profiles, Caddy/YARP config, healthcheck, release/rollback script.
Kiểm thử	Unit/integration/contract/load/security report; k6 scripts; danh sách known limitations.
Quan sát	Dashboard Grafana, alert rules, log/trace query mẫu và runbook xử lý sự cố.
Bảo mật	Threat model, SBOM, kết quả quét, danh sách secret cần cấp và lịch rotation.
Kiến trúc	Tài liệu thiết kế cuối, ADR, risk register, capacity assumptions và future evolution.
Demo	Kịch bản, dữ liệu mẫu, tài khoản theo vai trò, ảnh/video dự phòng khi hạ tầng mạng không ổn định.

Điều kiện khóa bản cuối: toàn bộ P0 đạt G4, không còn lỗi Critical/High, OpenAPI/AsyncAPI đồng bộ, khôi phục và rollback đã diễn tập, tài liệu khớp với mã nguồn.